Republic of Yemen

Ministry of Education and Scientific Research

University of Science and Technology

Faculty of Computing and Information Technology

ACTIT: An AI-Assisted Cyber Threat Intelligence Tool for Integrating Internal Telemetry and External Threat Sources

ACTIT: أداة مدعومة بالذكاء الاصطناعي لاستخبارات التهديدات السيبرانية لدمج بيانات الرصد الأمني الداخلي ومصادر التهديدات الخارجية

Alaaldeen GarAllah AL-Showie	202310102947
Ammar Yahya Mohammed Aikan	202310101030
Munif Ahmed Saleh AL-Omisi	202010100547

Supervised By

Dr. Raed Saeed

A graduation project document submitted to the department of Computer Science in partial fulfilment to the requirements for Bachelor Degree in Cybersecurity and Networking

2026

Abstract

Cyber threat intelligence is often fragmented across external threat sources and internal security telemetry, making it difficult for analysts to obtain a unified and contextualized view of potential threats. This project presents ACTIT: An AI-Assisted Cyber Threat Intelligence Tool for Integrating Internal Telemetry and External Threat Sources, designed to collect, normalize, analyze, correlate, enrich, and present heterogeneous security data within a unified analyst workflow.

ACTIT integrates external cyber threat intelligence with internal security telemetry and provides deterministic indicator extraction, AI-assisted named entity recognition, relationship extraction, cross-source correlation, session-based outlier analysis using Isolation Forest, risk scoring, NVD vulnerability enrichment, MITRE ATT&CK contextualization, STIX 2.1 export, and controlled MISP sharing. The system is implemented through an authenticated analyst interface, centralized backend services, PostgreSQL persistence, controlled integration gateways, role-based access control, and containerized deployment.

Production verification confirmed the principal analyst workflows and the integration of internal and external data sources. A bounded NVD enrichment run successfully processed 28 of 28 selected CVEs across 22 events, with CVSS information available for 25 records and CWE evidence for all 28. Offline BERT evaluation produced original-test exact-span F1 of 0.867546 and unique train-unseen F1 of 0.719566. The latter satisfies the report acceptance criterion, Unique Train Unseen > 70%. These are offline evaluation results rather than live production accuracy.

Overall, ACTIT demonstrates a practical AI-assisted CTI workflow that combines automated processing with analyst review, traceable enrichment, and controlled intelligence sharing.

Authorization

We authorize University of Science and Technology, Faculty of Computing and Information Technology, to supply copies of our graduation project report to libraries, organizations, or individuals on request.

Student Name	Student No.	Signature
Alaaldeen GarAllah AL-Showie	202310102947	
Ammar Yahya Mohammed Aikan	202310101030	
Munif Ahmed Saleh AL-Omisi	202010100547	

Date: / /

Dedication

First and foremost, praise be to **Allah**.

We dedicate this humble effort to our greatest role models, our beloved parents, whose prayers have been our fortress and whose patience has been our guiding light. To our fathers, who taught us that success requires struggle, and to our mothers, the source of tenderness and our endless inspiration. To our brothers and sisters, who stood by us with words of encouragement and support throughout this journey. To our friends and colleagues, who shared the toil of the road and the joy of achievement. To every hand that extended help to us, and to everyone who wished us well.

We dedicate this work to you all.

Acknowledgment

Before and above all, we extend our deepest gratitude to **Almighty Allah** for His blessings, guidance, and strength, which enabled us to successfully complete this project.

We also wish to express our deepest gratitude and appreciation to Dr. Raed Saeed for excellent guidance, kind encouragement, scientific advice, helpful supervision, honest cooperation, and good wishes, which instilled strength in us to make this work possible.

Additionally, we are deeply grateful to our families and friends for their constant support, motivation, and encouragement. Their belief in us has been a great source of strength and inspiration throughout our years of study and the completion of this project.

Finally, we would like to express our sincere gratitude to everyone who contributed to this project, whether through direct involvement or indirect support. Your help has been invaluable to its success.

Supervisor Certification

We certify that the preparation of this project entitled “ACTIT: An AI-Assisted Cyber Threat Intelligence Tool for Integrating Internal Telemetry and External Threat Sources”, prepared by **Ammar Aikan, Alaaldeen AL-Shuwaie , Munif AL-Omisi** was made under my supervision in the Department of Computer Science in partial fulfillment of the requirements for the Bachelor Degree in Cybersecurity and Networking.

Supervisor Name: Dr. Raed Saeed

Signature:

Date: / /

Examination Committee

Project Title: ACTIT: An AI-Assisted Cyber Threat Intelligence Tool for Integrating Internal Telemetry and External Threat Sources

Supervisor

No.	Name	Position	Signature
1	Dr. Raed Saeed	Faculty member	

Examination Committee

No.	Name	Position	Signature
1	Prof. Belal AL-Fuhaidy	Dean of the College	
2	Dr. Nuseibah Maqtari	Faculty member	

Head of Department

Dr. Nabeel AL-Mekhlafy

Table of Contents

Abstract ..... **I**
Authorization ..... **II**
Dedication ..... **III**
Acknowledgment ..... **IV**
Supervisor Certification ..... **V**
Examination Committee ..... **VI**
Table of Contents ..... **VII**
List of Figures ..... **XI**
List of Tables ..... **XII**
List of Abbreviations ..... **XIII**
Chapter 1: **Introduction** **1**
1.1 Context and Motivation **2**
1.2 Problem Statement **2**
1.3 Aim, Objectives, and Contributions **3**
1.3.1 Primary Objective 3
1.3.2 Secondary Objectives 3
1.3.3 Project Deliverables 4
1.4 Scope and Boundaries **4**
1.4.1 Controlled Dark-Web Collection Boundary 5
1.5 Research and Engineering Methodology **5**
1.6 Report Organization **7**
Chapter 2: **Background and Literature Review** **8**
2.1 Cyber Threat Intelligence Foundations **9**
2.2 CTI Representation, Knowledge, and Sharing **10**
2.3 NLP, BERT, and Named Entity Recognition for CTI **10**
2.4 Anomaly Detection and Isolation Forest **11**
2.5 Literature Review **11**
2.5.1 AI-Based Holistic Framework for Cyber Threat Intelligence Management 11
2.5.2 AI-Enhanced CTI Processing Pipeline 12
2.5.3 Technical Threat Intelligence Survey 12
2.5.4 Literature Review Comparison 13
2.6 Research Gap and ACTIT Positioning **13**
Chapter 3: **Requirements and Verified System Architecture** **15**
3.1 Stakeholders, Roles, and Use Cases **16**

3.2 Functional Requirements **18**
3.3 Non-Functional, Security, and Operational Requirements **19**
3.4 Verified High-Level System Architecture **20**
3.4.1 Internal Acquisition Domain 22
3.4.2 External Acquisition Domain 23
3.4.3 Processing and Analytics Domain 23
3.4.4 Enrichment and Knowledge Domain 23
3.4.5 Analyst and Output Domain 23
3.5 Production Context and Trust Boundaries **24**
3.6 Technology Stack and Selection Rationale **25**
3.6.1 Programming Languages 25
3.6.2 Frontend 26
3.6.3 Backend and API 26
3.6.4 Data Processing and Machine Learning 26
3.6.5 Persistence 26
3.6.6 Integrations and Reporting 26
3.7 Requirements Traceability and Scope Status **27**
Chapter 4: **Detailed System Design** **29**
4.1 Design Principles and Component Decomposition **30**
4.2 External Acquisition and Durable Handoff **30**
4.3 CTI Processing and Intelligence Lifecycle **33**
4.4 Internal Telemetry, Sessionization, and Anomaly Design **35**
4.5 Data Architecture and Persistence **36**
4.6 API and Integration Design **37**
4.7 Security Architecture **38**
4.8 ACTIT BERT NER Model **39**
4.9 Analyst Investigation and Governance Workflow **40**
4.10 Interoperability and Sharing Governance **43**
4.11 Failure, Retry, and Recovery Design **43**
Chapter 5: **Implementation** **45**
5.1 Implementation Environment and Repository Organization **46**
5.2 Frontend and Analyst Workspace **46**
5.3 Central FastAPI Backend **49**
5.4 External Sources, Gateway, and Durable Ingestion **49**
5.5 Preprocessing, Extraction, Correlation, and Risk **52**

5.5.1 Cleaning, Normalization, and Privacy 52
5.5.2 Deduplication 53
5.5.3 CTI Relevance Classification 53
5.5.4 Entities, Observables, and ATT&CK Candidates 53
5.5.5 Relationship Extraction 54
5.5.6 Normalized CTI Objects 54
5.6 Internal Telemetry and Anomaly Implementation 55
5.7 Vulnerability, ATT&CK, STIX, and MISP Services 56
5.8 ACTIT BERT NER Implementation 56
5.9 Data Persistence and Audit Implementation 57
5.10 Security Controls in Code and Containers 57
5.11 Deployment, Operations, and Release Management 58
5.12 Implementation Summary 58
Chapter 6: **Evaluation, Production Verification, and Discussion 59**
6.1 Evaluation Questions and Evidence Classes 60
6.2 Functional and Integration Test Evidence 60
6.2.1 Data Collection 60
6.2.2 Preprocessing and Deduplication 60
6.2.3 CTI Relevance Classification 61
6.2.4 NER and IoC Extraction 61
6.2.5 Relationship Extraction 62
6.2.6 Normalized CTI Objects 62
6.2.7 Historical Regression Boundary 62
6.3 BERT/NER Evaluation 63
6.3.1 BERT Supervision and Training Configuration 63
6.3.2 Exact-Span Entity Results 64
6.3.3 Dataset Integrity and Generalization Boundaries 65
6.3.4 Interpretation and Production Transition 66
6.4 Internal Session and Outlier Evaluation 66
6.5 Production Deployment and Readiness Verification 67
6.6 Verified Analyst Workflows 69
6.7 Verified NVD Enrichment Workflow 75
6.8 NER Transition: Captured Deployment versus Final Architecture 77
6.9 Repository, Report, and Production Discrepancies 78
6.10 Discussion and Threats to Validity 78

6.11 Chapter Summary **79**
Chapter 7: **Conclusions and Future Work** **80**
7.1 Project Summary **81**
7.2 Principal Contributions **81**
7.3 Consolidated Limitations **81**
7.4 Final NER Promotion and Post-Deployment Verification **82**
7.5 Future Work **82**
7.6 Conclusion **83**
References **84**
Appendix A: Verification and Version Ledger **86**
Appendix B: Implementation Evidence Register **87**
Current Evidence Boundaries **90**
Appendix C: ACTIT Final NER Model Evidence and Deployment Transition **91**
C.1 Evidence Scope **91**
C.2 Adopted BERT Model and Evaluation **91**
C.2.1 Adopted BERT Model 91
C.3 Training and Quality Gates **93**
C.4 Captured Production and Benchmark Boundary **94**
C.5 Supplementary Model Figures **95**
Appendix D: Supplementary Production Interface Evidence **99**

List of Figures

Figure 1-1. Project Methodology Cycle 6
Figure 3-1. ACTIT Use Case Diagram 17
Figure 3-2. ACTIT Context Diagram — Level 0 20
Figure 3-3. ACTIT Context Diagram — Level 1 21
Figure 3-4. Verified ACTIT system architecture 24
Figure 3-5. Production deployment topology 25
Figure 4-1. Durable External-to-Central ingestion sequence 31
Figure 4-2. External CTI Ingestion and Durable Central Commit — UML Sequence Diagram 32
Figure 4-3. CTI processing and intelligence pipeline 33
Figure 4-4. ACTIT CTI Lifecycle Activity Diagram 34
Figure 4-5. Internal telemetry, sessionization, and outlier pipeline 36
Figure 4-6. Production-aligned conceptual ER diagram 37
Figure 4-7. Docker and network trust boundaries 39
Figure 4-8. ACTIT BERT NER Model 40
Figure 4-9. Analyst investigation and governance workflow 41
Figure 4-10. ACTIT Analyst Investigation User Flow 42
Figure 4-11. MISP governance workflow 43
Figure 4-12. Release, backup, and rollback flow 44
Figure 5-1. Processing Center in a safe idle state 48
Figure 5-2. External Sources registry 49
Figure 5-3. Successful dark-web source collection and accepted record evidence 52
Figure 6-1. Original-test performance summary for BERT 65
Figure 6-2. Authenticated ACTIT dashboard accessed through the public HTTPS Funnel endpoint 68
Figure 6-3. Authenticated System Readiness view 69
Figure 6-4. Global Intelligence Search 70
Figure 6-5. Threat Event Details 71
Figure 6-6. Threat Storyline 72
Figure 6-7. MITRE ATT&CK review candidate 73
Figure 6-8. MISP governance and delivery boundary 74
Figure 6-9. Production MISP event records in the operational sharing environment 75
Figure 6-10. NVD enrichment before the bounded analyst action 76
Figure 6-11. NVD enrichment after successful persistence 77
Figure C-1. ACTIT BERT NER Model and dated deployment transition 92
Figure C-2. BERT WordPiece supervision 92
Figure C-3. BERT validation exact-span entity F1 at the selected epoch 93
Figure C-4. BERT original-test and unique train-unseen F1 94
Figure C-5. BERT performance on the original test split 95
Figure C-6. Per-entity-class exact-span F1 for BERT 96
Figure C-7. BERT unique train-unseen acceptance criterion 97
Figure C-8. Word-token metrics excluding the O class 97
Figure C-9. BERT validation-loss change after epoch three 98
Figure C-10. Recorded CPU training duration for BERT 98
Figure D-1. Review governance queue 99
Figure D-2. Internal Sources overview 100
Figure D-3. Observables and Indicators 100
Figure D-4. Outlier Sessions 101
Figure D-5. Tailscale Funnel machine status for controlled public ACTIT defense access 101
Figure D-6. ACTIT frontend reached through the public HTTPS Funnel endpoint 102

List of Tables

Table 2-1. Literature review comparison 13
Table 2-2. Scientific concepts and verified ACTIT realization 14
Table 3-1. Roles and principal workflows 16
Table 3-2. Internal Telemetry Source Inventory 22
Table 3-3. Verified production service inventory 24
Table 3-4. Technologies used in the implemented CTI processing components 27
Table 3-5. Requirements traceability and verified scope 28
Table 4-1. Internal Session and Isolation Forest Processing Stages 35
Table 4-2. Major API groups and authorization boundaries 37
Table 5-1. External CTI Source and Connector Inventory 51
Table 5-2. Internal Session Feature Vector 55
Table 5-3. Security controls and evidence boundaries 57
Table 6-1. Data collection test cases 60
Table 6-2. Preprocessing and duplicate-detection test cases 60
Table 6-3. CTI relevance classification test cases 61
Table 6-4. NER and IoC extraction test cases 61
Table 6-5. Relationship extraction test cases 62
Table 6-6. Normalized CTI object test cases 62
Table 6-7. Version-scoped regression evidence 62
Table 6-8. BERT training and evaluation configuration 63
Table 6-9. Exact-span entity results for the ACTIT BERT NER Model 64
Table 6-10. DNRTI dataset audit and quality-gate evidence 65
Table 6-11. Representative stored NVD enrichment evidence 75
Table 6-12. Repository, production, and submission-state differences 78
Table A-1. Verification and version ledger 86
Table B-1. Verified implementation evidence register 87
Table C-1. BERT evaluation and deployment transition 91

List of Abbreviations

Acronym	Definition
ACTIT	AI-Assisted Cyber Threat Intelligence Tool
AI	Artificial Intelligence
API	Application Programming Interface
ATT&CK	Adversarial Tactics, Techniques, and Common Knowledge
BERT	Bidirectional Encoder Representations from Transformers
CTI	Cyber Threat Intelligence
CVE	Common Vulnerabilities and Exposures
CVSS	Common Vulnerability Scoring System
CWE	Common Weakness Enumeration
DDoS	Distributed Denial of Service
DSR	Design Science Research
ETag	Entity Tag
HMAC	Hash-Based Message Authentication Code
IDS	Intrusion Detection System
IoA	Indicator of Attack
IoC	Indicator of Compromise
IP	Internet Protocol
JWT	JSON Web Token
MISP	Malware Information Sharing Platform
MITRE	MITRE Corporation
ML	Machine Learning
NER	Named Entity Recognition
NLP	Natural Language Processing
NVD	National Vulnerability Database
RBAC	Role-Based Access Control
SOC	Security Operations Center
SSRF	Server-Side Request Forgery
STIX	Structured Threat Information eXpression
TAXII	Trusted Automated eXchange of Intelligence Information
TTP	Tactics, Techniques, and Procedures

Chapter 1:

Introduction

1.1 Context and Motivation

Digital services, cloud infrastructure, and interconnected systems have expanded both the volume of operational data and the range of threats that security teams must examine. Ransomware, phishing, distributed denial-of-service attacks, exploitation of public vulnerabilities, and persistent intrusion campaigns can leave evidence across public reports, vulnerability records, network services, authentication logs, and endpoint or sensor telemetry.

Cyber Threat Intelligence (CTI) provides value when these observations are processed with enough provenance and context to support an investigation. Collection alone is insufficient: heterogeneous records must be validated, normalized, deduplicated, related to technical observables and entities, enriched where appropriate, and presented in a form that analysts can review.

Artificial intelligence and machine-learning methods can assist selected parts of this process. In ACTIT, BERT-based named entity recognition supports cybersecurity-entity extraction, while Isolation Forest supports session-level outlier analysis of internal telemetry. Deterministic validation, evidence retention, and analyst review remain part of the workflow because model output is one source of investigative evidence rather than an autonomous security judgment.

ACTIT is an implemented CTI tool that brings bounded external-source collection and internal security telemetry into a shared processing and investigation environment. A React analyst interface, FastAPI services, the authenticated CTI Gateway, PostgreSQL persistence, enrichment services, and governed STIX and MISP outputs provide the engineering basis for this integration. The later chapters document the architecture, implementation, evaluation evidence, and verified production behavior in detail.

1.2 Problem Statement

Modern security operations produce large volumes of heterogeneous data, yet the information required for an investigation is often distributed across separate tools. External threat reports, vulnerability records, public advisories, honeypot observations, authentication logs, and web-access events use different structures, semantics, and levels of context. This fragmentation makes it difficult to build a coherent view of a developing threat.

Raw observations also have limited investigative value when viewed in isolation. An IP address, domain, CVE identifier, failed login, honeypot connection, or web request becomes

more useful when it can be traced to its source and related to threat events, entities, vulnerabilities, ATT&CK context, correlations, and earlier evidence. Without that context, analysts must reconstruct relationships manually and may lose the provenance needed to explain how an intelligence record was produced.

Analysts therefore spend substantial effort normalizing records, checking indicators, comparing sources, enriching vulnerabilities, and deciding which information is suitable for export or sharing. When these tasks are split across independent systems, the investigation is interrupted by repeated searches and format conversion. The operational need is not simply to collect more data, but to preserve evidence while turning different observations into reviewable intelligence.

The central engineering problem is how to transform heterogeneous internal and external security observations into contextualized, traceable, and reviewable cyber threat intelligence while preserving provenance and analyst oversight. ACTIT addresses this problem through an integrated workflow for collection, normalization, extraction, analysis, enrichment, investigation, and controlled sharing. Its automated methods assist the analyst while retaining explicit evidence and governance boundaries.

1.3 Aim, Objectives, and Contributions

1.3.1 Primary Objective

To design and implement ACTIT as an integrated tool that transforms heterogeneous internal telemetry and external threat sources into contextualized, traceable, and reviewable cyber threat intelligence while preserving analyst oversight.

1.3.2 Secondary Objectives

1. Collect and normalize verified internal telemetry and external CTI sources through controlled acquisition paths.

2. Extract validated technical observables, cybersecurity entities, and supported relationships from normalized evidence.

3. Apply the ACTIT BERT NER Model and session-level anomaly analysis where their evidence and operating conditions are appropriate.

4. Preserve source provenance and processing evidence in the authoritative PostgreSQL repository.

5. Provide authenticated workflows for search, event investigation, correlation review, vulnerability enrichment, ATT&CK context, and audit review.

6. Support bounded STIX export and analyst-governed sharing to MISP.

1.3.3 Project Deliverables

The system and architecture deliverables comprise a working ACTIT deployment with a React analyst interface, central FastAPI services, an authenticated CTI Gateway, separate external-source and internal-telemetry acquisition paths, PostgreSQL persistence, container and network boundaries, health checks, persistent storage, release management, backups, and rollback procedures.

The processing and analytics deliverables comprise cleaning, normalization, privacy handling, deduplication, CTI relevance classification, deterministic observable extraction, BERT-based NER, relationship extraction, correlation, deterministic risk scoring, NVD enrichment, ATT&CK candidate mapping, and internal-session outlier analysis.

The analyst, security, and evaluation deliverables comprise readiness and processing views, source and review governance, intelligence search, threat-event and storyline investigation, observables, enrichment evidence, correlations, outlier sessions, STIX export, governed MISP sharing, role-based administration and audit functions, authentication, Gateway request authentication, rate limiting, SSRF safeguards, preserved automated tests, BERT experiment artifacts, internal-analysis evidence, authenticated production verification, and the bounded NVD enrichment run.

Project Repository: https://github.com/AmmarAikan/CTI-Tool.git

1.4 Scope and Boundaries

ACTIT covers two acquisition domains. The internal domain includes deployed Dionaea honeypot, host-authentication, and web-access telemetry. A Wazuh connector is implemented in source but was not deployed in the verified production baseline. The external domain includes verified feed, advisory, vulnerability, public-web, social-source, manually submitted URL, and operator-approved onion-source connectors.

The implemented scope includes normalization, privacy handling, stable identity and deduplication, relevance classification, observable and entity extraction, relationship extraction, authoritative persistence, correlation, deterministic risk, internal session analysis, NVD enrichment, ATT&CK candidate mapping, analyst investigation, STIX 2.1 export, and

governed MISP sharing. PostgreSQL remains the authoritative ACTIT repository; MISP is an optional sharing destination.

The project is evaluated as a single-VPS graduation-project deployment. TAXII is included as standards background and future interoperability work, rather than as a deployed ACTIT transport. The report does not generalize the verified operating evidence into claims of enterprise-scale throughput or universal detection performance.

The stakeholders are viewers, analysts, and administrators. Viewers receive read-oriented access; analysts investigate, enrich, export, review, and share within authorized routes; administrators manage authorized users, configuration exposed by the product, integration status, and audit evidence. Backend authorization dependencies define the effective permissions.

1.4.1 Controlled Dark-Web Collection Boundary

Dark-web collection is restricted to explicitly configured and operator-approved onion sources. The collector performs bounded HTTP GET requests through the configured Tor path, extracts textual content, applies the established preprocessing pipeline, and stores normalized CTI records with their source context.

The design excludes account creation, authentication bypass, form submission, interaction with threat actors, credential collection, purchases, transactions, and unrestricted link traversal. It is therefore a controlled acquisition path for approved sources rather than a general-purpose dark-web surveillance system.

1.5 Research and Engineering Methodology

The project follows the six activities of Design Science Research: problem identification, definition of objectives, design and development, demonstration, evaluation, and communication [16]. This method is suitable because ACTIT is both a technical artifact and the subject of an evidence-based evaluation.

1. Problem identification and motivation. The study identifies fragmentation between internal telemetry, external intelligence, enrichment, investigation, and sharing as the engineering problem addressed by ACTIT.

2. Definition of objectives. Functional, security, operational, and evidence-preservation requirements are derived from the problem and the intended analyst roles.

3. Design and development. The work defines and implements the acquisition domains, processing pipeline, data model, analyst interface, integrations, security controls, and ACTIT BERT NER Model.

4. Demonstration. The artifact is operated in the verified VPS deployment and exercised through preserved tests, existing production records, authenticated read-only interface workflows, and bounded operational evidence.

5. Evaluation. Automated test results, versioned BERT artifacts, production-service observations, interface verification, and the bounded NVD run are examined according to their defined scope. Precision, recall, and F1 are reported only for experiments that define those metrics.

6. Communication. The architecture, implementation decisions, evaluation results, limitations, and deployment evidence are presented in this report and its appendices.

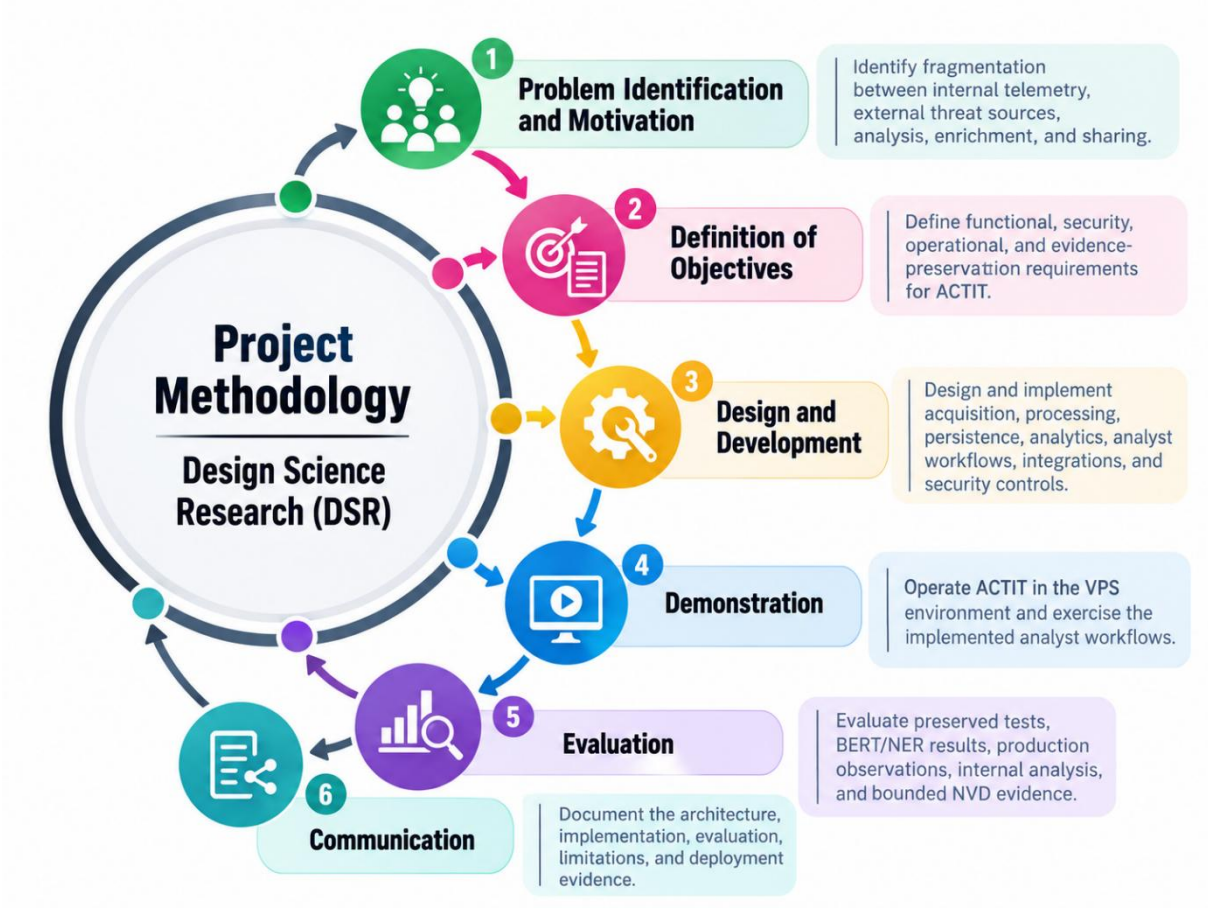


Figure1-1. Project Methodology Cycle

1.6 Report Organization

This report is organized into seven main chapters. Each chapter builds on the previous one, progressing from the project problem and scientific background to system design, implementation, evaluation, and final conclusions. The following overview summarizes the purpose of each chapter.

Chapter 1: Introduction
Introduces the project context, problem statement, objectives, scope, controlled dark-web boundary, research methodology, and overall organization of the report.

Chapter 2: Background and Literature Review
Presents the foundations of cyber threat intelligence, CTI representation and sharing, BERT-based named entity recognition, and anomaly detection, then reviews related studies and identifies the research gap addressed by ACTIT.

Chapter 3: Requirements and Verified System Architecture
Defines the system stakeholders, functional and non-functional requirements, major architectural components, trust boundaries, technology stack, and requirements traceability.

Chapter 4: Detailed System Design
Describes the detailed design of external and internal acquisition, CTI processing, persistence, APIs, security controls, the adopted BERT model, analyst workflows, interoperability, and recovery mechanisms.

Chapter 5: Implementation
Explains how the frontend, backend, ingestion services, processing pipeline, internal telemetry analysis, enrichment services, persistence, security controls, and deployment mechanisms were implemented.

Chapter 6: Evaluation, Production Verification, and Discussion
Evaluates functional evidence, BERT/NER results, internal session analysis, production deployment, analyst workflows, NVD enrichment, deployment-state differences, and the limitations affecting interpretation of the results.

Chapter 7: Conclusions and Future Work
Summarizes the main contributions and limitations of ACTIT, outlines the remaining NER deployment-verification requirements, presents future improvements, and concludes the project.

Chapter 2:

Background and Literature Review

2.1 Cyber Threat Intelligence Foundations

Cyber threat information becomes intelligence when evidence is analyzed and communicated with enough context to support a decision. NIST guidance treats CTI sharing as the exchange of indicators, tactics, procedures, security findings, and associated context rather than as the transfer of isolated raw values [6]. ACTIT follows this distinction by retaining source and evidence context and by keeping extracted observables separate from analyst-confirmed malicious indicators.

CTI covers multiple forms of threat-related evidence. Indicators of Compromise (IoCs) are technical observables associated with suspicious or malicious activity, such as IP addresses, domains, URLs, file hashes, and CVE identifiers. Tactics, Techniques, and Procedures (TTPs) describe higher-level adversary behavior and are commonly related to knowledge frameworks such as MITRE ATT&CK. Together with entities, relationships, campaign context, and vulnerability information, these elements help build a more complete view of the threat landscape [1].

The CTI lifecycle is commonly organized into a sequence of connected stages. It begins with planning and direction, where intelligence requirements and priorities are defined. Collection then gathers relevant information from sources such as OSINT, security telemetry, advisories, vulnerability repositories, and approved threat-intelligence sources. Processing transforms the collected material into usable form through activities such as parsing, normalization, deduplication, filtering, and structuring.

During analysis, human expertise and automated techniques are used to identify meaningful patterns, relationships, indicators, and potential threats. Dissemination then delivers the resulting intelligence to the appropriate stakeholders or security systems in a suitable format. The final feedback stage evaluates the usefulness of the intelligence and refines future requirements and collection priorities, creating an iterative cycle [1], [3].

Cyber threat intelligence is commonly categorized into four levels: strategic, tactical, operational, and technical intelligence. Each level serves different audiences and decision-making needs. Strategic intelligence supports high-level assessment of emerging threats, adversary objectives, and geopolitical risk for executive and governance audiences. Tactical intelligence describes TTPs that help security teams plan defenses against known attack patterns. Operational intelligence provides context about active campaigns, infrastructure, and targeted sectors. Technical intelligence supplies detailed observables and signatures, including

IP addresses, domains, hashes, and vulnerability identifiers, for direct use in security operations and defensive tools [1].

2.2 CTI Representation, Knowledge, and Sharing

Cyber threat information can be represented and exchanged through standardized formats and protocols. STIX 2.1 defines a machine-readable language and serialization for cyber threat and observable information [7]. TAXII 2.1 defines an application-layer RESTful protocol for communicating CTI, including STIX content, between authorized systems [8]. The standards address different layers: STIX describes the information, while TAXII defines a transport interface.

MISP is an open-source platform for structuring, analyzing, correlating, and sharing threat-intelligence events and attributes [10]. MITRE ATT&CK is a knowledge base of adversary behavior based on real-world observations; it organizes behavior through tactics, techniques, sub-techniques, and procedures [9]. STIX, TAXII, MISP, and ATT&CK therefore support complementary needs: information representation, exchange, governed collaboration, and adversary-behavior knowledge.

Within ACTIT, PostgreSQL is the authoritative operational repository. STIX 2.1 provides a bounded export representation, MITRE ATT&CK supports evidence-bearing technique mappings, and MISP is a governed sharing destination. TAXII is discussed as a CTI exchange protocol but is not implemented as a deployed ACTIT transport.

Vulnerability identifiers and evidence use related but distinct vocabularies. The CVE Program catalogs publicly disclosed vulnerabilities [20]; NVD adds analysis and structured metadata [17]; CVSS 3.1 specifies severity scoring [18]; and CWE classifies software and hardware weakness types that can lead to vulnerabilities [19]. ACTIT preserves these boundaries when presenting stored NVD evidence.

2.3 NLP, BERT, and Named Entity Recognition for CTI

Selected AI/ML methods can assist CTI tasks such as NER and internal outlier analysis. ACTIT keeps those methods distinct from deterministic IoC and relationship extraction, risk scoring and lexical event correlation. Automatic summarization and a general malware classifier are outside its inspected implementation [1], [2].

NER identifies and classifies entity spans in text, while BERT supplies bidirectional contextual representations that can be fine-tuned for token classification [11], [12]. BIO tagging

records whether a token begins an entity, continues an entity, or lies outside an entity [13]. In CTI, domain-specific entity labels are required because general-purpose person and location categories do not capture malware, attack patterns, tools, organizations, and other security concepts.

The DNRTI study evaluates transformer-based NER on more than 300 open-source threat-intelligence reports [14]. ACTIT uses the preserved DNRTI splits and a BERT token-classification architecture, but reports its own parsing decisions, exact-span metrics, overlap audit, and fallback design. ACTIT also separates NER from deterministic IoC extraction, relationship rules, risk scoring, and lexical correlation. The final architecture and its evidence are described in Chapters 4–6.

2.4 Anomaly Detection and Isolation Forest

Isolation Forest isolates unusual observations through random feature and split selection; shorter average isolation paths indicate points that are easier to separate from the sample [15]. ACTIT applies this method to numeric session features derived from structured internal telemetry when the batch is suitable and uses a transparent rule-based fallback for small batches. This implementation behavior does not by itself establish detection accuracy.

2.5 Literature Review

2.5.1 AI-Based Holistic Framework for Cyber Threat Intelligence Management

Spyros et al. (2025) identify fragmentation across the CTI lifecycle as a major challenge, particularly when collection, analysis, enrichment, and sharing are handled by disconnected tools. To address this issue, they propose ThreatWise AI, a modular framework that integrates OSINT collection, NLP-based processing, analytical methods, enrichment, and MISP-supported sharing [1].

ThreatWise AI uses Python-based components to gather public threat information and applies NLP, including NER, to extract IoCs and other attributes from unstructured text. The resulting information is structured for downstream analysis, enrichment, storage, and sharing through systems such as MISP [1].

The framework uses MISP to organize and enrich intelligence and combines direct attribute correlation, such as matching IP addresses, with analytical methods intended to reveal less obvious relationships. The study illustrates the framework through naval, smart-city, and healthcare application scenarios and presents it as an integrated CTI lifecycle approach [1].

The study is relevant to ACTIT because it treats AI-assisted analysis as one stage within a broader modular CTI lifecycle. ACTIT adopts that integration principle while using PostgreSQL as its authoritative datastore and MISP as a selective, analyst-controlled sharing destination. ACTIT also combines continuously available application and internal-telemetry services with bounded, scheduled external collection rather than treating every stage as fully event-driven.

Strength: The study presents an integrated CTI framework that spans multiple lifecycle stages and illustrates how AI-assisted analysis can be combined with enrichment and sharing. **Limitation:** The reported architecture relies on batch-oriented processing for parts of the workflow, and its evaluation context limits the extent to which the reported results can be generalized to every production environment.

2.5.2 AI-Enhanced CTI Processing Pipeline

Alevizos and Dekker (2024) discuss unstructured CTI processing and propose an AI-enhanced pipeline blueprint. Their opinion article is architectural background, rather than a deployed experiment comparable with ACTIT [2].

The proposed design considers collection, normalization, entity extraction, structured output and human oversight. ACTIT implementation claims are supported separately by the project source and audit evidence [2].

The article discusses potential automation benefits, privacy, bias and transparency. It does not establish a measured reduction of ACTIT analyst workload or enrichment time [2].

2.5.3 Technical Threat Intelligence Survey

Tounsi and Rais (2018) review technical CTI as a response to targeted attacks that are not adequately addressed by signature-only defenses. They argue that conventional signature matching is limited against new or rapidly changing attacks and identify shared, reliable threat intelligence as an additional defensive input. The survey also highlights non-standardized and redundant threat data as barriers to effective analysis [3].

The survey examines CTI categories, the intelligence lifecycle, open and commercial sources, and exchange standards such as STIX and TAXII. It also discusses large-scale analysis, visualization, and information sharing as factors that affect the quality and usability of technical threat intelligence [3].

As a survey, the study provides a conceptual basis for positioning ACTIT rather than an implemented benchmark. Its emphasis on standardized representation and automated analysis

supports ACTIT's structured CTI outputs. ACTIT implements STIX 2.1 export, while TAXII remains a future interoperability extension; no direct performance comparison with the survey is claimed [3].

2.5.4 Literature Review Comparison

Table2-1. Literature review comparison

Reference	Problem Addressed	Methodology / Tools	Key Results	Limitations
Spyros et al. (2025) [1]	Fragmented CTI lifecycle; no unified AI-driven pipeline for gathering, analysis, enrichment, and sharing.	ThreatWise AI framework; MISP, OSINT crawlers, NLP (NER), ML-based anomaly detection, Python scripts; modular pipeline.	Demonstrates an integrated CTI lifecycle combining collection, NLP-assisted analysis, enrichment, and sharing across multiple application scenarios.	Component-level results and application examples are not directly comparable with ACTIT's models or deployment environment.
Alevizos & Dekker (2024) [2]	High volume and velocity of unstructured CTI data overwhelming human analysts in SOC environments.	Opinion article; blueprint for an AI-enhanced CTI pipeline with NLP, structuring and human oversight [2].	Presents an architectural blueprint for applying NLP, structured representation, and human oversight to high-volume unstructured CTI.	Opinion article; does not provide a deployed implementation or quantitative benchmark.
Tounsi & Rais (2018) [3]	Insufficiency of signature-based defences against sophisticated attacks; non-standardised, redundant threat data.	Technical CTI survey; review of TI types, intelligence cycle, STIX/TAXII standards, sources, and sharing platforms.	Synthesizes technical CTI concepts, source-quality concerns, visualization needs, and the role of STIX/TAXII in standardized exchange.	Survey only; no implemented prototype or quantitative benchmark, and some reviewed tooling predates recent AI-assisted methods.

2.6 Research Gap and ACTIT Positioning

The literature presents CTI as a lifecycle that links collection, processing, analysis, dissemination, and feedback, yet implementations often address these stages through separate tools or narrowly scoped pipelines [1], [3]. This separation complicates the movement from unstructured reports and raw observations to intelligence that retains source context and can be reviewed by an analyst.

A related gap concerns the treatment of internal operational telemetry and external threat information. Honeypot records, authentication events, web-access observations, public

advisories, vulnerability records, and threat reports differ in structure and meaning. When their processing histories are not preserved across normalization, extraction, correlation, and enrichment, analysts have difficulty tracing an intelligence conclusion back to its evidence [1]–[3].

The reviewed work also shows that extraction, correlation, enrichment, analyst review, and governed sharing are frequently discussed as distinct capabilities [1], [2]. A coherent analyst-facing workflow must connect those capabilities without treating extracted observables, model output, or automated ATT&CK mappings as confirmed facts. The literature therefore supports an integration problem involving both technical interoperability and evidence governance.

ACTIT addresses this gap by integrating internal security telemetry and external threat intelligence within a common, provenance-preserving workflow that connects automated extraction and analytics with analyst review, enrichment, investigation, and governed sharing. The scientific framework provides lifecycle and NER context, while ACTIT design, implementation, and production evidence are established separately in the chapters that follow.

Table2-2. Scientific concepts and verified ACTIT realization

Scientific concept	ACTIT realization	Evidence boundary
Holistic CTI lifecycle	External and internal acquisition, central processing, PostgreSQL persistence, analyst investigation, and governed sharing.	The primary paper motivates the lifecycle; ACTIT implementation and production evidence establish the realized components.
AI-assisted CTI extraction	Deterministic IoC extraction plus the adopted BERT model for named entity recognition.	Offline model results are separate from production runtime evidence.
Intelligence enrichment	Analyst-controlled NVD/CVE enrichment and evidence-bearing ATT&CK candidates.	No universal enrichment coverage or automatic ATT&CK confirmation is claimed.
Structured exchange and sharing	STIX 2.1 export and selective MISP delivery.	TAXII is background/future work; PostgreSQL remains authoritative.

Chapter 3:

Requirements and Verified System Architecture

3.1 Stakeholders, Roles, and Use Cases

ACTIT defines three user roles: administrator, analyst, and viewer. Administrators manage authorized users, roles, operational configuration, and audit evidence; analysts perform collection, review, investigation, enrichment, export, and governed sharing; viewers receive read-oriented access. Effective authorization is enforced by backend role dependencies rather than interface visibility alone.

The principal analyst path begins with operational readiness and source status, continues through Global Intelligence Search and an existing Threat Event, then pivots to Threat Storyline, observables, ATT&CK candidates, NVD evidence, correlations, outlier context, STIX export, or MISP preview as appropriate. Enrichment, review decisions, source changes, and sharing remain explicit authorized actions rather than automatic consequences of viewing a record.

The formal use-case view summarizes these role boundaries and the supported interactions with external services. Associations indicate a verified route or workflow; a visible control does not supersede backend authorization.

Table3-1. Roles and principal workflows

Role	Principal capabilities	Boundary
Viewer	Read authorized status and intelligence views.	No administrative or state-changing privileges.
Analyst	Operate approved collection/review paths; investigate events; request enrichment; export or prepare governed sharing.	Every write action remains route-authorized and audited where implemented.
Administrator	Manage users and roles; inspect audit/operations; retain analyst capabilities.	Last-administrator protection and backend policy apply.

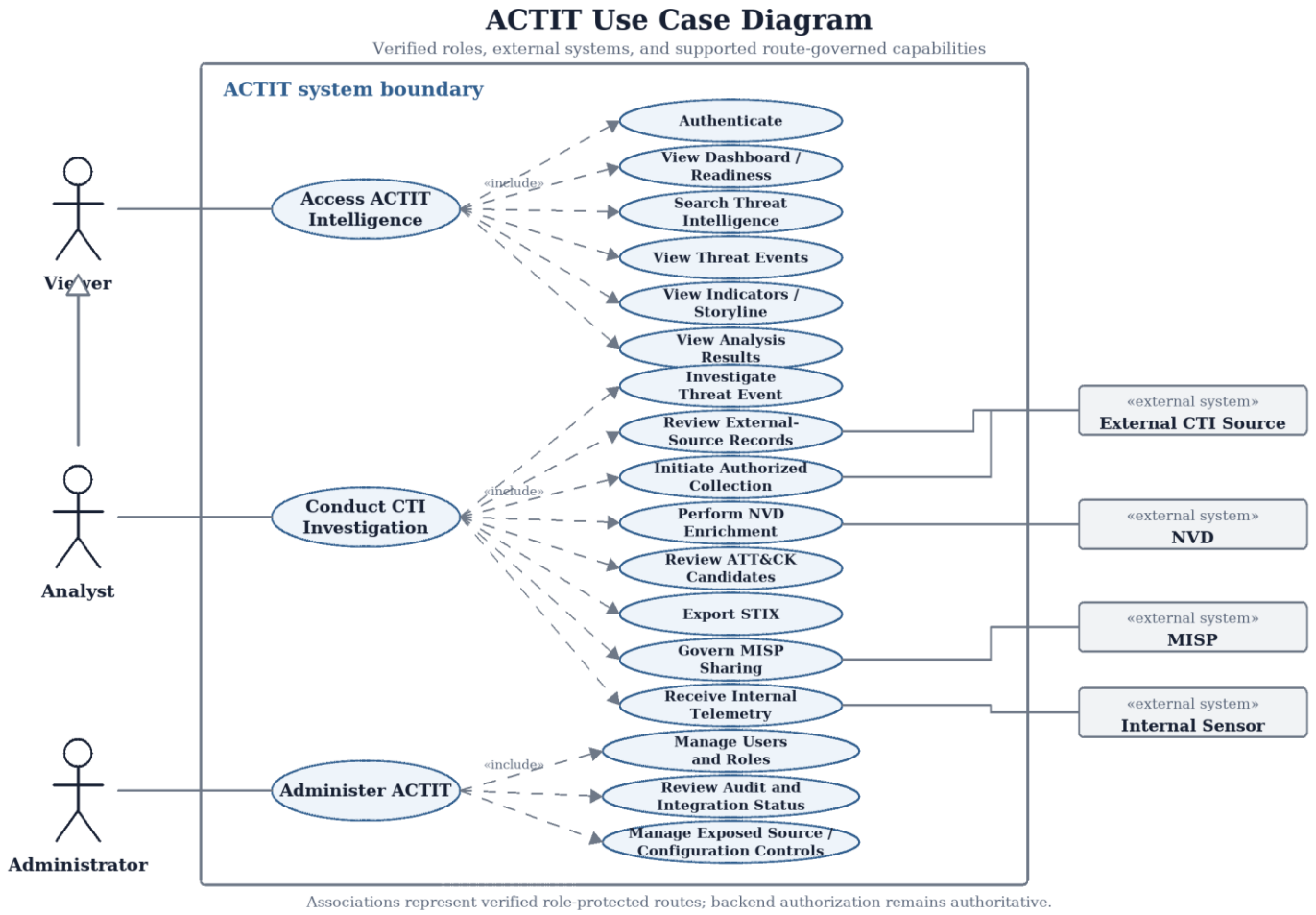


Figure3-1. ACTIT Use Case Diagram

Source: verified backend authorization dependencies, implemented routes, and authenticated production workflows. Associations do not grant permissions beyond backend policy.

3.2 Functional Requirements

Multi-Source Security Data Collection: The tool shall ingest data from supported internal telemetry and external CTI sources while preserving source identity, provenance, and acquisition boundaries.

Log Parsing and Data Preprocessing: The tool shall parse, clean, normalize, validate, and deduplicate collected records before analysis while preserving raw/source references and producing consistent source-independent CTI records.

AI/ML-Assisted Analysis: The tool shall apply BERT for named entity recognition and shall support session-level Isolation Forest analysis with a documented deterministic heuristic for small batches. Deterministic IoC extraction, relevance classification, and risk scoring remain separate from model output.

Threat-Intelligence Extraction and Relationship Mapping: The tool shall extract technical observables and relevant entities, preserve their provenance, identify relationships that support investigation, and present automated ATT&CK mappings as review candidates rather than confirmed TTPs.

Threat Enrichment and Contextual Mapping: The tool shall add context through risk and confidence information, vulnerability evidence, correlation, ATT&CK mapping, STIX 2.1 export, and selective governed sharing.

Centralized CTI Repository: The tool shall persist raw and processed CTI, threat events, indicators, entities, relationships, correlations, outlier sessions, pipeline runs, users, and audit records in a centralized PostgreSQL repository while keeping MISP as a selective sharing destination.

Dashboard and Investigation Views: The tool shall provide authenticated operational status, source, search, event, storyline, indicator, analysis, readiness, and governance views appropriate to the active role.

Evidence, Audit, and Controlled Sharing: The tool shall preserve evidence and provenance for analyst review, enforce role-based access, record auditable actions, and support controlled STIX export and selective MISP delivery without automatically mirroring all PostgreSQL records.

3.3 Non-Functional, Security, and Operational Requirements

Usability: ACTIT shall provide a consistent analyst interface with clear navigation, tables, filters, status indicators, and bilingual-ready layout behavior. The implemented React frontend provides these core interaction patterns; formal accessibility evaluation is outside the current scope.

Performance: ACTIT shall use bounded collection, pagination, asynchronous processing, and model/runtime controls to prevent individual processing tasks from blocking normal analyst workflows. Formal end-to-end latency benchmarking is outside the current evaluation scope.

Security and Access Control: The system shall protect CTI data and administrative functions through authentication, authorization, private service boundaries, and secure secret handling. The current implementation includes bearer authentication, administrator/analyst/viewer roles, audit logging, loopback/private application ports, separated Docker networks, and Tailscale HTTPS for analyst access.

Reliability and Error Handling: The system shall isolate failures so that a malformed record or unavailable source does not stop the entire workflow. External-source jobs use bounded processing and safe error contracts, and production services use health checks, restart policies, and controlled deployment/rollback procedures.

Scalability: The architecture shall permit additional sources and processing modules without redesigning the complete system. The current prototype is modular, but production scaling beyond the verified single-VPS environment is outside the demonstrated project scope.

Maintainability: The codebase shall use modular services, shared contracts, configuration files, tests, and version-controlled deployment artifacts so that individual collectors, models, APIs, or user-interface components can be changed with limited impact on unrelated modules.

Data Integrity and Auditability: The system shall preserve source provenance, normalized records, deterministic identifiers where applicable, and traceable user/system actions. PostgreSQL is the source of truth, audit logs are implemented, and deployment procedures explicitly preserve existing production volumes and database state.

These requirements are evidence-scoped. The report does not claim a formal service-level objective, enterprise high availability, a completed disaster-recovery exercise, or measured end-to-end capacity unless a dated artifact explicitly establishes it.

3.4 Verified High-Level System Architecture

ACTIT comprises a React analyst frontend, a central FastAPI backend, PostgreSQL as the authoritative operational repository, an External Sources service, an authenticated CTI Gateway, internal telemetry collectors, processing and intelligence services, the ACTIT BERT NER Model, and governed external integrations. External and internal acquisition paths converge in the central backend while retaining provenance and distinct preprocessing semantics.

The Level 0 context view treats ACTIT as one system and identifies the external actors, evidence sources, enrichment services, sharing boundary, and authoritative persistence relationship. The Level 1 view then decomposes ACTIT into verified acquisition, access, processing, analytics, persistence, and governed-output subsystems without exposing credentials or internal addresses.

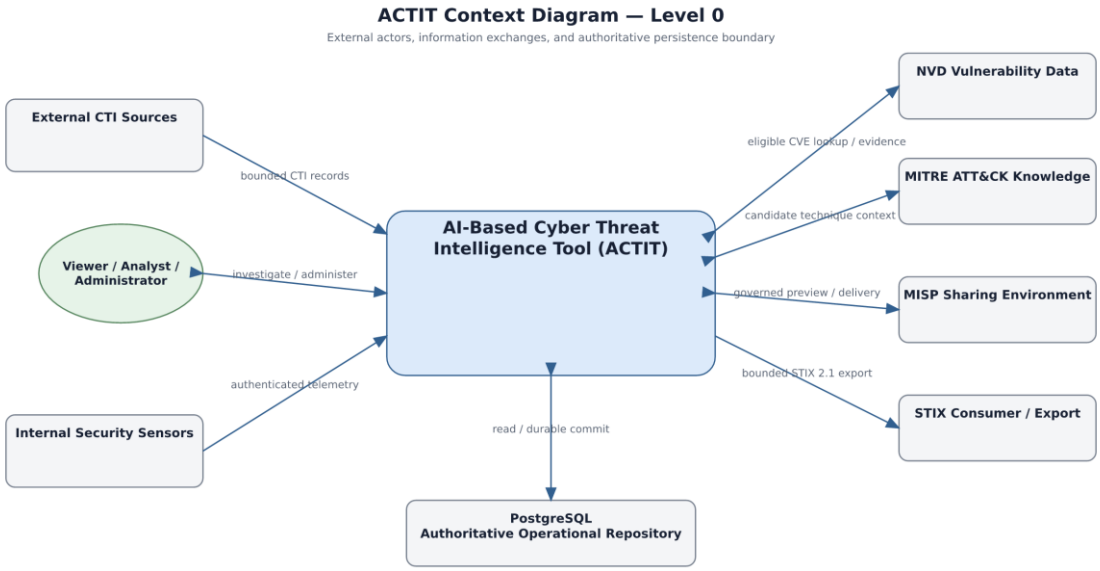


Figure3-2. ACTIT Context Diagram — Level 0

Source: verified system actors, deployed integrations, STIX output, governed MISP sharing, and PostgreSQL authority boundary.

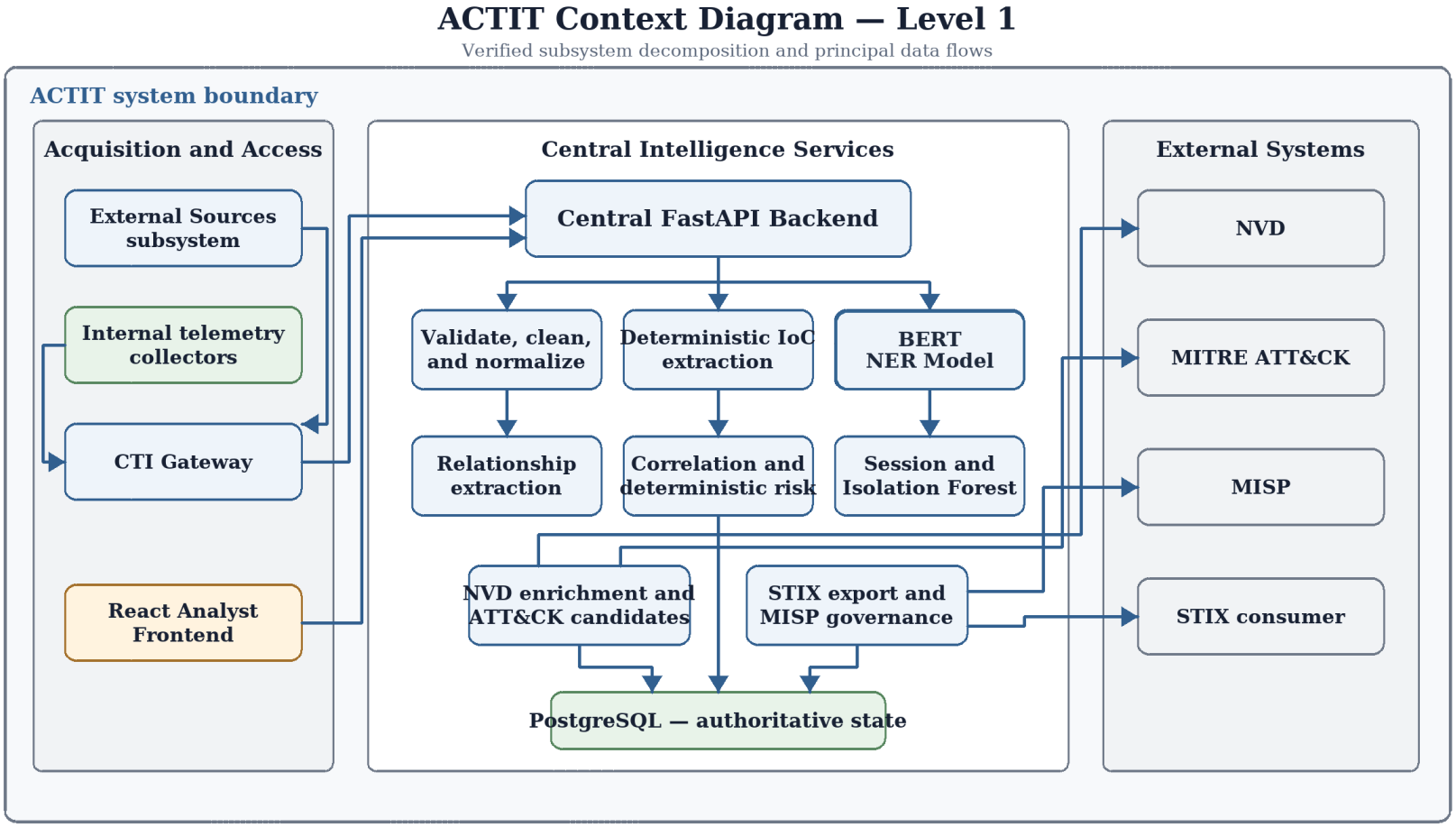


Figure3-3. ACTIT Context Diagram — Level 1

Source: verified implementation and production service relationships. Trust boundaries are conceptual; secrets and sensitive network addresses are intentionally omitted.

3.4.1 Internal Acquisition Domain

The internal component receives security telemetry from the monitored environment. In the verified production baseline, Dionaea honeypot telemetry and lightweight host-auth/web-access streams are active through authenticated gateway paths. The backend also contains a Wazuh ingestion connector that supports alert-file and authenticated indexer workflows; however, the Wazuh Manager/Indexer/Dashboard stack is not deployed in the verified 23 September VPS deployment configuration and is documented as implemented but not deployed.

Internal telemetry groups source type, source name and IP with a 30-minute inactivity gap. Isolation Forest fits on the current batch with 200 trees; fewer than four sessions or unavailable scikit-learn trigger the documented heuristic. Both inliers and outliers may be stored.

Table3-2. Internal Telemetry Source Inventory

Source	Data type	Acquisition path	Normalization / session key	Analysis use	Verified status
Dionaea	Honeypot connection and interaction telemetry	Authenticated Gateway sensor path from JSONL/API input	Structured RawRecord normalization; source type/name/IP; 30-minute inactivity boundary	Session features, outlier analysis, and controlled promotion	Deployed
Host authentication	Authentication successes, failures, and credential-attempt evidence	Authenticated bounded sensor JSON through the Gateway	Sensitive-field handling and normalized records; source type/name/IP session key	Failure and credential-attempt features; analyst session review	Deployed
Web access	HTTP access activity, URLs, methods, destinations, and status evidence	Authenticated bounded sensor JSON with checkpoint/HMAC controls	Normalized records; source type/name/IP; 30-minute inactivity boundary	HTTP, URL, destination, and session-level outlier features	Deployed
Wazuh connector	Alert JSON from file or authenticated indexer workflow	Implemented optional connector path	Shared RawRecord normalization and session pipeline	Would feed the same session/outlier design when configured	Implemented; not deployed in verified baseline

Source: verified internal connectors, Gateway contracts, sessionizer, feature extractor, and production deployment evidence.

3.4.2 External Acquisition Domain

The external component is implemented as a canonical bounded collection subsystem. It supports RSS feeds, CERT/security advisories, vulnerability intelligence, generic crawling/manual routing, Reddit, Hacker News, Telegram public previews, and operator-approved onion sources. Dark-web collection is restricted to explicitly configured sources over Tor and does not perform unrestricted discovery or interaction.

External content is cleaned, privacy-checked, classified for CTI relevance, deduplicated through incremental state, validated against shared contracts, and exported in run-scoped artifacts before authenticated handoff to the central pipeline. In production, the External Sources service is bound to loopback and scheduled collection publishes validated data to the CTI Gateway.

3.4.3 Processing and Analytics Domain

The analytical methods are distinct: external relevance classification precedes independent IoC extraction, optional NER and rule-based relationships. Short batches durably persist raw/CTI records and deterministic risk. Internal sessions follow an Isolation Forest path, while global correlation is a separate operation.

Event correlation combines exact indicator type/value matches with lexical TF-IDF unigram/bigram cosine similarity (default 0.35 threshold), with a Jaccard fallback. ATT&CK explicit identifiers and rule-based review candidates are distinguished [5].

3.4.4 Enrichment and Knowledge Domain

The enrichment domain provides analyst-controlled NVD/CVE enrichment and evidence-bearing MITRE ATT&CK mappings. Detailed production verification is reported in Section 6.7.

MISP is used as an analyst-controlled sharing destination rather than as the authoritative ACTIT repository. PostgreSQL remains the source of truth. MISP preview/send/history paths and idempotent identifiers support controlled delivery, while bulk mirroring of all ACTIT events is intentionally not enabled.

3.4.5 Analyst and Output Domain

The analyst and output domain provides authenticated operational awareness, source and review governance, intelligence search, event and storyline investigation, observables, ATT&CK and NVD context, correlations, outlier analysis, model evidence, exports, MISP governance, and authorized administration and audit functions.

The frontend presents these functions through role-aware routes backed by central APIs. Detailed production verification and interface limitations are reported in Section 6.6.

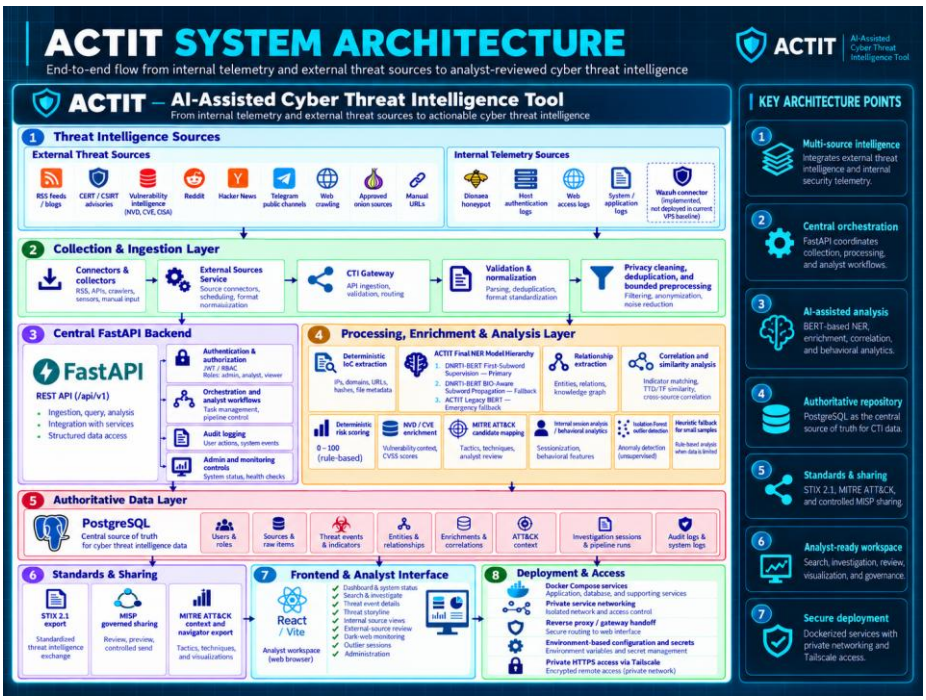


Figure3-4. Verified ACTIT system architecture

Source: verified implementation, deployed service inventory, and production UI route evidence.

3.5 Production Context and Trust Boundaries

The verified production source is release 20260928T102847Z-ae9bf948. Analysts reach the deployed frontend through private Tailscale HTTPS; the frontend proxies the versioned API to the Central Backend. Backend, Gateway, External Control, MISP, and PostgreSQL use loopback or explicit internal Docker boundaries, while selected Dionaea honeypot ports and key-only SSH are intentional host ingress.

Configuration and network presence are not treated as proof of complete readiness. Runtime health, model readiness, backup/restore evidence, and dated production observations are evaluated separately in Chapter 6.

Table3-3. Verified production service inventory

Service/component	Production role	Persistence / boundary
Frontend	React workspace and reverse proxy	Loopback/internal deployment behind private Tailscale HTTPS.
Central Backend	FastAPI, orchestration, APIs, security, analytics	Authoritative writes to PostgreSQL.

Service/component	Production role	Persistence / boundary
PostgreSQL	Operational CTI repository	Named persistent volume; source of truth.
External Sources	Bounded public, social, vulnerability, and approved onion collection	Run/export state; controlled Internet/Tor egress.
CTI Gateway	Authenticated sensor and external handoff	Delivery boundary, not the authoritative CTI database.
Internal telemetry	Dionaea, host-authentication, and web-access paths	Gateway-mediated; Wazuh runtime absent.
MISP stack	Selective intelligence-sharing destination	Separate MISP persistence; no automatic mirroring.
Operational automation	Health checks, scheduled tasks, log rotation, release management	Systemd timers and immutable release evidence.

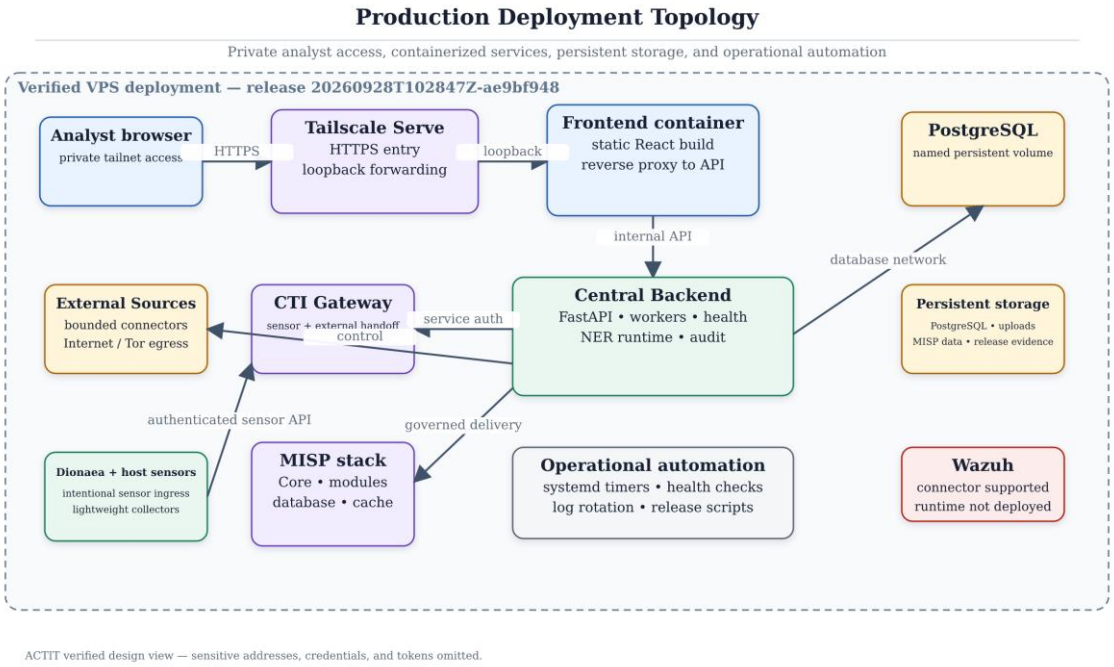


Figure3-5. Production deployment topology

Source: release 20260928T102847Z-ae9bf948 deployment evidence. Wazuh is supported but was not deployed.

3.6 Technology Stack and Selection Rationale

3.6.1 Programming Languages

Python 3.12 was selected as the shared language for backend services, ingestion, preprocessing, analytics, testing, and ML integration because its ecosystem supports FastAPI,

scientific processing, and NLP/ML libraries. TypeScript supports typed browser-side contracts and React application logic.

3.6.2 Frontend

React and TypeScript were selected to support a modular analyst interface with typed frontend contracts and reusable investigation components. A Vite-based build produces the deployed frontend, which communicates with the Central Backend through authenticated same-origin routes.

3.6.3 Backend and API

FastAPI was selected for typed request and response models, OpenAPI integration, and suitability for modular Python-based analytics services. The backend exposes versioned /api/v1 routes, authentication and RBAC, ingestion and analysis services, persistence operations, health/status endpoints, and integration paths for the frontend and internal services.

3.6.4 Data Processing and Machine Learning

The data and ML stack uses NumPy and pandas for structured processing, scikit-learn for Isolation Forest and supporting analytics, and PyTorch with Hugging Face Transformers for BERT token classification. These libraries align with the Python backend and the required analytics workflows. BERT provides named entity recognition; rule-based extraction, TF-IDF similarity, and Isolation Forest retain distinct roles.

3.6.5 Persistence

PostgreSQL was selected because ACTIT requires durable relational persistence, referential consistency, transactional operations, and audit-oriented data relationships. SQLAlchemy models persist sources, raw items, threat events, indicators, entities, relationships, correlations, outliers, runs, users, and audit records. SQLite is limited to lightweight local tests; MongoDB is not part of the implemented system.

3.6.6 Integrations and Reporting

The current interoperability and enrichment stack includes NVD/CVE enrichment capability, MITRE ATT&CK review candidates, STIX 2.1 bundle export, and MISP for selective analyst-controlled sharing. TAXII is not a verified production capability in the current release and is retained as future work. Visualization is provided by the React frontend, while service health and operational evidence are exposed through backend and integration endpoints.

Docker and Compose were selected to provide repeatable service isolation, networking, storage attachment, health checks, and deployment. The VPS baseline runs Ubuntu 24.04.4

LTS with Python 3.12, FastAPI, React/TypeScript/Vite, and PostgreSQL 16.14; Python 3.12.3 was used in a historical regression environment. PyTorch and Hugging Face Transformers support BERT. Dated production evidence is reported separately from the adopted model architecture. Scikit-learn supports Isolation Forest and non-NER analytics.

Table3-4. Technologies used in the implemented CTI processing components

Component	Verified Technology / Implementation
Runtime OS	Ubuntu 24.04.4 LTS on Contabo VPS
Python	3.12 baseline; Python 3.12.3 verified regression environment
Backend/API	FastAPI with versioned /api/v1 routes
Frontend	React + TypeScript + Vite
Production Database	PostgreSQL 16.14; SQLite for isolated local tests
NER / NLP	BERT token classification, implemented with PyTorch and Hugging Face Transformers. The dated deployment state is reported separately in Chapter 6.
Analytics	scikit-learn Isolation Forest; TF-IDF/cosine correlation; deterministic risk scoring
External CTI	RSS/CERT/vulnerability/social/manual/onion bounded collectors
Internal Telemetry	Dionaea + host-auth + web-access live; Wazuh connector implemented but stack not deployed
Sharing / Interoperability	STIX 2.1 export + selective MISP 2.5.44 submission
Deployment / Access	Docker/Compose, systemd timers, isolated networks, Tailscale Serve
Testing	Historical 351/351 pass at 91c823a; current 55 files/487 methods are static inventory only

Model development is offline, while operational CTI processing is service-oriented and persistent. The ACTIT BERT NER Model is specified in Section 4.8 and implemented in Section 5.8; its evaluation artifacts are reported in Section 6.3 and Appendix C, and dated promotion evidence remains pending. The evidence package does not contain deployable weights, and the inspected read-only model mount was unchanged during verification. PostgreSQL stores operational CTI state; External Sources, the CTI Gateway, Dionaea, MISP, and the Central Backend run as bounded services; Tailscale Serve provides private analyst access.

3.7 Requirements Traceability and Scope Status

Requirements are traced to design, implementation, production evidence, and residual limitations using the statuses Implemented, Deployed, Production-target, Future, and Scientific

background. Dated implementation and production evidence remain version-scoped where earlier snapshots differed.

Table3-5. Requirements traceability and verified scope

Requirement	Implemented mechanism	Verified status / boundary
Multi-source acquisition	External Sources plus Gateway-mediated internal sensors	Implemented and deployed; Wazuh connector not deployed.
Normalization and provenance	Validation, cleaning, privacy handling, deduplication, source identity	Implemented; individual source paths remain bounded.
Authentication and RBAC	Password hashing, JWT validation, administrator/analyst/viewer dependencies	Implemented and production UI authenticated.
Investigation workflow	Search, Event Details, Storyline, observables, ATT&CK, correlations, outliers	Deployed; screenshots are point-in-time evidence.
Vulnerability enrichment	Analyst-controlled NVD client with PostgreSQL persistence	28/28 bounded run completed; risk recomputation not validated by that run.
Interoperability	STIX 2.1 export and governed MISP sharing	Implemented; TAXII not deployed.
Final NER architecture	BERT named entity recognition	Final design and offline evidence; production promotion pending.
Operations and recovery	Health checks, timers, immutable releases, backups, rollback evidence	Implemented; off-host restore drill remains unverified.

Chapter 4:

Detailed System Design

4.1 Design Principles and Component Decomposition

ACTIT separates acquisition from authoritative persistence, uses bounded and validated interfaces, preserves provenance, exposes degraded states, and keeps analyst-governed actions explicit. External documents and internal structured telemetry follow different preprocessing paths before converging on common CTI storage and analyst views.

PostgreSQL is the central source of truth. Gateway and External Sources retain bounded delivery and processing state, while MISP receives only selected sharing copies.

4.2 External Acquisition and Durable Handoff

External Sources executes approved, bounded connectors and produces validated run exports. The authenticated Gateway provides bounded delivery using stable identities, pagination, ETag/checkpoints, schema and size controls, and response integrity checks.

The deployed release adds a durable External-to-Central ingestion operation persisted in PostgreSQL. An operation is identified by the external job, exact export run, and dataset digest; a worker claims it through an expiring lease, resumes retryable stages, commits central processing and checkpoint state before acknowledgement, and records terminal or retryable failure information. This bounded lifecycle supports safe replay and recovery without describing Gateway as a permanent CTI database or claiming global exactly-once processing.

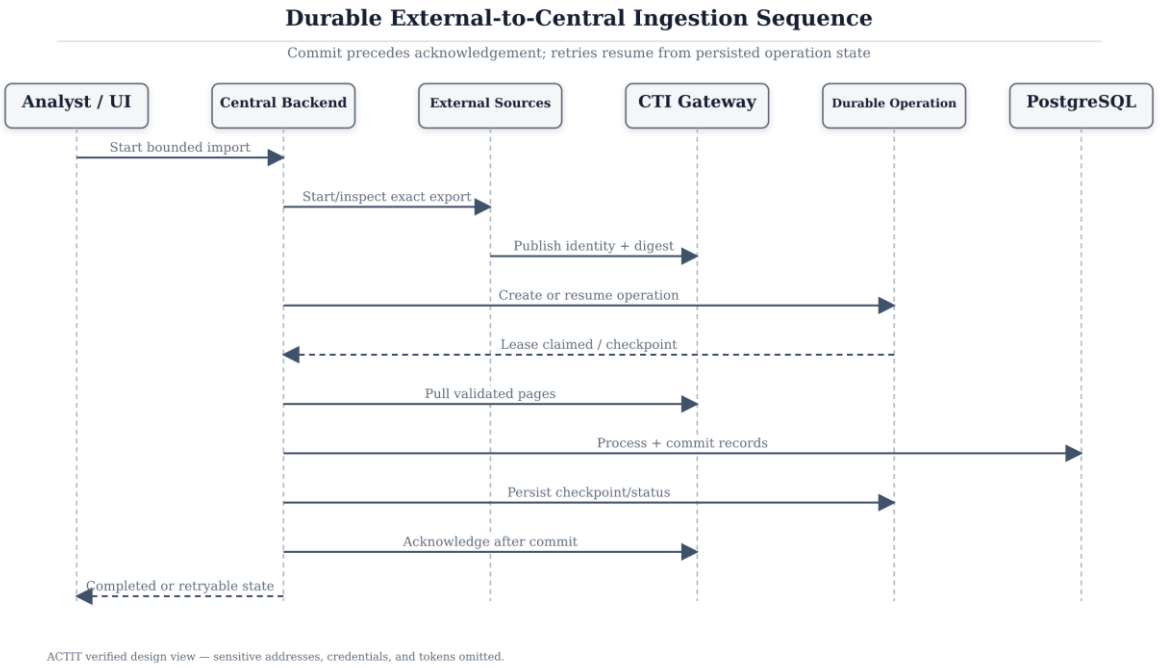


Figure4-1. Durable External-to-Central ingestion sequence

Source: deployed operation model, service lifecycle, routes, frontend state, migration, and tests.

The UML sequence view emphasizes temporal ownership: the Central Backend creates or finds the durable operation, the worker claims an expiring lease, and acknowledgement occurs only after central persistence and checkpoint commit. Interrupted work resumes from durable state; this bounded design does not claim global exactly-once delivery.

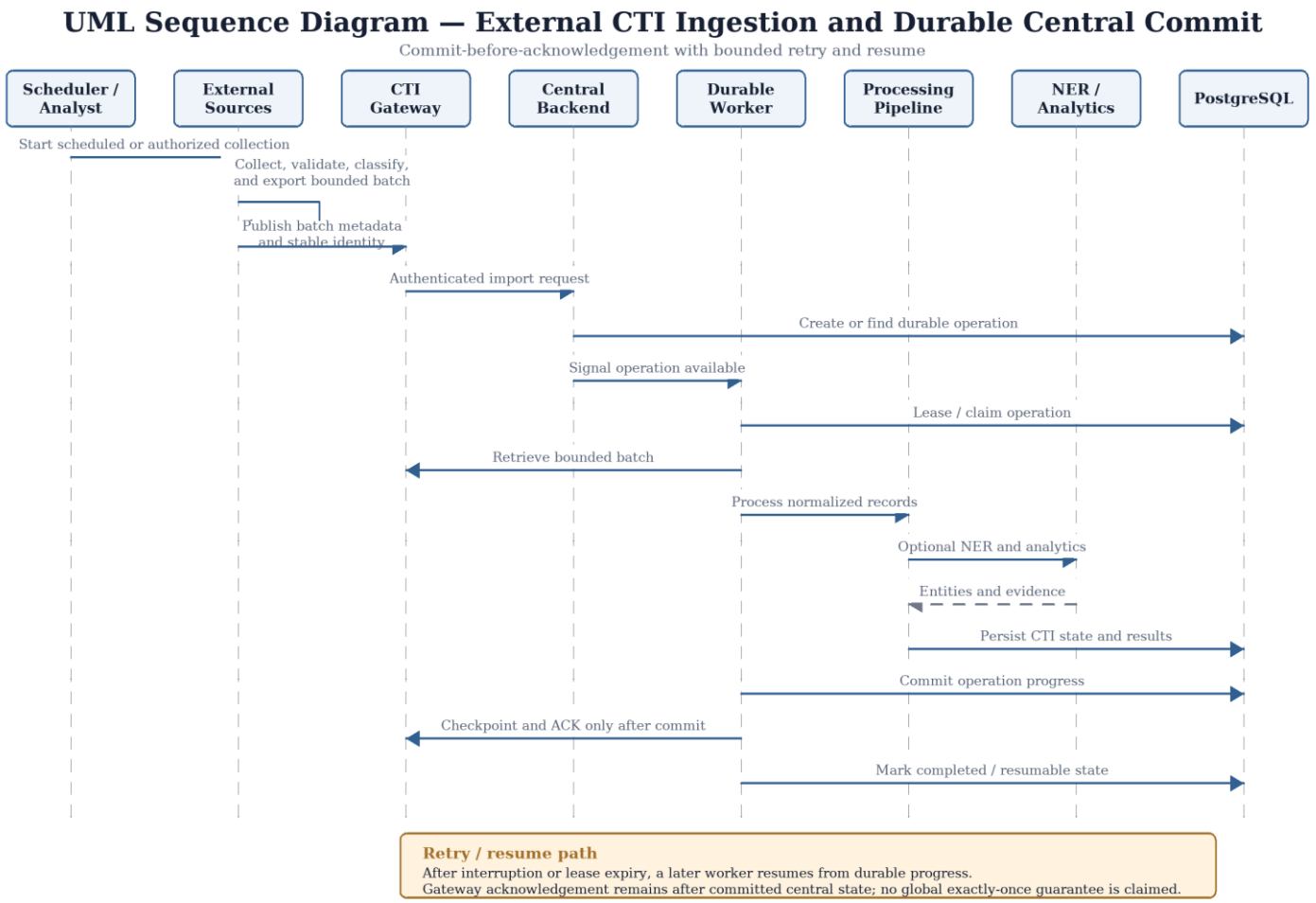


Figure4-2. External CTI Ingestion and Durable Central Commit — UML Sequence Diagram

Source: deployed durable-operation model, Gateway contract, lease/retry lifecycle, commit-before-acknowledgement logic, migration, routes, and tests.

4.3 CTI Processing and Intelligence Lifecycle

Unstructured external content follows validation/privacy, cleaning, normalization, deduplication, CTI relevance classification, deterministic IoC extraction, optional NER, relationship extraction, persistence, correlation, deterministic risk, enrichment, and analyst presentation. Trusted structured records can bypass ordinary document relevance classification through explicit source metadata while remaining subject to validation and persistence controls.

Extracted observables are evidence-bearing technical values, not automatically confirmed malicious indicators. Risk scoring is deterministic and explainable rather than an ML verdict.

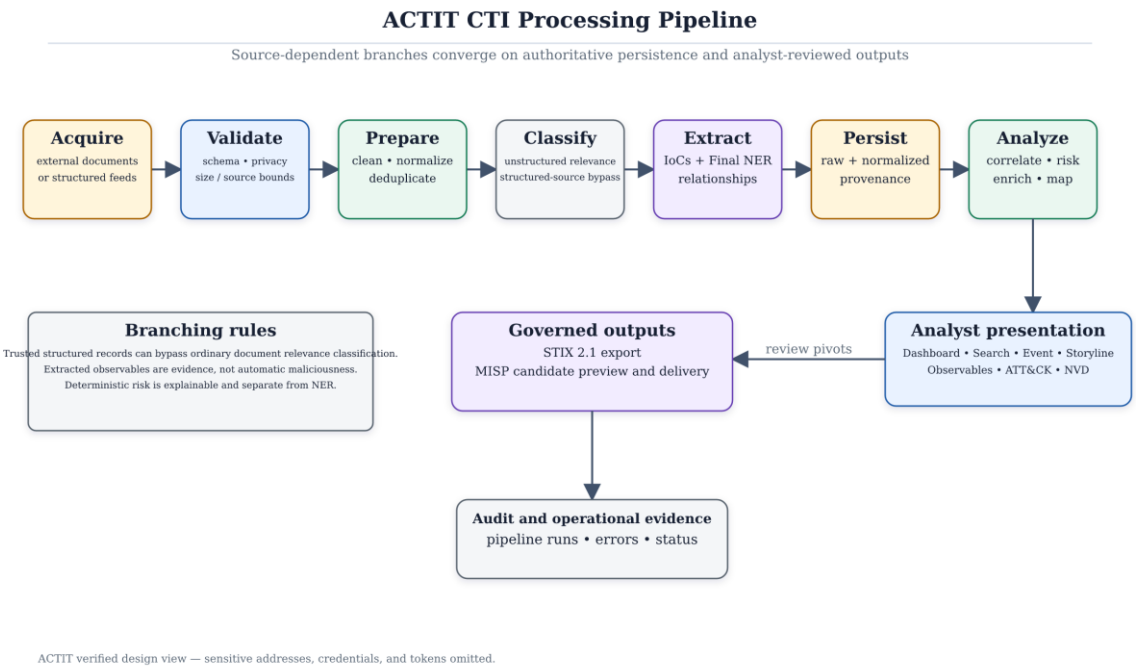


Figure4-3. CTI processing and intelligence pipeline

Source: central orchestration, preprocessing, extraction, persistence, enrichment, and presentation services.

The activity model makes review states explicit. Duplicate records can terminate without creating a new authoritative event; relevance can result in accepted, review, or rejected handling; enrichment is conditional on eligibility; and STIX/MISP sharing occurs only after an authorized decision. Neither extraction nor an automated mapping confirms maliciousness.

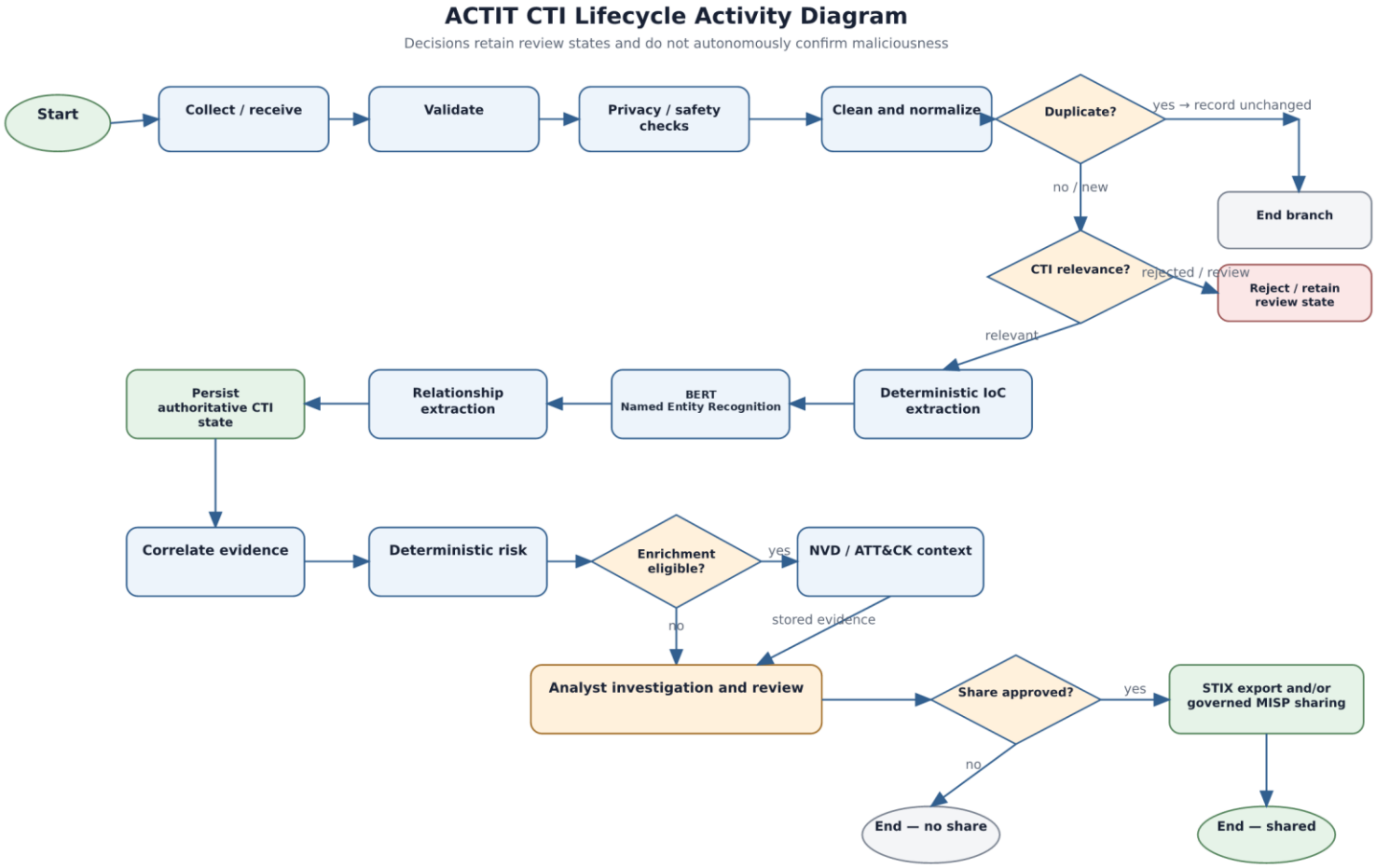


Figure4-4. ACTIT CTI Lifecycle Activity Diagram

Source: verified collection, validation, privacy, normalization, deduplication, relevance, extraction, persistence, enrichment, analyst-review, STIX, and MISP workflows.

4.4 Internal Telemetry, Sessionization, and Anomaly Design

Dionaea, host-authentication, and web-access telemetry are obtained through authenticated Gateway sensor contracts, normalized with sensitive-field handling, grouped into 30-minute inactivity sessions, and transformed into numeric features. Suitable batches use deterministic Isolation Forest; smaller batches use a transparent rule-based fallback. All sessions can remain available for analysis while only outliers are promoted to internal threat events. Wazuh follows an implemented optional connector path but was not deployed in the verified baseline.

A normal session is a stored analytical result that did not meet the outlier condition. An outlier session is a stored result that did. A promoted internal threat event is a separate, later representation created only when the promotion rule is satisfied. These states support investigation but do not establish attack-detection accuracy without labelled evaluation data.

Table4-1. Internal Session and Isolation Forest Processing Stages

Stage	Verified processing behavior	Output / evidence boundary
1. Acquire and authenticate	Receive bounded Dionaea, host-authentication, or web-access records through Gateway sensor contracts.	Authenticated, source-scoped raw records.
2. Normalize and protect	Map records to shared fields and remove or mask configured sensitive keys before downstream use.	Normalized records with source provenance.
3. Sessionize	Group by source type, source name, and source IP; start a new session after more than 30 minutes of inactivity.	Stable session identity, start/end times, and ordered records.
4. Construct features	Create the fixed 15-value numeric vector from counts, duration, rule levels, destinations, URLs, ports, extracted observables, failures, credentials, and HTTP methods.	Reviewable feature evidence for each session.
5. Select detector	Use Isolation Forest for batches of at least four sessions; use the deterministic documented heuristic for smaller batches or an unavailable dependency.	Explicit backend identity for the decision.
6. Score and classify	Isolation Forest uses 200 estimators, random state 42, and bounded contamination; the heuristic applies declared thresholds.	Normal or outlier session with anomaly score and factors.
7. Persist result	Store normal and outlier session results so the analytical outcome remains inspectable.	Session-analysis history and analyst-facing explanation.
8. Promote selectively	Only records meeting the outlier promotion rule become internal threat events.	Promoted event remains distinct from the stored session result.

Source: verified internal orchestrator, sessionizer, feature extractor, detector, repository, and result contract.

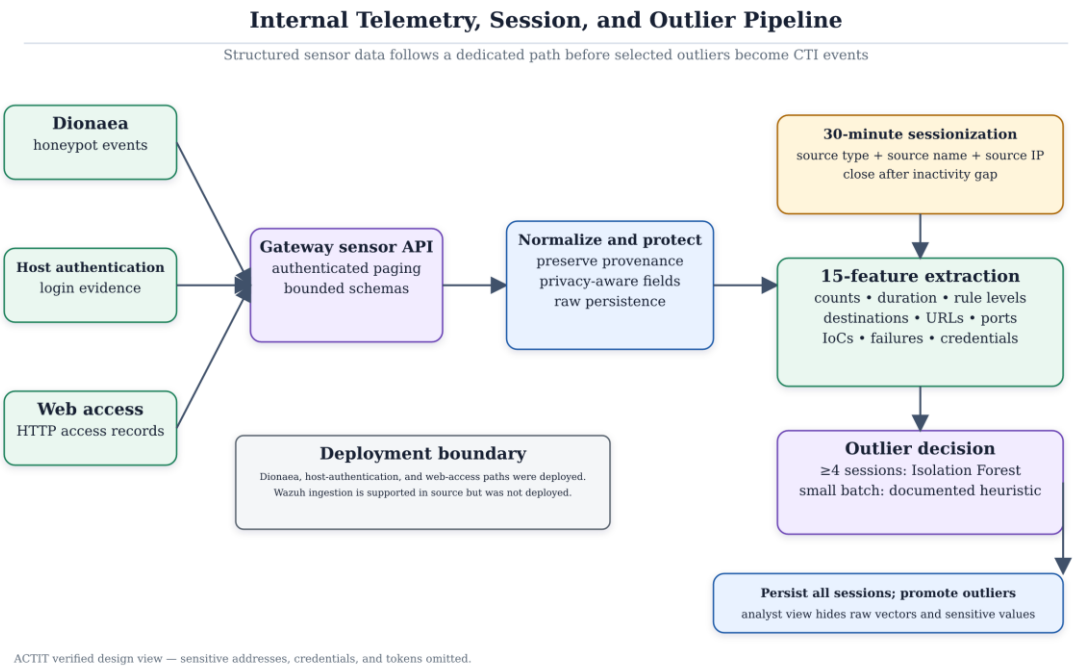


Figure4-5. Internal telemetry, sessionization, and outlier pipeline

Source: Gateway sensor contracts, sessionizer, feature extractor, detector, repository, and UI result contract.

4.5 Data Architecture and Persistence

The implemented storage design uses PostgreSQL as the authoritative production datastore and SQLite only for lightweight isolated development/testing. Service-specific runtime state may exist inside bounded volumes, but it does not replace the central ACTIT application database.

Production CTI Repository: PostgreSQL stores sources, raw items, threat events, indicators/observables, entities, relationships, correlations, enrichments, outlier sessions, pipeline runs, users, and audit records on an internal Docker network.

- Local Testing Repository: SQLite is supported for isolated development and automated tests that do not require the production PostgreSQL service.
- Threat Sharing Platform: MISP is a selective analyst-controlled sharing destination. Preview/send/history workflows and authenticated submission are supported, while PostgreSQL remains the source of truth and no automatic full-database synchronization is enabled.

The production-aligned data model includes users, audit logs, sources, raw items, pipeline runs, durable external-ingestion operations, threat events, indicators, entities, extracted

relationships, enrichments, correlations, and outlier sessions. MISP retains sharing-platform state but does not replace PostgreSQL as ACTIT's authoritative repository.

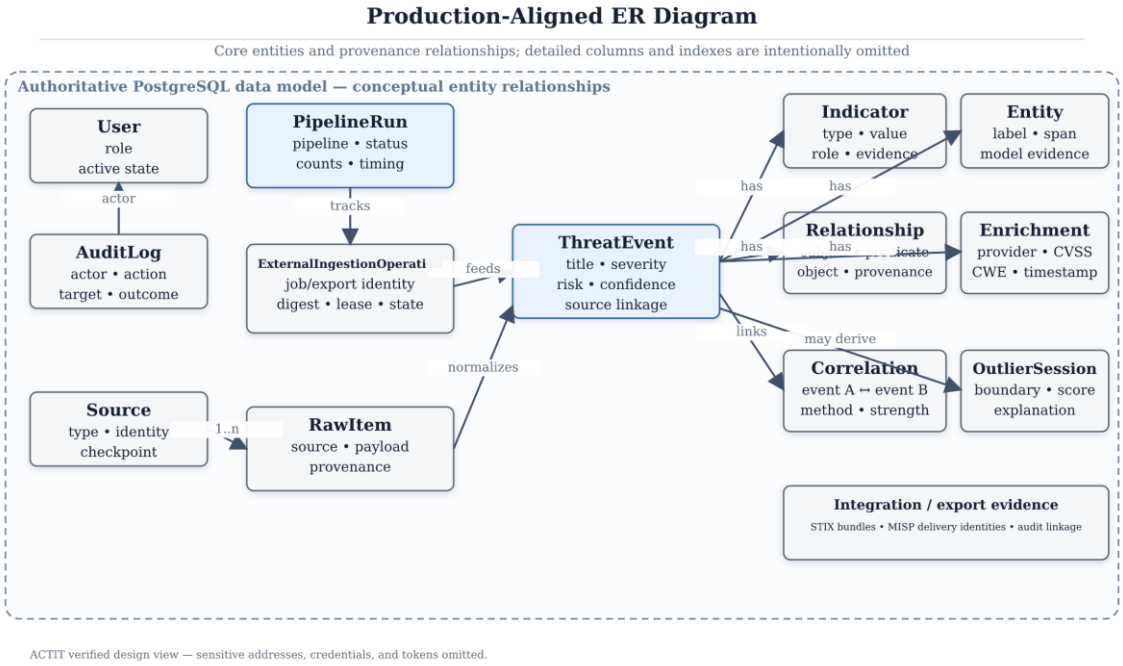


Figure4-6. Production-aligned conceptual ER diagram

Source: ORM models, migrations, production durable-operation delta, and repository relationships.

4.6 API and Integration Design

FastAPI exposes versioned /api/v1 routes grouped around authentication and administration, source and integration control, internal telemetry, intelligence search and analysis, enrichment, model evidence, audit, STIX, ATT&CK, and MISP. Protected routes apply authenticated user and role dependencies, while system-to-system boundaries use separately scoped contracts and credentials.

Table4-2. Major API groups and authorization boundaries

API group	Purpose	Typical authorization
Authentication and users	Login, identity, registration boundary, user and role administration	Authenticated; administrative changes require administrator role.

API group	Purpose	Typical authorization
Sources and processing	Source registry, jobs, pipeline runs, durable external imports	Read access by role; state-changing operations require authorized analyst/administrator policy.
Intelligence	Events, search, storyline, observables, correlations, outliers, ATT&CK	Authenticated read routes; selected analytical actions require analyst authority.
Enrichment and export	NVD enrichment, STIX bundle generation, export records	Explicit authorized action with validation and audit evidence.
MISP	Status, candidate selection, preview, send, and history	Governed analyst/administrator workflow; delivery is never implicit.
Readiness and audit	Health/readiness, model status, audit history	Authenticated; detailed administration/audit remains role-restricted.

4.7 Security Architecture

The security design combines scrypt password hashing, signed expiring JWT bearer tokens, database-backed user and role checks, audit logging, bounded in-process rate limits, trusted-proxy handling, manual-URL SSRF controls, security headers, read-only and capability-reduced containers, pairwise Docker networks, loopback bindings, Tailscale access, host firewall controls, and protected configuration.

Each control retains a scope boundary: rate limits are process-local, bearer tokens have no separate refresh flow, audit completeness must be assessed per operation, and configuration files do not prove that a candidate public-edge path is active.

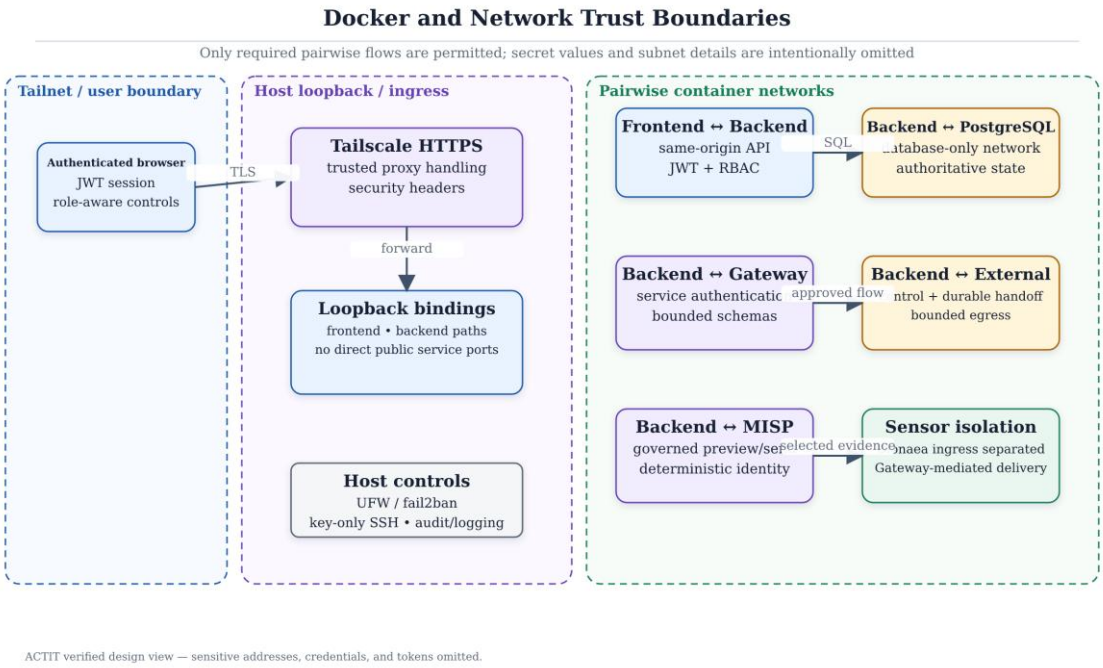


Figure4-7. Docker and network trust boundaries

Source: Compose networks, reverse proxy, Gateway/External/MISP boundaries, and host security configuration.

4.8 ACTIT BERT NER Model

The three-level fallback sequence is summarized in Figure4-8.

ACTIT adopts BERT for named entity recognition. The model applies word-level BIO labels through the first WordPiece of each word. If the model cannot serve the extraction contract, ACTIT reports a runtime service error.

Runtime state, model identity, failure reason, artifact evidence, and quality/readiness state are separate observable concepts. The adopted architecture is described here independently of the dated production evidence in Section 6.8. Model evaluation and deployment verification remain distinct.

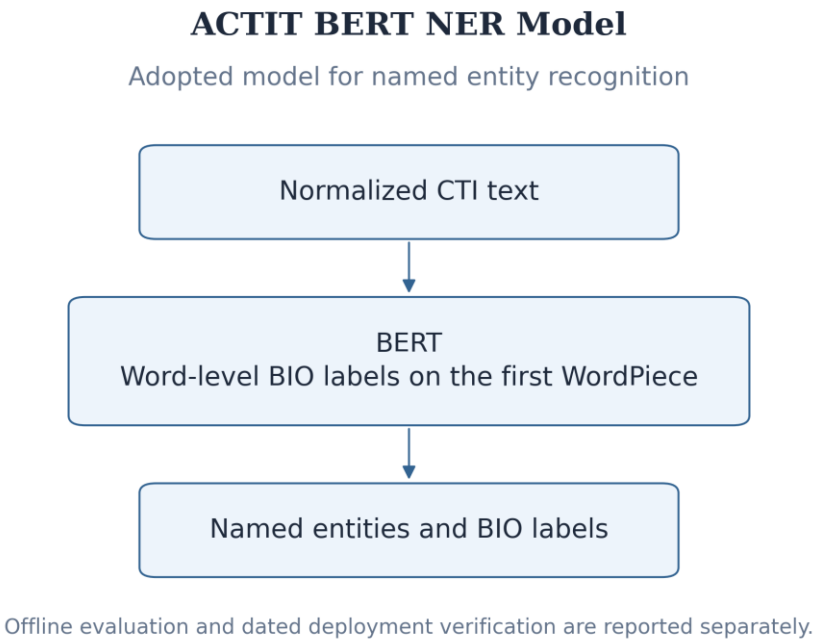


Figure4-8. ACTIT BERT NER Model

Source: final ACTIT design and preserved BERT evidence package. The deployment-transition note is dated 4 October 2026.

4.9 Analyst Investigation and Governance Workflow

The principal investigation path is Global Intelligence Search → Threat Event → Threat Storyline → Observables and Indicators → ATT&CK, NVD, and STIX pivots → controlled MISP sharing where appropriate. Threat Storyline presents evidence chronology and provenance rather than causal proof. ATT&CK automated mappings remain review candidates unless independently confirmed.

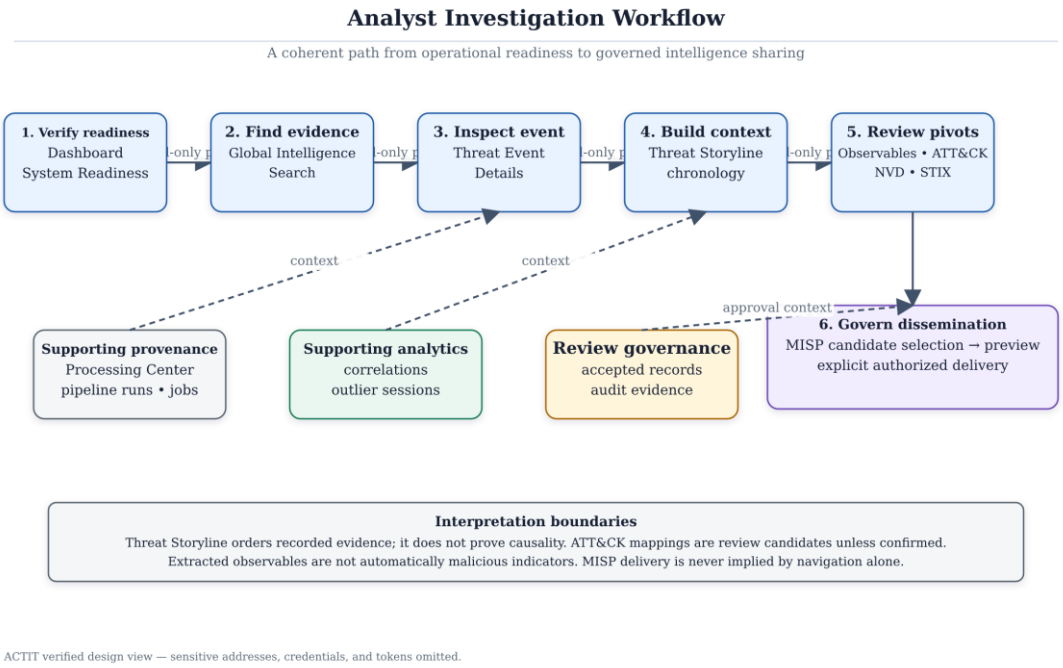


Figure4-9. Analyst investigation and governance workflow

Source: deployed routes and authenticated production UI verification.

The user flow presents navigation rather than internal service calls. Analysts may return to search, inspect correlation or internal-outlier evidence, export STIX where needed, or end the investigation without sharing. MISP delivery remains a governed optional branch.

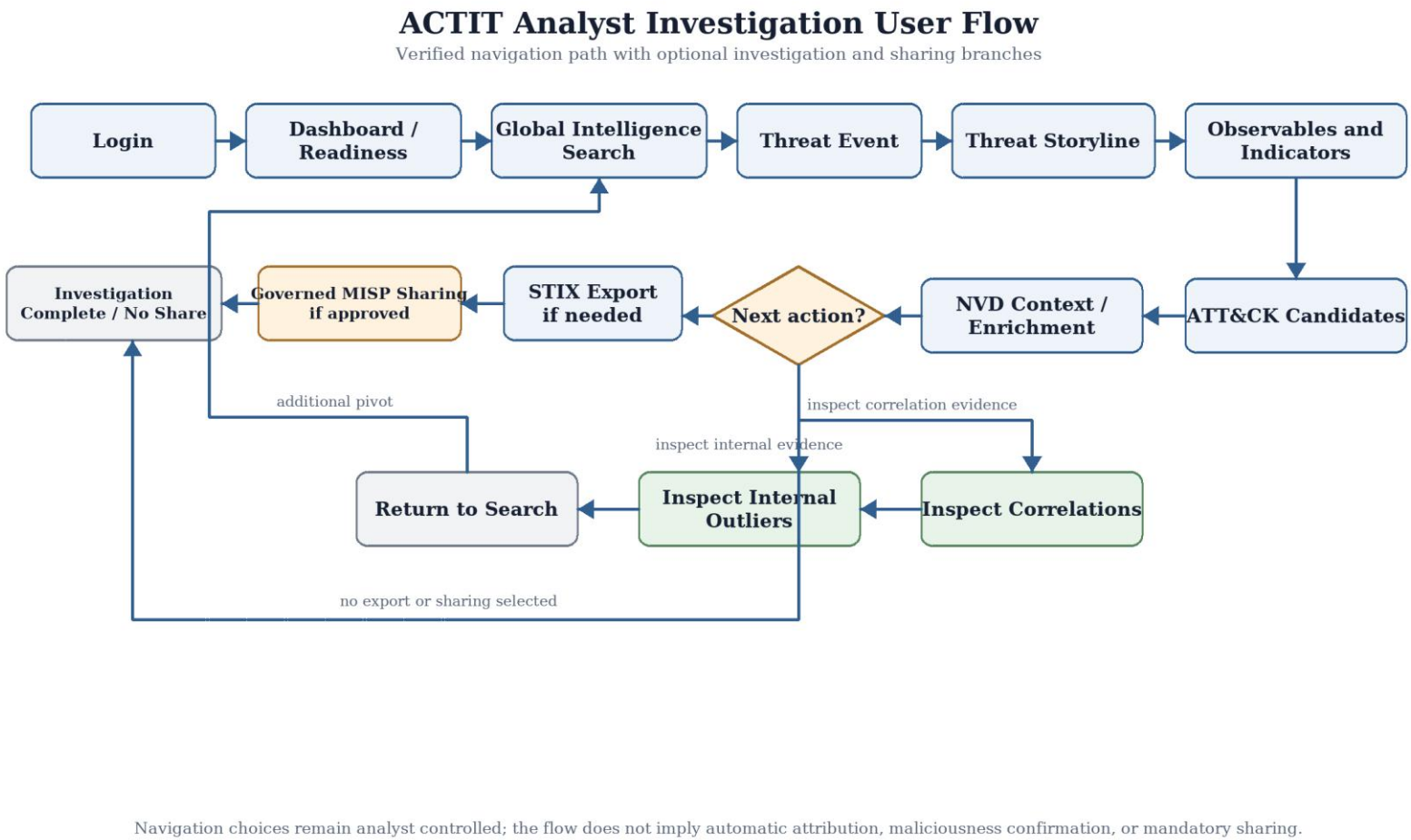


Figure4-10. ACTIT Analyst Investigation User Flow

Source: authenticated production navigation and implemented analyst routes. Optional pivots do not imply automatic attribution, confirmation, export, or sharing.

4.10 Interoperability and Sharing Governance

ACTIT provides bounded STIX 2.1 export and governed MISP integration. Candidate selection, authorization, deterministic identities, idempotent behavior, read-back validation, and audit evidence constrain MISP delivery. MISP is a dissemination destination; PostgreSQL remains authoritative. TAXII is not a deployed ACTIT transport.

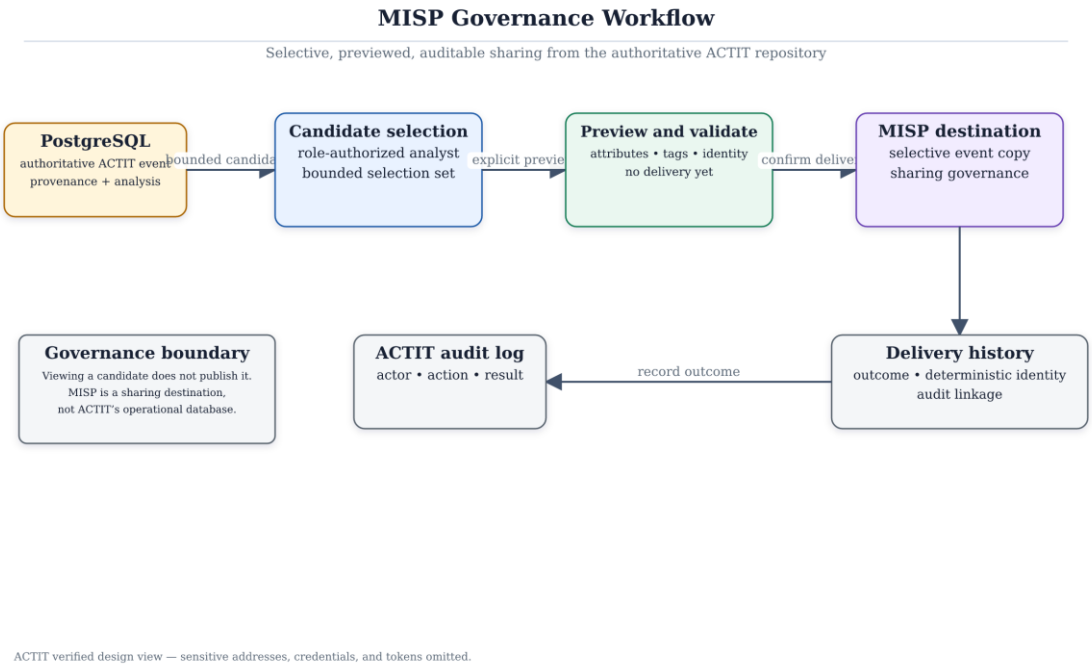


Figure4-11. MISP governance workflow

Source: MISP service, preview/send/history routes, deterministic identity, audit evidence, and production UI.

4.11 Failure, Retry, and Recovery Design

Failure isolation is implemented at multiple boundaries so that malformed records, unavailable optional integrations, small-sample analytics conditions, or individual source failures do not silently corrupt the authoritative CTI state. Validation is fail-closed where required, external runs preserve previous valid exports when a new export fails, and production deployment procedures preserve rollback points and existing PostgreSQL volumes.

Input validation.

Normalized record validation.

Duplicate detection.

Model and model-artifact availability checking.

Structured output validation.

Record-level exception handling.

Preservation of valid records when individual records fail.

This design improves failure tolerance while keeping degraded states visible. The design favors explicit errors, preserved provenance, bounded retries/fallbacks, and analyst-visible evidence over silently accepting ambiguous or unsafe results.

Durable external ingestion adds persisted identity, retryable state, expiring worker leases, resume behavior, commit-before-acknowledgement, and explicit failure information. Deployment recovery preserves named volumes, records a pre-cutover database dump and previous application images, and treats database restoration as a separate explicit disaster-recovery action.

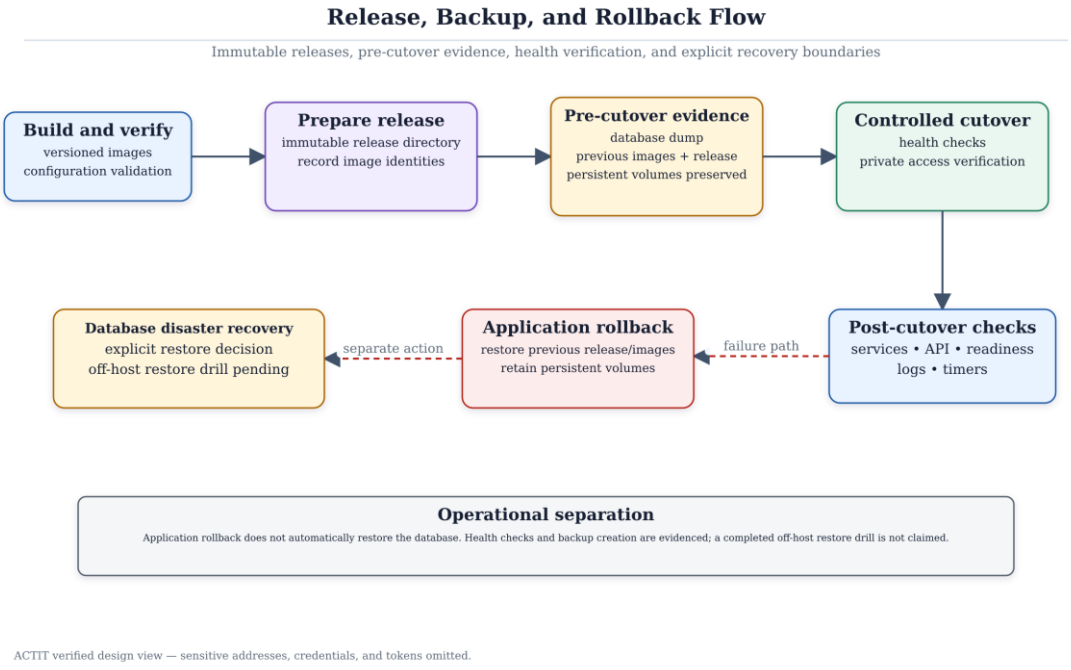


Figure4-12. Release, backup, and rollback flow

Source: production release layout, deployment scripts, health checks, backup evidence, and rollback runbooks.

Chapter 5:

Implementation

5.1 Implementation Environment and Repository Organization

The implementation combines a TypeScript/React frontend, Python/FastAPI backend, SQLAlchemy/PostgreSQL persistence, dedicated external and internal ingestion packages, ML/NLP artifacts, Docker/Compose deployment definitions, infrastructure scripts, and automated test suites.

5.2 Frontend and Analyst Workspace

The deployed React/TypeScript interface is the primary production end-user interface for authenticated analysts. It consumes Central Backend routes rather than calling collectors or internal databases directly.

Interactive Dashboard: The current interface provides functional operational and intelligence views for counts, severities, pipelines/runs, sources, indicators, internal telemetry/outliers, MISP integration, and other backend-exposed CTI records. The dashboard is operational but continues to receive readiness and evidence-presentation improvements.

1. Analytical Input and Collection Controls: Authorized users can initiate supported external-source jobs and submit manual public URLs through the controlled routing workflow. Manual URL processing is subject to source detection, URL/SSRF validation, preprocessing, privacy/relevance checks, and bounded adapters; the verified production design does not rely on arbitrary local CSV upload as its primary analyst input path.
2. Investigation and Evidence Views: The deployed UI provides Global Intelligence Search, Threat Event Details, Threat Storyline, Observables and Indicators, ATT&CK candidates, correlation evidence, NVD enrichment, and STIX pivots. Threat Storyline organizes recorded evidence and time information; it does not establish causality. Observables remain extracted evidence until separately assessed.

Authentication and Role-Aware Access: Bearer-authenticated sessions enforce administrator, analyst, and viewer roles, with audit logging for security-relevant operations and last-administrator protection in the administration workflow.

Interface Boundaries: The verified deployed release provides private Tailscale HTTPS access and includes bounded registration, authenticated intelligence search, storyline/readiness surfaces, and administration features. Registration creates a viewer account and does not imply

public-Internet exposure. Public-IP application access and broader product hardening remain outside the verified baseline.

The deployed workspace includes Dashboard, System Readiness, Processing Center, External Sources, review governance, Dark Web Monitoring, internal-source views, Global Intelligence Search, Threat Event Details, Threat Storyline, Observables and Indicators, ATT&CK mappings, correlations, outlier sessions, MISP governance, model evidence, jobs, exports, and administration/audit routes where authorized.

The frontend groups work into four functional areas. Operational awareness combines Dashboard, System Readiness, Processing Center, Jobs, and Exports. Acquisition and governance combine External Sources, Reviews, Dark Web Monitoring, and Internal Sources. Investigation combines Global Intelligence Search, Threat Event Details, Threat Storyline, Observables and Indicators, ATT&CK, Correlations, Outlier Sessions, and Model Evidence. Controlled dissemination and administration combine STIX actions, MISP governance, users, roles, and audit history.

Authentication establishes the active role before navigation begins. Dashboard and System Readiness provide operational orientation; Processing Center and source views organize bounded acquisition; Global Intelligence Search leads to Event Details, Storyline, observables, ATT&CK and NVD context; correlations and internal outliers provide supporting analytical pivots; STIX and MISP provide controlled outputs; and administration/audit functions remain role restricted.

Global Intelligence Search provides the investigation entry point across supported record types. From an existing event, the analyst can inspect provenance and deterministic risk factors, review the evidence chronology in Threat Storyline, distinguish extracted observables from assessed indicators, examine ATT&CK mappings as review candidates, request bounded NVD enrichment, and prepare STIX or MISP outputs. Correlation and outlier pages provide supporting analytical pivots; their current stored examples do not establish universal cross-source coverage or anomaly-detection accuracy.

The interface uses authenticated API calls to the Central Backend and displays loading, empty, degraded, and authorization states. System Readiness separates component availability from model quality, while Processing Center and External Sources expose bounded operations without making the browser the durable owner of ingestion state. Production screenshots in

Chapter 6 provide dated evidence of these workflows rather than serving as the implementation description.

Processing Center presents an eight-stage analyst-facing workflow: (1) source selection; (2) collection or pull; (3) cleaning, validation, and privacy handling; (4) relevance classification; (5) NER and deterministic IoC extraction; (6) authoritative persistence; (7) correlation and analytics; and (8) confirmed or reviewable results. The production figure was captured in a safe idle state. No collection, ingestion, review, enrichment, or analysis operation was launched for documentation capture.

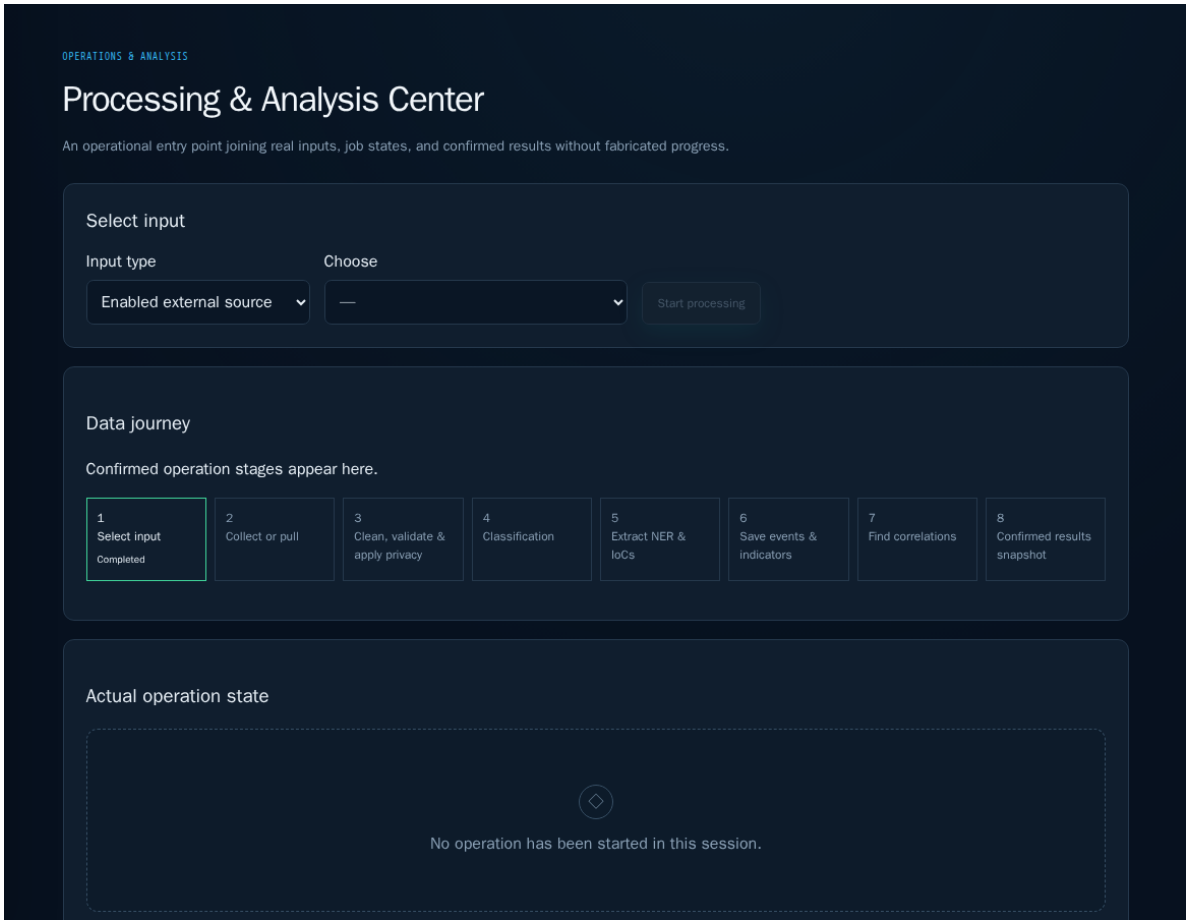


Figure5-1. Processing Center in a safe idle state

Production evidence of bounded operational controls and workflow design; no documentation-specific operation was launched.

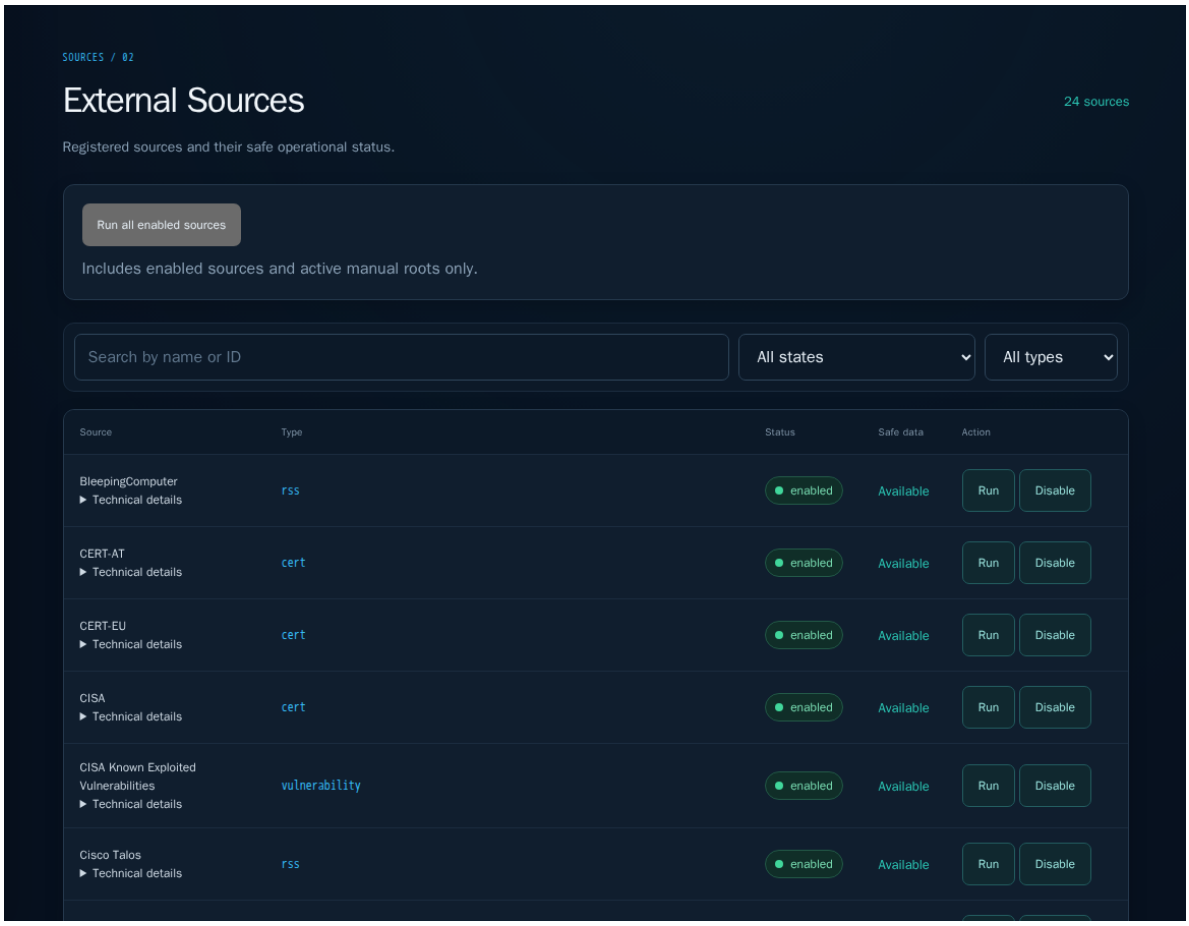


Figure5-2. External Sources registry

Production evidence of source status and governance; no source was enabled, disabled, deleted, or retried.

5.3 Central FastAPI Backend

The central FastAPI application exposes versioned routes, validates request and response contracts, enforces authentication and RBAC, coordinates processing and integration services, and persists authoritative CTI state through SQLAlchemy repositories. Optional integrations report bounded health/degraded states rather than silently becoming authoritative.

5.4 External Sources, Gateway, and Durable Ingestion

Data acquisition is implemented through two complementary domains. External CTI is collected through bounded connectors and approved manual routing, while internal telemetry is received from Dionaea and lightweight host-authentication/web-access sensors through authenticated gateway paths. The backend also contains a Wazuh ingestion connector, but the Wazuh Manager/Indexer/Dashboard stack is not deployed in the verified 23 September VPS deployment configuration.

External connectors preserve source identity and bounded collection rules before handing validated data to the downstream pipeline. Internal sensor events retain their own provenance while converging into the same source-independent ACTIT representation. This design allows new sources to be added without changing the central database schema or analyst workflow.

Each collection run is bounded by connector-specific lookback, item, size, and timeout controls. Normalization preserves source and collection provenance, privacy handling filters or redacts disallowed fields, and stable identities support incremental deduplication. Relevance classification separates accepted, review, and rejected outcomes rather than treating every retrieved document as intelligence.

Run-scoped datasets and exports are generated only after validation. Authenticated Gateway publication transfers bounded records to the Central Backend, where the durable ingestion operation can be created or resumed. Central processing persists CTI state and checkpoint information before acknowledgement. This commit-before-ACK boundary permits safe retry without claiming unrestricted or globally exactly-once collection.

Receive CTI information from an external source.
Validate the received record.
Convert source-specific information into the normalized input structure.
Preserve source information for traceability.
Pass the normalized record to the preprocessing stage.

Implementation evidence is provided by the bounded External Sources collectors, source configuration/contracts, and corresponding automated pipeline tests.

In production release 20260928T102847Z-ae9bf948, central ingestion is implemented as a durable operation rather than a browser-bound synchronous import. The frontend can observe the operation identity and state, the backend worker leases and resumes it, and Gateway acknowledgement occurs only after durable central commit.

Table5-1. External CTI Source and Connector Inventory

Category	Verified connector examples	Acquisition mode	Safety/privacy and processing boundary	Status
RSS / security research	Security publication and advisory feeds, including configured Hacker News publication, BleepingComputer, Talos, SANS ISC, and Krebs feeds	Scheduled bounded feed retrieval	Lookback limits, stable source identity, cleaning, privacy checks, deduplication, and relevance governance	Configured in deployed External Sources subsystem
CERT / CSAF	CISA RSS and CSAF, CERT-EU, and CERT-AT	Scheduled advisory/feed or structured-document retrieval	Schema/content validation, bounded retrieval, provenance, and normalized export	Configured in deployed source registry
Vulnerability intelligence	NVD, MITRE CVE, GitHub advisories, and CISA KEV	Bounded connector/API or feed retrieval	Identifier validation, conservative pacing where applicable, evidence persistence, and provider provenance	Implemented; NVD production workflow verified
Reddit	Configured public security subreddits	Public RSS with bounded browser fallback	Public content only, request bounds, privacy filtering, deduplication, and review states	Configured
Hacker News search	Configured CVE, vulnerability, and breach queries	Bounded public search retrieval	Query and result limits, stable identity, cleaning, and relevance classification	Configured
Telegram public previews	Configured public channel preview pages	Public web-preview retrieval	No private account interaction; bounded extraction, privacy checks, and review governance	Configured
Manual public URL	Operator-submitted public HTTP/HTTPS pages	Explicit authorized preview/collection path	SSRF controls, allow/deny checks, validation, size/time limits, and no automatic promotion	Implemented in deployed interface
Approved onion sources	Operator-approved onion addresses	Controlled Tor path and scheduled/manual bounded collection	Explicit registry, no unrestricted discovery or interaction, privacy controls, review, and deduplication	Active production monitoring verified

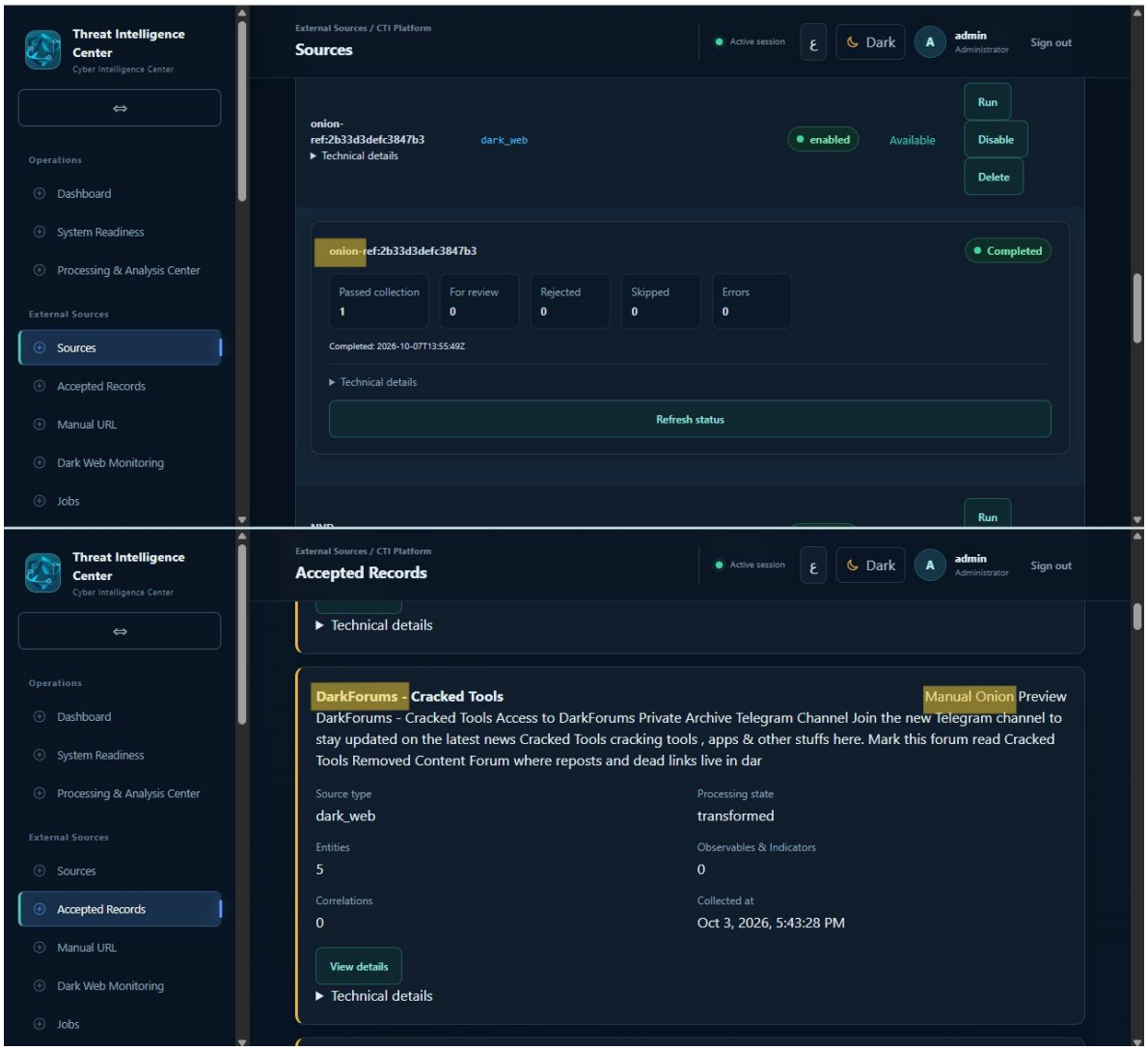


Figure5-3. Successful dark-web source collection and accepted record evidence

Production evidence of a successful bounded collection from an operator-approved onion source together with a separately captured accepted transformed dark-web record. The displayed run reported one passed collection and zero review, rejected, skipped, or error outcomes. These point-in-time observations demonstrate bounded collection and accepted-record processing, but do not establish that the displayed accepted record originated from the same displayed run, nor do they imply unrestricted dark-web discovery, interaction, or surveillance.

5.5 Preprocessing, Extraction, Correlation, and Risk

5.5.1 Cleaning, Normalization, and Privacy

Preprocessing converts heterogeneous source material into consistent downstream inputs. External content is cleaned, structurally validated, privacy-reviewed, classified for CTI relevance, and prepared for run-scoped export/handoff. Internal telemetry is parsed into normalized event structures and, where applicable, grouped into source-IP sessions for behavioral feature extraction.

Cleaning incoming CTI text and records.

Normalizing the record structure.

Preparing information for downstream NLP processing.
Detecting duplicated information.
Preserving source metadata where available.
Isolating malformed records without terminating the complete processing batch.

The output of preprocessing is a consistent representation that can be passed to duplicate detection and CTI relevance classification.

5.5.2 Deduplication

Duplicate handling is applied before unnecessary downstream work. External collection uses incremental state, ETag/conditional-request behavior where supported, and content hashing so unchanged material can be skipped while provenance and run state are preserved. At the central layer, source-independent identities and normalized records provide a further basis for consistent persistence and correlation.

The implemented processing sequence is: Collection → Cleaning and Normalization → Duplicate Detection. The duplicate-detection stage improves processing efficiency and contributes to consistency in the resulting CTI objects.

5.5.3 CTI Relevance Classification

Following preprocessing and duplicate detection, the system performs CTI relevance classification. The purpose of this stage is to determine whether an incoming document contains information relevant to CTI processing.

The classification stage precedes NER for unstructured CTI. Relevant text passes through independent IoC extraction before BERT named entity recognition. Deterministic IoC persistence remains independent of NER output.

Normalized Record → CTI Relevance → Independent IoC Extraction → BERT Named Entity Recognition → Rule-Based Relationships

5.5.4 Entities, Observables, and ATT&CK Candidates

Independent deterministic IoC extraction validates technical observables before optional NER entities and rule-based relationships. Explicit ATT&CK IDs and lower-confidence review candidates are distinguished; neither establishes automatic attribution.

Relevant CTI → Independent IoC Extraction → Optional NER Entities → Rule-Based Relationships. The IoC stage does not require successful NER loading.

Internal telemetry groups source type, source name and IP by a 30-minute inactivity gap. Current-batch Isolation Forest (200 trees) or a small-batch heuristic evaluates features. Inliers and outliers may both be retained.

5.5.5 Relationship Extraction

After entities and indicators have been identified, the system performs relationship extraction. The current implementation uses rule-based relationship extraction and retains provenance information.

The purpose of this stage is to preserve contextual relationships among extracted CTI entities instead of representing each indicator as an isolated value. The resulting relationships provide a structured basis for later correlation and enrichment stages.

Relationship extraction evidence is preserved through structured relationship records, provenance fields, and automated relationship tests.

5.5.6 Normalized CTI Objects

Normalized ACTIT objects form the common representation consumed by persistence, analytics, API, and visualization layers. PostgreSQL stores sources, raw items, threat events, indicators/observables, entities, relationships, correlations, enrichments, outlier sessions, pipeline runs, users, and audit records while preserving source provenance and analytical evidence.

The public project provides a reduced technical schema example containing fields such as source information, title, classification metadata, indicators, and processing status. Indicator records may also contain the indicator value, type, confidence, and extractor information. The published schema is explicitly described as a reduced technical sample rather than the complete private runtime implementation.

Normalized object behavior is validated through schema/contracts, serialization tests, and persistence/API integration tests.

Deterministic risk scoring, correlation evidence, and later enrichment are presented as explainable factors. Extracted observables do not become confirmed malicious indicators solely because they were parsed from CTI content, and the production correlation examples captured for documentation do not establish universal cross-source correlation.

5.6 Internal Telemetry and Anomaly Implementation

Internal connectors normalize Dionaea, host-authentication, and web-access records; the orchestrator persists raw provenance, builds sessions and features, stores the analysis result, and promotes outliers to CTI events. The analyst view hides raw feature vectors and sensitive values. Wazuh connector code remains supported but non-deployed in the verified baseline.

The internal pipeline accepts deployed Dionaea, host-authentication, and web-access records through authenticated Gateway sensor APIs. Connector-specific parsing maps timestamps, source identity, title, content, and selected structured fields into a common internal record while privacy handling limits sensitive values in analyst-facing responses. The Wazuh connector follows the same boundary but its Manager, Indexer, and Dashboard were not deployed in the verified production baseline.

Sessionization groups records by source type, source name, and source IP and closes a session after 30 minutes of inactivity. The feature extractor records alert count, session duration, rule-level summaries, distinct rules, destinations, URLs, ports, CVEs, IPs, domains, failed actions, credential attempts, and HTTP method counts. These numeric features are stored as analysis evidence but raw feature vectors and raw source addresses are not exposed in the production Outliers view.

Batches of at least four sessions use Isolation Forest with 200 trees and deterministic random state 42. The contamination value is bounded by the batch size and an upper limit of 0.25. Smaller batches, or an unavailable Isolation Forest dependency, use a documented rule-based heuristic. ACTIT stores both ordinary and outlying sessions so that the result remains reviewable; only records meeting the promotion rule become internal threat events.

The implementation supplies the following fixed feature order to the detector. The vector summarizes a session; it does not expose raw telemetry in the analyst Outliers view and does not by itself label a session as malicious.

Table5-2. Internal Session Feature Vector

Feature	Meaning	Implementation source
alerts_count	Number of normalized records in the session	Session record count
duration_minutes	Elapsed minutes between the first and last record, bounded at zero	Session timestamps
max_rule_level	Maximum parsed rule/severity level in the session	Nested rule.level or level field
avg_rule_level	Arithmetic mean of parsed rule/severity levels	Nested rule.level or level field

Feature	Meaning	Implementation source
distinct_rules	Number of distinct rule, group, decoder, or protocol identifiers	Normalized raw rule/decoder/protocol fields
unique_destinations	Number of distinct destination IP values	Normalized destination IP fields
unique_urls	Number of distinct structured URL values	Normalized URL fields
unique_ports	Number of distinct destination port values	Normalized destination port fields
cve_count	Number of distinct extracted CVE identifiers	Deterministic IoC extraction over session text
ip_count	Number of distinct extracted IPv4 observables	Deterministic IoC extraction over session text
domain_count	Number of distinct extracted domains, including URL hostnames	Deterministic IoC extraction and URL parsing
failed_actions	Count of failure/denial/invalid terms plus structured credential attempts	Session text and structured credentials
credential_attempts	Count derived from structured credential collections	Normalized credentials field
http_get_count	Case-insensitive count of GET method tokens	Session title/content text
http_post_count	Case-insensitive count of POST method tokens	Session title/content text

Source: verified SessionFeatureExtractor.NUMERIC_FEATURES and extract() implementation.

5.7 Vulnerability, ATT&CK, STIX, and MISP Services

NVD enrichment is an analyst-controlled external lookup. The backend identifies eligible CVEs, applies conservative request pacing, retrieves records through the existing ACTIT NVD client, and stores provider evidence in PostgreSQL. Stored fields include CVSS score, severity, CVSS version, NVD description, weakness/CWE information, provider timestamp, and evidence metadata. The verified bounded run completed 28 of 28 selected CVEs across 22 events with no failures, not-found results, skipped items, retries, or HTTP 429 responses. No NVD API key was configured or used.

ATT&CK mappings distinguish explicit identifiers from automated review candidates. STIX provides bounded export, while MISP delivery remains an explicit governed action against a sharing destination rather than a replication of the authoritative PostgreSQL repository.

5.8 ACTIT BERT NER Implementation

The implementation loads and verifies BERT for named entity recognition. Runtime status identifies the active model and records any service failure. If BERT cannot serve the

extraction contract, the service reports a runtime error condition. Model quality evidence remains separate from runtime availability.

At the 4 October 2026 production evidence capture, deployment of the adopted BERT model had not yet been verified. That dated state is evaluated in Section 6.8 and must not alter the architecture described here.

5.9 Data Persistence and Audit Implementation

SQLAlchemy maps central records to PostgreSQL, which stores raw and normalized CTI, processing runs, threat events, observables, entities, relationships, enrichments, correlations, outlier sessions, durable ingestion operations, users, and audit records. Unique source/external identities and deterministic integration identities support idempotent bounded workflows.

5.10 Security Controls in Code and Containers

Backend code implements password hashing, signed token validation, role dependencies, database user-state checks, selected-operation audit records, request bounds, rate limiting, trusted-proxy logic, and SSRF-oriented manual URL validation. Deployment definitions add read-only filesystems, temporary writable mounts, dropped capabilities, resource limits, internal networks, and loopback service bindings where applicable.

Dionaea intentionally requires a narrowly different capability and ingress profile from ordinary application containers. Security controls are documented per boundary rather than generalized as complete protection.

Table5-3. Security controls and evidence boundaries

Control area	Implemented control	Boundary
Authentication	Password hashing and signed JWT validation	Token values and secrets are excluded from documentation.
Authorization	Administrator, analyst, and viewer dependencies plus active-user checks	Backend route policy is authoritative.
Request protection	Validation, request bounds, rate limiting, trusted-proxy handling, SSRF-oriented URL checks	Control presence does not prove absence of every attack path.
Auditability	Security-relevant action records and administration/audit views	Coverage is action-dependent and must be verified per route.

Control area	Implemented control	Boundary
Container hardening	Read-only filesystems, temporary mounts, dropped capabilities, resource limits	Dionaea has a deliberately different sensor profile.
Network boundary	Private Tailscale access, loopback bindings, pairwise Docker networks	No subnet, credential, or token value is published.

5.11 Deployment, Operations, and Release Management

The verified production source is the immutable release 20260928T102847Z-ae9bf948. The deployment model preserves named PostgreSQL and upload volumes, uses health checks and restart policies, provides systemd timers for scheduled collection and maintenance, applies bounded log rotation, records pre-cutover database and application rollback evidence, and limits normal analyst access to Tailscale HTTPS.

Application rollback and database disaster recovery are distinct. Existing evidence does not establish a completed off-host restore drill or enterprise high availability.

5.12 Implementation Summary

ACTIT implements a source-separated but centrally governed CTI tool in which acquisition services remain distinct while intelligence is processed and persisted through a common backend. The frontend, FastAPI services, PostgreSQL repository, analytics, integrations, and operational controls implement the design defined in Chapter 4; evaluation and production verification are presented in Chapter 6.

Chapter 6:

Evaluation, Production Verification, and Discussion

6.1 Evaluation Questions and Evidence Classes

Evaluation distinguishes source inspection, preserved test results, saved offline model metrics, targeted compatibility checks, dated service observations, and authenticated production UI verification. A test file or configuration is not a passing execution result, and a saved model metric is not live production accuracy.

The principal questions are whether the implemented requirements have traceable evidence, whether the adopted BERT model has valid preserved evaluation artifacts, what was actually deployed at the capture date, and which limitations prevent broader claims.

6.2 Functional and Integration Test Evidence

The following tables preserve version-scoped functional and integration test evidence collected during project development. Because no fresh complete regression or coverage run was performed for the final documentation baseline, these results are reported only within their recorded execution scope and are not presented as evidence of a new full-suite run.

6.2.1 Data Collection

Table6-1. Data collection test cases

Test ID	Objective	Expected Result	Status
TC-DC-01	Verify external CTI input	CTI record is accepted by the collection interface.	Inspected test scope; no current-release pass result
TC-DC-02	Verify source normalization	Source record is converted to the normalized input structure.	Inspected test scope; no current-release pass result
TC-DC-03	Verify malformed input isolation	Invalid record does not terminate the complete processing batch.	Inspected test scope; no current-release pass result
TC-DC-04	Verify source traceability	Source information remains associated with the processed record.	Inspected test scope; no current-release pass result

6.2.2 Preprocessing and Deduplication

Table6-2. Preprocessing and duplicate-detection test cases

Test ID	Objective	Expected Result	Status
TC-PP-01	Test data cleaning	Unnecessary content is removed or normalized.	Inspected test scope; no current-release pass result

Test ID	Objective	Expected Result	Status
TC-PP-02	Test data normalization	Records follow the expected normalized structure.	Inspected test scope; no current-release pass result
TC-PP-03	Test duplicate detection	Repeated records are detected.	Inspected test scope; no current-release pass result
TC-PP-04	Test batch processing	Duplicate or malformed records do not disrupt valid records.	Inspected test scope; no current-release pass result

6.2.3 CTI Relevance Classification

Table6-3. CTI relevance classification test cases

Test ID	Objective	Expected Result	Status
TC-CLS-01	Classify relevant CTI	Relevant CTI receives the appropriate classification metadata.	Inspected test scope; no current-release pass result
TC-CLS-02	Classify non-relevant text	Non-CTI content is prevented from unnecessary NER processing.	Inspected test scope; no current-release pass result
TC-CLS-03	Verify structured-source handling	Trusted structured advisory data can follow its defined classification path.	Inspected test scope; no current-release pass result

6.2.4 NER and IoC Extraction

Table6-4. NER and IoC extraction test cases

Test ID	Objective	Expected Result	Status
TC-NER-01	Load local NER model	Model loads successfully.	Inspected test scope; no current-release pass result
TC-NER-02	Process CTI text	Input text is processed successfully.	Inspected test scope; no current-release pass result
TC-NER-03	Identify cybersecurity entities	Relevant entities are detected.	Inspected test scope; no current-release pass result
TC-IOC-01	Extract indicators	Identified IoCs are represented structurally.	Inspected test scope; no current-release pass result
TC-IOC-02	Preserve extraction metadata	Supported confidence and extractor metadata are retained.	Inspected test scope; no current-release pass result

6.2.5 Relationship Extraction

Table6-5. Relationship extraction test cases

Test ID	Objective	Expected Result	Status
TC-REL-01	Extract relationships	Rule-defined relationships are identified.	Inspected test scope; no current-release pass result
TC-REL-02	Preserve provenance	Relationship origin/context is retained.	Inspected test scope; no current-release pass result
TC-REL-03	Validate relationship structure	Relationship information follows the expected representation.	Inspected test scope; no current-release pass result

6.2.6 Normalized CTI Objects

Table6-6. Normalized CTI object test cases

Test ID	Objective	Expected Result	Status
TC-OBJ-01	Generate CTI object	A normalized CTI object is generated.	Inspected test scope; no current-release pass result
TC-OBJ-02	Validate source information	Source fields are preserved.	Inspected test scope; no current-release pass result
TC-OBJ-03	Validate indicators	Extracted indicators are included in the object.	Inspected test scope; no current-release pass result
TC-OBJ-04	Validate classification	Classification metadata is represented when available.	Inspected test scope; no current-release pass result
TC-OBJ-05	Serialize object	The CTI object can be represented as structured data.	Inspected test scope; no current-release pass result

6.2.7 Historical Regression Boundary

The historical 91c823a workspace recorded 351/351 Python passes. The current inspected release instead has 55 files and 487 static test methods; no fresh full-suite result was obtained in the read-only audit.

Table6-7. Version-scoped regression evidence

Evidence Item	Version-pinned Result
Historical source snapshot	Workspace commit 91c823a
Recorded Python runtime	Python 3.12.3 in isolated .venv-final
Requirements source	Committed requirements.txt + backend/requirements.txt
Historical automated result	351/351 passed - retained only for the historical workspace snapshot

Evidence Item	Version-pinned Result
Audited deployed release test inventory	55 test files / 487 static test methods - inventory only, not a pass result
Fresh deployed-release regression run	Not executed under the strict read-only audit
Newest 25 Sep release	Source delta completed: 404 unchanged/47 changed/0 missing prior blobs; fresh full-suite applicability remains untested.

The historical 351/351 Python result belongs to workspace snapshot 91c823a. Static inventories and later targeted tests must not be reported as a fresh pass for release 20260928T102847Z-ae9bf948.

6.3 BERT/NER Evaluation

This section evaluates the adopted BERT model using the preserved paper-parity package. It separates training configuration, supervision strategy, original-test metrics, unique train-unseen metrics, production-transition evidence, and scientific limitations. Saved production-screen percentages are not reused as results for the adopted model.

6.3.1 BERT Supervision and Training Configuration

BERT assigns the word-level BIO label to the first WordPiece and masks subsequent pieces from the loss. The model uses BERT-based token classification [11], BIO sequence labels [13], and the DNRTI entity scheme [14]. Training settings and the selected checkpoint are documented in Table 6-8.

Table6-8. BERT training and evaluation configuration

Setting	BERT
Base checkpoint	bert-base-cased, resolved revision cd5ef92a…
Epochs	4
Physical / effective batch	2; accumulation 8; effective batch 16
Evaluation batch	4
Learning rate	0.0001
Maximum sequence length	120
Optimizer / regularization	AdamW; weight decay 0.01; epsilon 1e-12; max gradient norm 1.0
Scheduler	Linear decay; zero warmup
Seed / CPU threads	42 / 4

Setting	BERT
Checkpoint selection	Validation exact-span entity micro-F1; test used only after four epochs

BERT selected epoch 4 and recorded validation exact-span entity micro-F1 0.800982. The experiment used one deterministic seed and CPU-only training; it does not provide multi-seed uncertainty.

6.3.2 Exact-Span Entity Results

Exact-span entity precision measures the proportion of predicted entity spans that are correct, recall measures the proportion of gold entity spans recovered, and F1 is their harmonic mean: F1 = 2PR / (P + R). The reported scores use exact-span entity evaluation.

Table6-9. Exact-span entity results for the ACTIT BERT NER Model

Model	Validation F1	Original test precision	Original test recall	Original test F1	Original test token accuracy	Unique train-unseen F1
BERT	0.800982	0.852735	0.882879	0.867546	0.9629713253556107	0.719566

BERT recorded original-test exact-span entity F1 of 0.867546. On the 297 unique test sentences absent from training, BERT recorded F1 of 0.719566. Under the report acceptance criterion, Unique Train Unseen > 70%, the result is satisfactory. The recorded scores are retained as the measured evidence for this assessment.

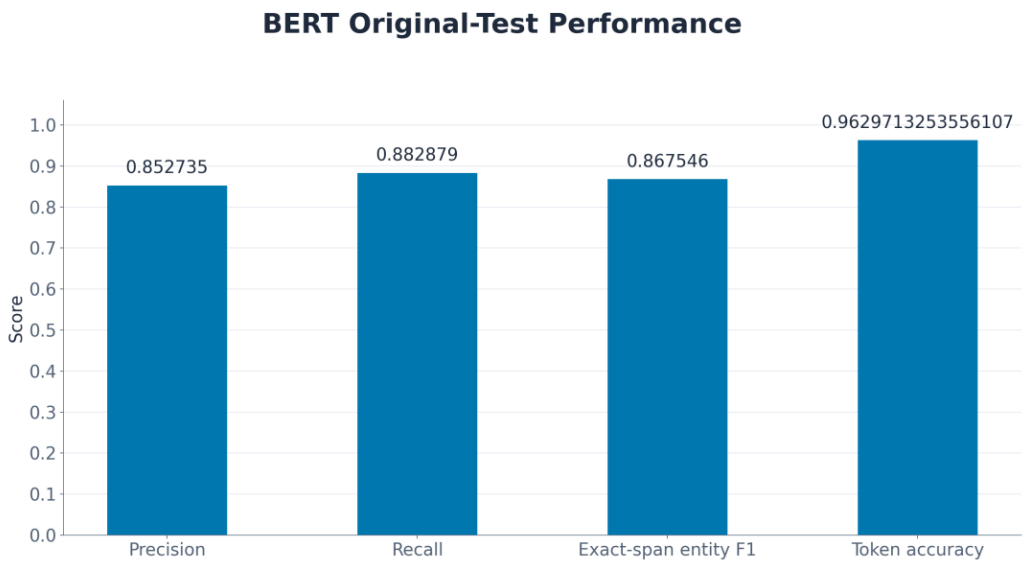


Figure6-1. Original-test performance summary for BERT

Source: authoritative BERT documentation package. The chart reports the original split, which contains documented train–test overlap; it is not production accuracy.

6.3.3 Dataset Integrity and Generalization Boundaries

Table6-10. DNRTI dataset audit and quality-gate evidence

Split / check	Recorded evidence	Interpretation
Training split	5,251 sentences; 140,348 parseable tokens; 18,921 entities; 179 malformed lines	1,366 duplicate rows and 17 texts with conflicting label sequences were recorded.
Validation split	662 sentences; 17,602 tokens; 2,173 entities; 7 malformed lines	43 duplicate rows and one conflicting text were recorded.
Test split	664 sentences; 17,716 tokens; 2,348 entities; 16 malformed lines	59 duplicate rows and 11 conflicting texts were recorded.
Cross-split overlap	271 train–validation; 308 train–test; 54 validation–test shared unique sentences	The original split is not leakage-free.
Unique train-unseen test	297 sentences	BERT recorded 0.719566 F1 on the unique train-unseen evaluation, satisfying the report acceptance criterion, Unique Train Unseen > 70%.

Split / check	Recorded evidence	Interpretation
Dataset-integrity checks	Cross-split overlap, conflicting label sequences, and malformed rows were documented in the preserved DNRTI splits.	These dataset-integrity limitations remain independent of the unique train-unseen F1 results and should be considered when interpreting model performance.

The repository parser discarded malformed rows without inventing tokens. The training file contained 140,348 parseable tokens, while the primary paper reports 140,526; the paper's undocumented corrections or dataset-version differences could not be reconstructed. The experiment therefore preserved the repository splits and reported the discrepancy rather than altering the source data.

6.3.4 Interpretation and Production Transition

The primary paper reports BERT precision 0.874, recall 0.928, and F1 0.899, but it does not establish that its aggregation, corrections, and split handling are equivalent to ACTIT exact-span entity micro evaluation. Direct numerical parity is therefore not claimed. Token accuracy and all-class token micro-F1 are also kept separate because they are dominated by the O class and do not substitute for exact-span entity F1.

At the authenticated production capture on 4 October 2026, deployment of the adopted BERT model had not yet been verified. That dated observation does not change the adopted architecture. Post-deployment verification must establish the model identity, output-contract equivalence, readiness, model-status API evidence, runtime error handling, rollback, and replacement English/LTR screenshots.

6.4 Internal Session and Outlier Evaluation

Production verification confirmed the session-analysis result contract and analyst-facing explanations. The captured page showed normal sessions, so it establishes presentation and traceability rather than anomaly-detection accuracy or a confirmed malicious case.

The internal-analysis implementation has deterministic configuration evidence: 30-minute inactivity sessionization, a fixed 15-feature vector, Isolation Forest with 200 estimators and random state 42, and a documented heuristic for fewer than four sessions. Automated tests exercise connector normalization, sessionization, feature construction, detector result contracts, and internal orchestration. These tests establish expected software behavior within their recorded version scope.

The authenticated Outlier Sessions screen showed stored normal sessions with boundaries, alert counts, scores, status, and human-readable factors. This verifies persistence and analyst presentation without exposing raw feature vectors. No labelled production benchmark was available, so the report does not claim precision, recall, F1, or real-world anomaly-detection accuracy for the internal detector.

6.5 Production Deployment and Readiness Verification

The verified production source for this report is release 20260928T102847Z-ae9bf948. Authenticated evidence captured on 4 October 2026 confirmed the deployed React frontend, FastAPI backend path, PostgreSQL health, External Sources, Gateway-mediated internal telemetry, MISP connectivity, dark-web monitoring configuration, and analyst investigation routes.

Dashboard counts and health values are point-in-time observations. System Readiness does not prove firewall, public-port, backup, restore, or end-to-end correctness. No service was changed during documentation capture.

On 7 October 2026, a temporary controlled public HTTPS path was enabled for the graduation defense through Tailscale Funnel. HTTPS port 443 terminated at the existing ACTIT frontend, while application authentication and role-based access control remained active. The backend, PostgreSQL, CTI Gateway, External Sources, and MISP services were not exposed directly. This path changed frontend reachability rather than ACTIT processing semantics (Figure 6-2 and Appendix Figures D-5 and D-6).

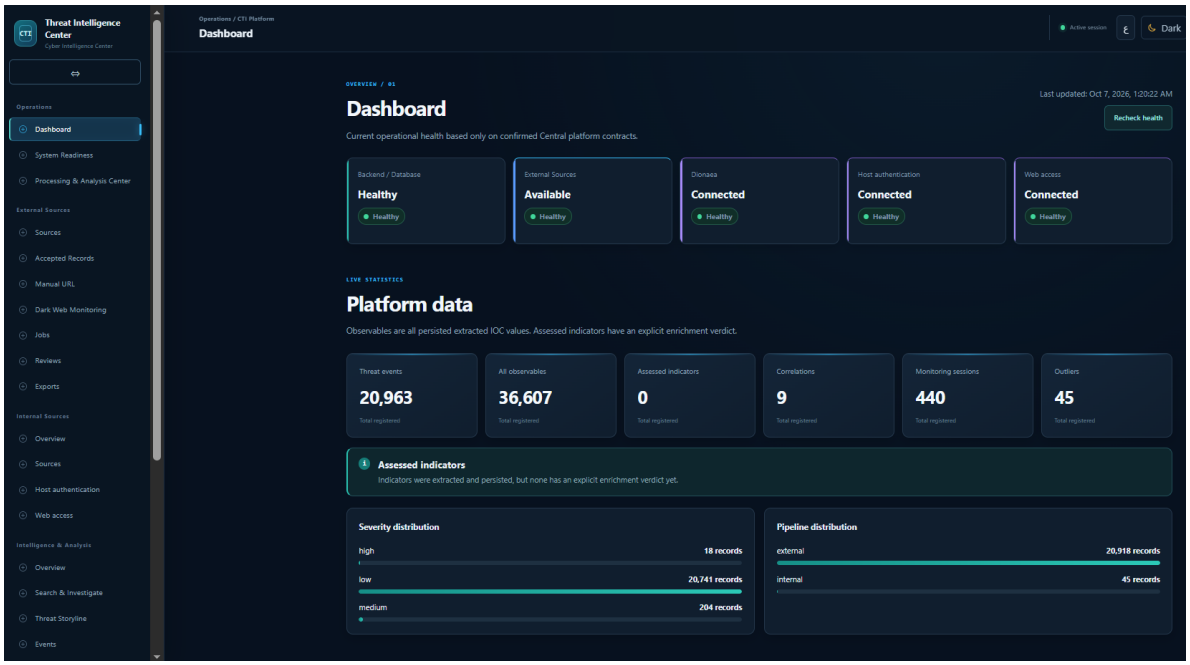


Figure6-2. Authenticated ACTIT dashboard accessed through the public HTTPS Funnel endpoint

Source and limitation: authenticated production observation captured on 7 October 2026 through the public HTTPS Funnel endpoint. ACTIT authentication remained enabled; visible counts are point-in-time values.

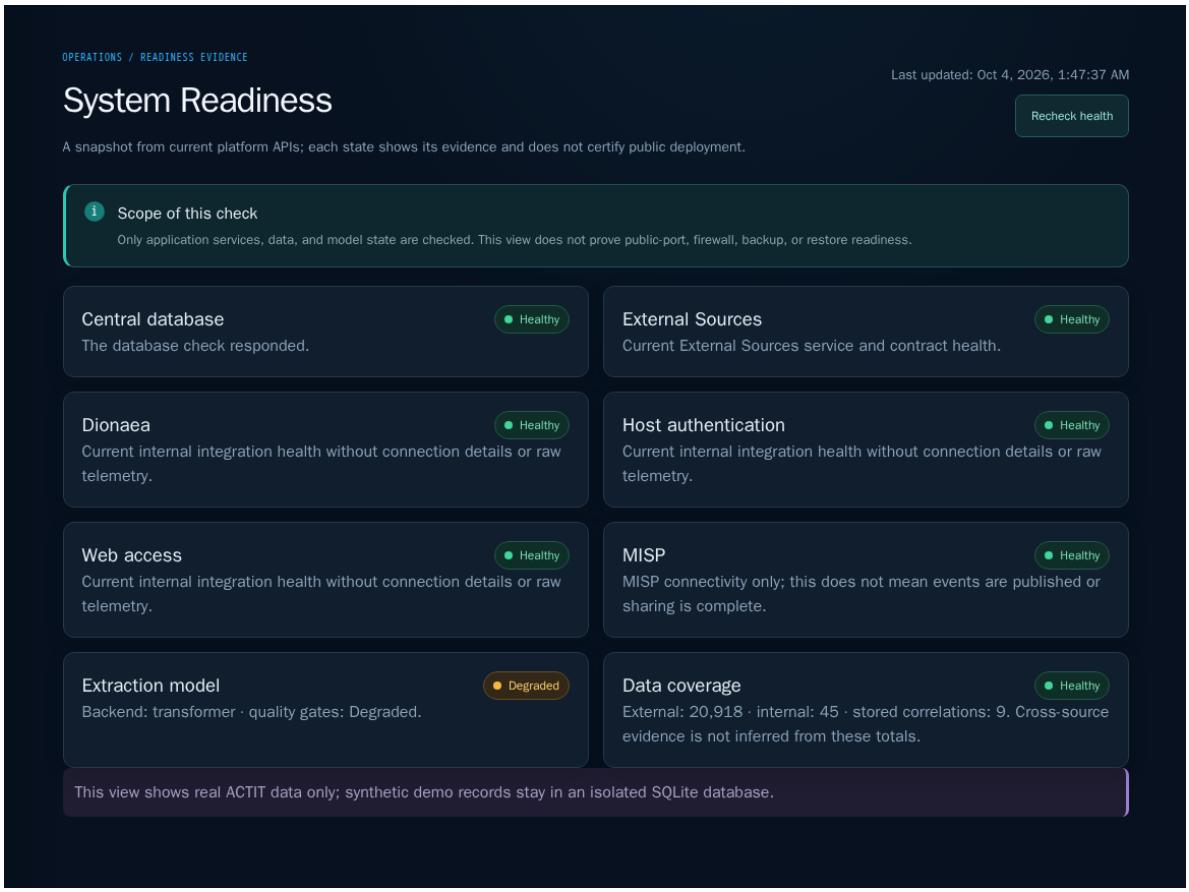


Figure6-3. Authenticated System Readiness view

Readiness summarizes component evidence and does not by itself prove firewall, backup restoration, or end-to-end correctness.

6.6 Verified Analyst Workflows

Read-only production navigation verified Dashboard, Readiness, Processing Center, External Sources, Reviews, Dark Web, internal-source views, Global Search, Event Details, Threat Storyline, Observables, ATT&CK, correlations, outliers, model evidence, MISP, Jobs, Exports, and Administration where authorized. During the 4 October 2026 read-only verification session, no ingestion, review decision, source change, scan, user change, export download, or MISP delivery was performed.

A filtered Threat Events listing displayed a UI error while its API response returned HTTP 200; Global Search and direct event/storyline views remained functional. This is recorded as a production discrepancy, not silently corrected in the report.

The verified investigation workflow begins with a bounded query in Global Intelligence Search, which returns provenance, match information, severity, and record pivots. Opening an existing Threat Event exposes its source, confidence, deterministic risk factors, eligible

vulnerability identifiers, and available STIX action. Threat Storyline then arranges recorded evidence and time information while explicitly avoiding unsupported causal inference.

From the event, the analyst can inspect extracted observables and their format validity, review ATT&CK technique candidates with supporting text and confidence, request NVD enrichment for eligible CVEs, and inspect available correlation or outlier context. MISP remains a separate governed destination: candidate selection, preview, deterministic identity, and delivery history support controlled sharing, while PostgreSQL retains the authoritative ACTIT record.

Production access also confirmed Dashboard, Readiness, Processing Center, External Sources, Reviews, Dark Web Monitoring, Internal Sources, Model Evidence, Jobs, Exports, and authorized Administration/Audit routes. The screenshot set is selective; omitted pages were either redundant, volatile, privacy-sensitive, or associated with state-changing controls that were intentionally not used.

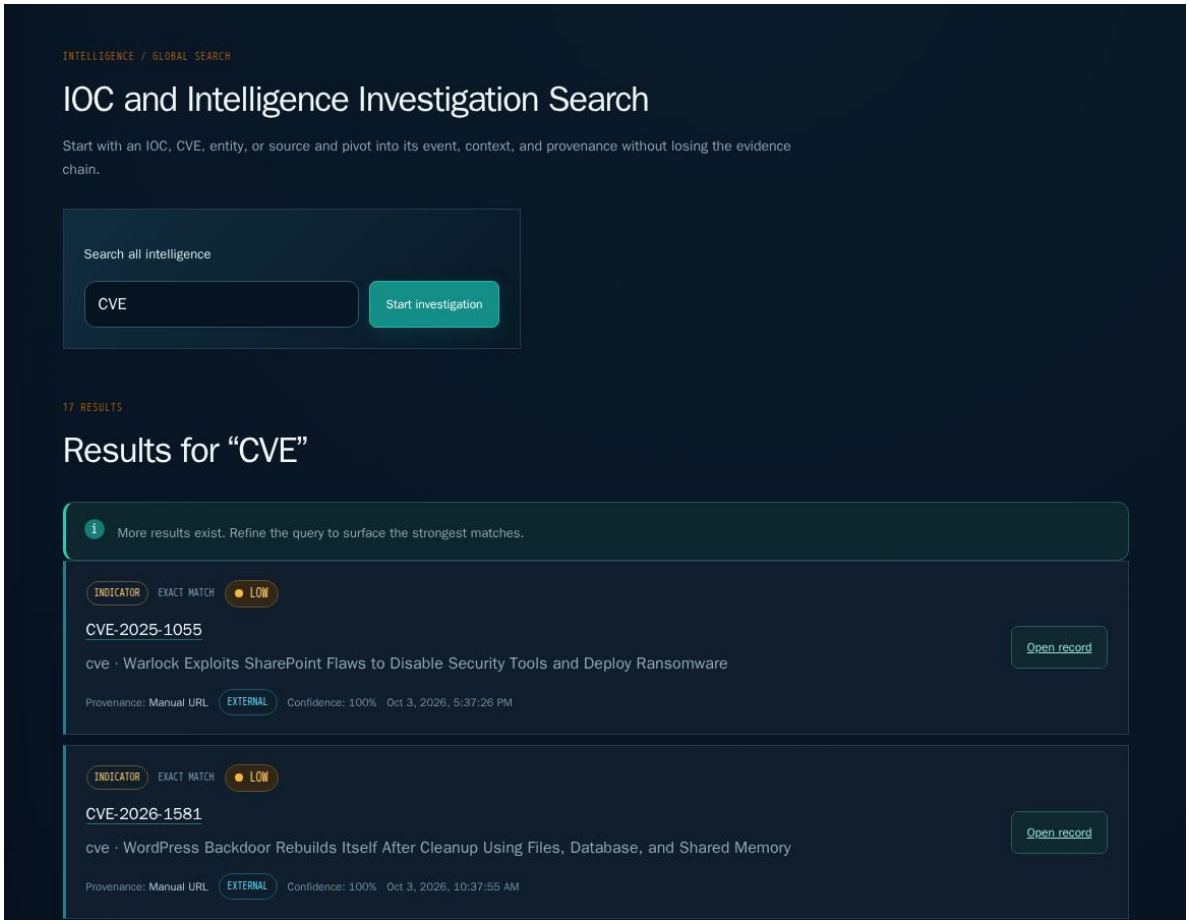


Figure6-4. Global Intelligence Search

Read-only production query using the generic term CVE; results are bounded and point-in-time.

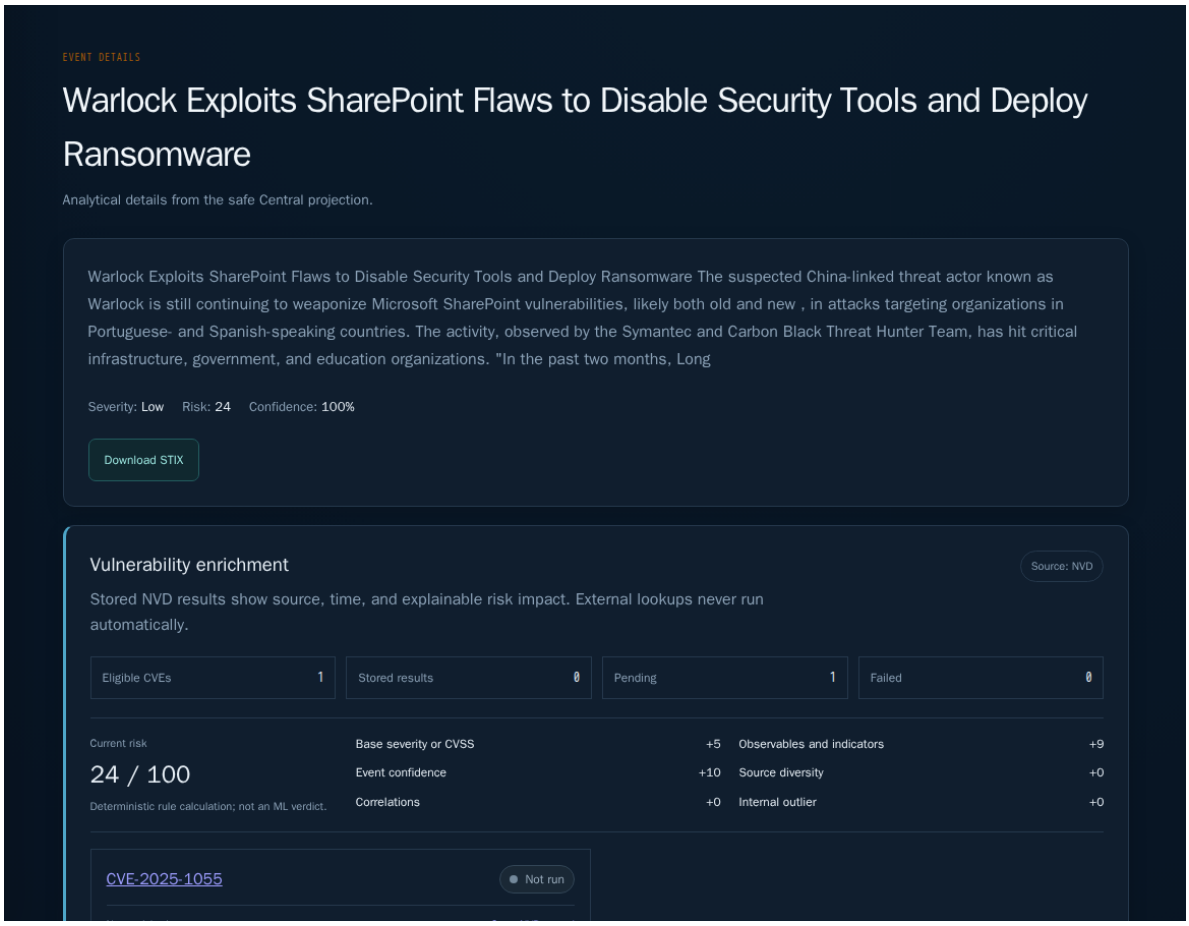


Figure6-5. Threat Event Details

Existing production event; extracted evidence and deterministic risk must not be interpreted as confirmed maliciousness or an ML verdict.

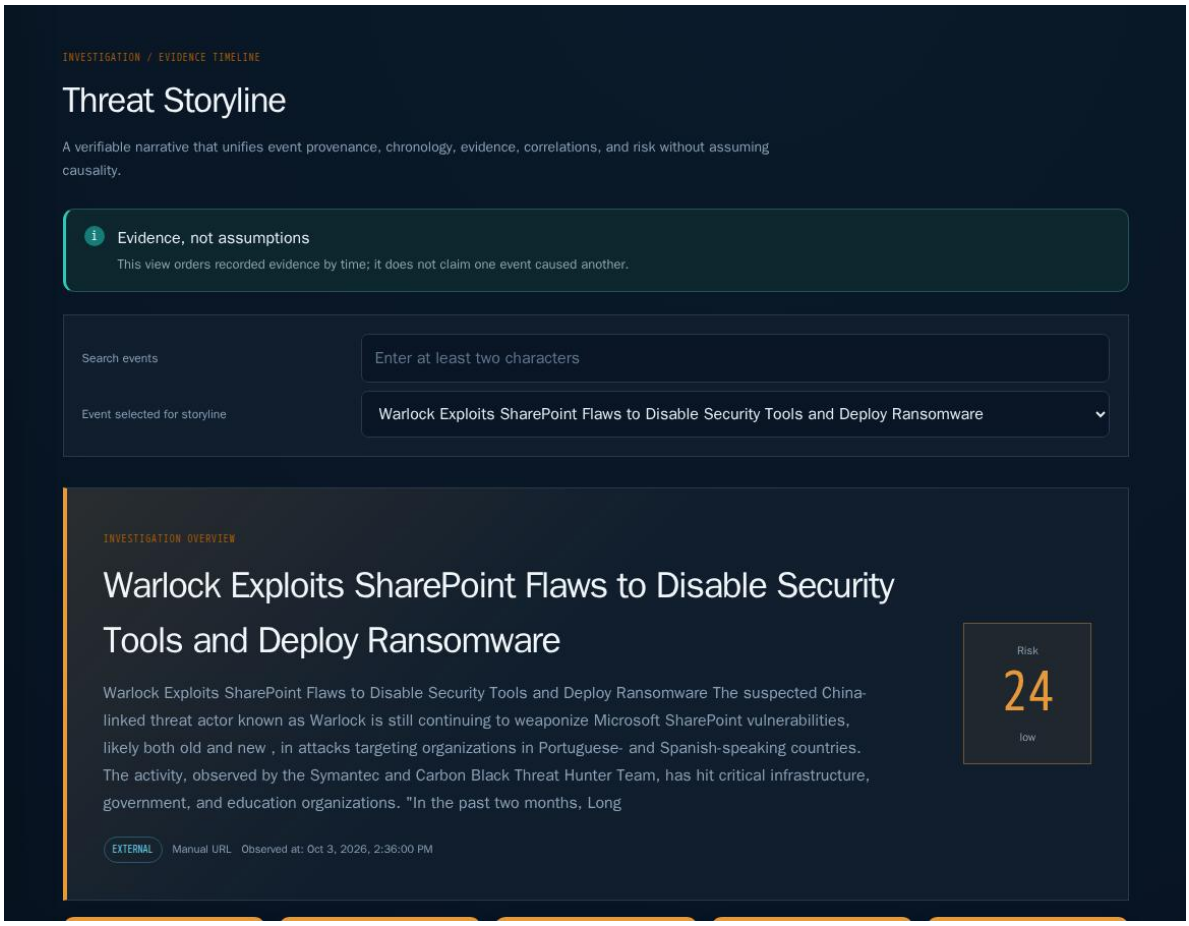


Figure6-6. Threat Storyline

Evidence chronology for an existing record; the view does not prove causal relationships.

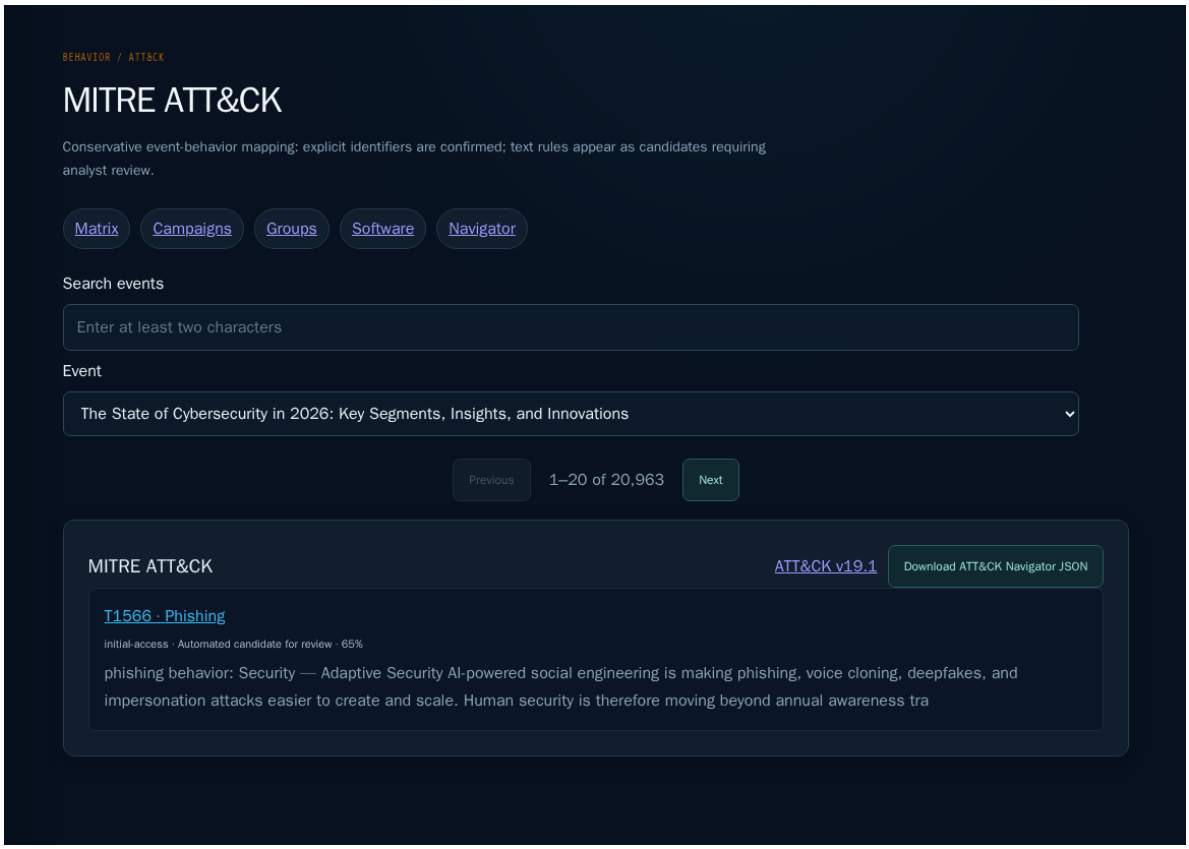


Figure6-7. MITRE ATT&CK review candidate

The visible automated mapping requires analyst review and is not confirmed ground truth.

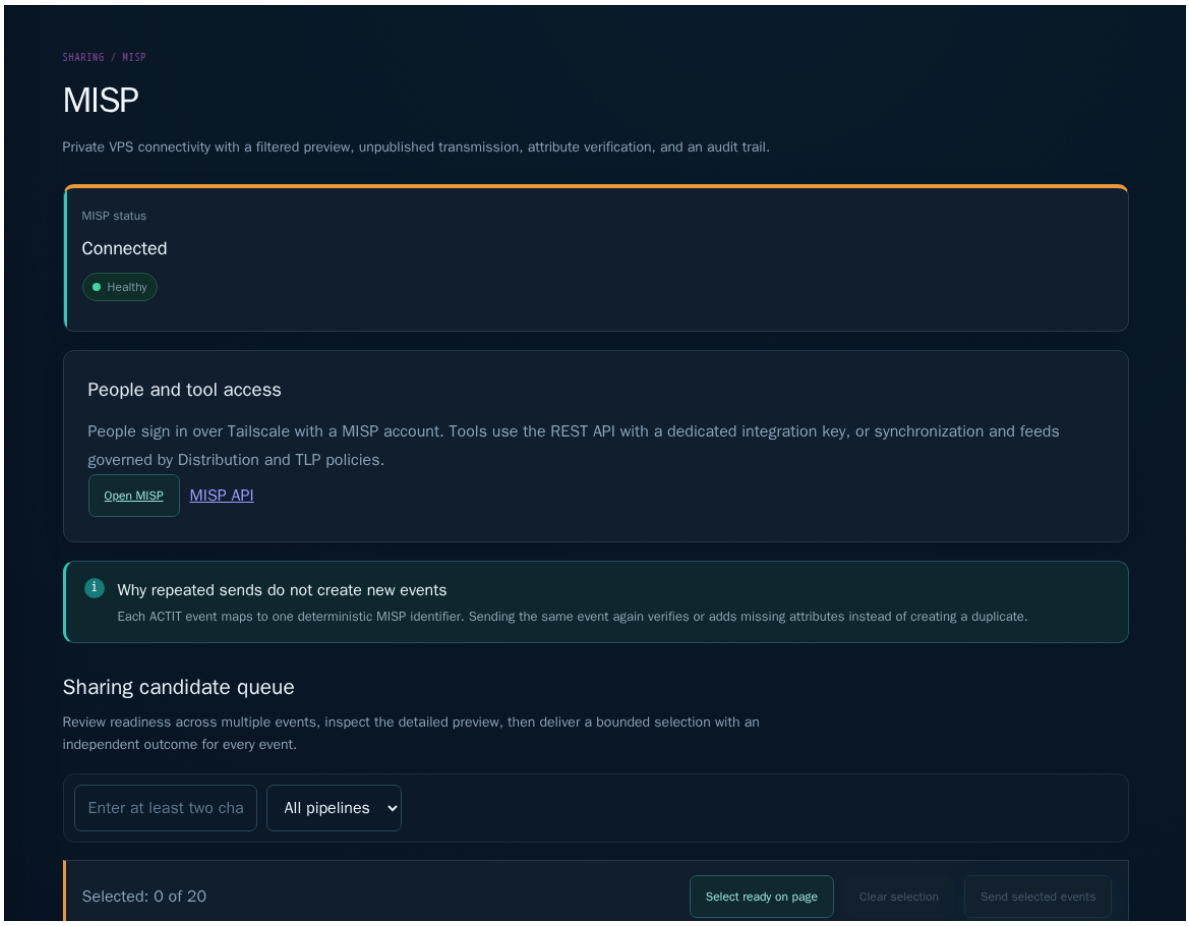


Figure6-8. MISP governance and delivery boundary

MISP was connected, but no event was selected, previewed, delivered, or published during documentation capture.

The production MISP server contained existing event records at the time of capture. This provides visual evidence of the operational MISP environment used by ACTIT; the screenshot alone does not establish that all visible events originated from ACTIT. PostgreSQL remains ACTIT's authoritative operational repository, while MISP remains a governed sharing destination.

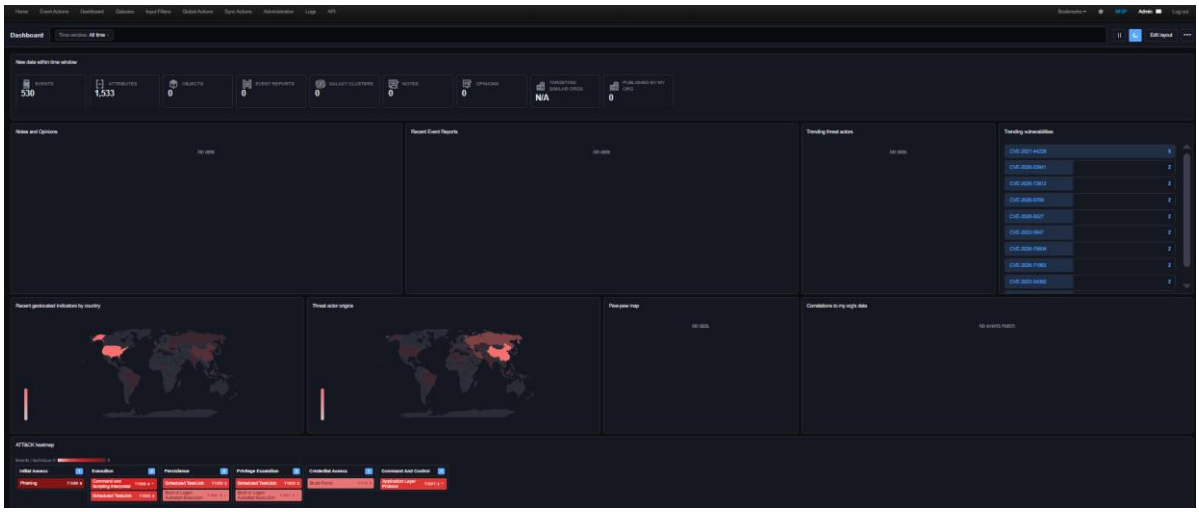


Figure6-9. Production MISP event records in the operational sharing environment

Source and limitation: existing sanitized production screenshot. It establishes an operational MISP environment with event records; it does not prove that every visible event was created by ACTIT.

6.7 Verified NVD Enrichment Workflow

The bounded production verification selected 28 CVEs across 22 existing events. All 28 completed successfully; none failed, returned not-found, or was skipped. The ACTIT client accessed real NVD data without an API key, used a conservative maximum of five requests per 31 seconds, encountered no HTTP 429 response, and required no retry. Results persisted in PostgreSQL and repeated independent API requests returned the same stored evidence.

Twenty-five of the 28 stored records contained complete CVSS data; three recent records did not include CVSS. All 28 contained CWE information and provider timestamp/evidence. Representative stored results include CVE-2021-44228 (CVSS 3.1 score 10.0; CWE-502), CVE-2024-3400 (CVSS 3.1 score 10.0; CWE-20 and CWE-77), CVE-2025-53770 (CVSS 3.1 score 9.8; CWE-502), CVE-2024-38112 (CVSS 3.1 score 7.5; CWE-451), and CVE-2022-22965 (CVSS 3.1 score 9.8; CWE-94). This bounded run does not establish universal NVD coverage or continuous synchronization. It verifies lookup, persistence, and analyst presentation; it does not validate CVSS-driven risk recomputation.

Table6-11. Representative stored NVD enrichment evidence

CVE	CVSS version	Base score	Stored CWE evidence
CVE-2021-44228	3.1	10.0	CWE-502
CVE-2024-3400	3.1	10.0	CWE-20; CWE-77
CVE-2025-53770	3.1	9.8	CWE-502
CVE-2024-38112	3.1	7.5	CWE-451
CVE-2022-22965	3.1	9.8	CWE-94



Figure6-10. NVD enrichment before the bounded analyst action

Sanitized production evidence: eligible CVEs, zero stored results, and an explicit non-automatic pending state.

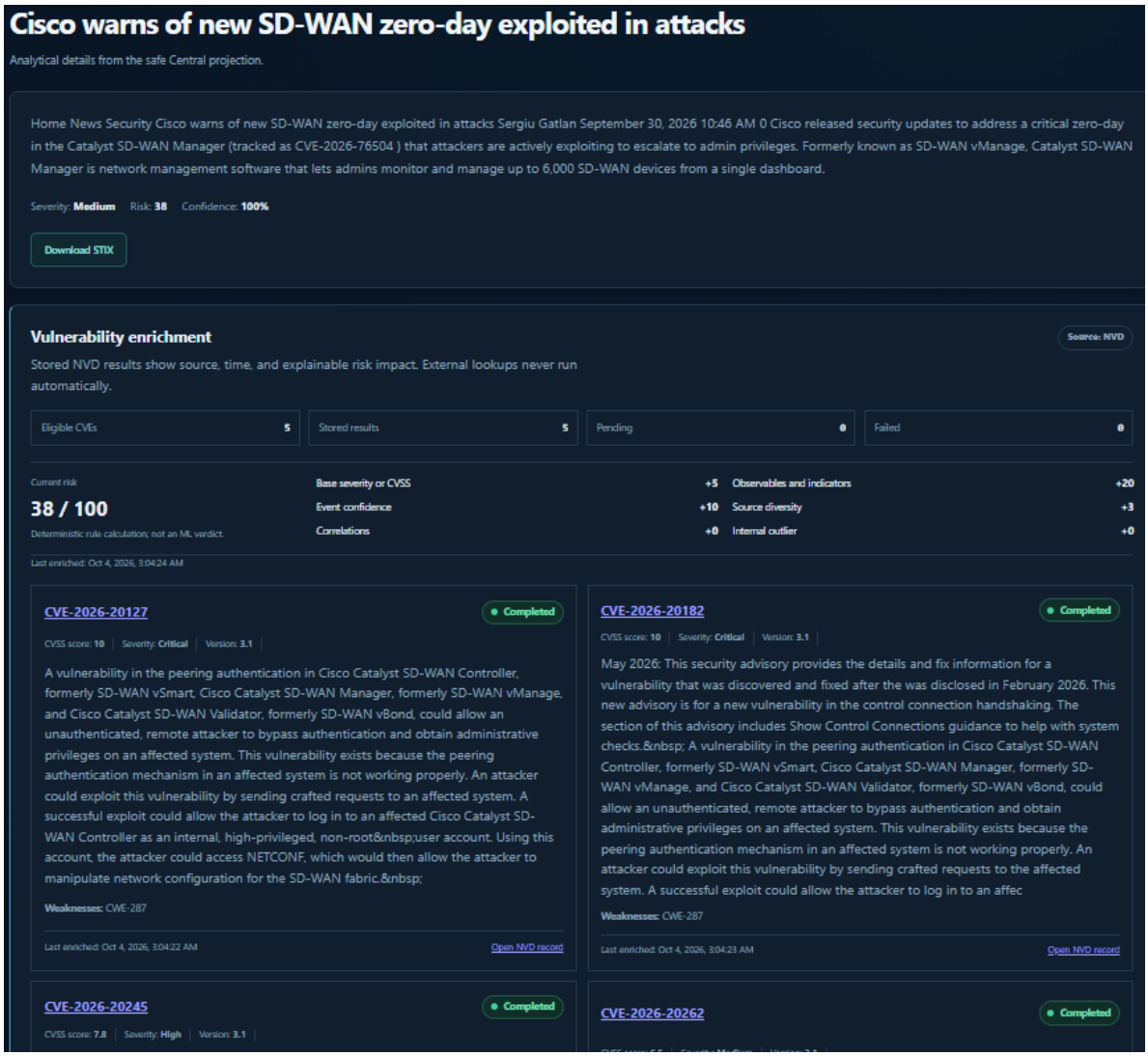


Figure6-11. NVD enrichment after successful persistence

Sanitized production evidence: completed CVE cards with stored CVSS, description, and CWE data. Visible risk changes are not treated as causal proof.

6.8 NER Transition: Captured Deployment versus Final Architecture

At the 4 October 2026 evidence capture, deployment of the adopted BERT model had not yet been verified. Saved production-screen percentages are not live production accuracy and are not used as evaluation results for the adopted model. Its preserved original-test and unique train-unseen scores are reported in Section 6.3.

BERT is the adopted NER model. A future promotion requires new runtime-identity, readiness, rollback, and deployment evidence; until then, the 4 October state remains the verified deployment observation.

6.9 Repository, Report, and Production Discrepancies

The final-production branch was reconciled with the submitted repository state before final delivery. Historical differences between earlier workspace snapshots and the deployed release remain documented in Appendix A for provenance.

Table6-12. Repository, production, and submission-state differences

Topic	Verified production state	Final submission treatment
Durable ingestion	Present in release 20260928T102847Z-ae9bf948	Final repository state reconciled; historical production-release provenance is retained in the verification ledger.
BERT NER model	Adopted-model deployment unverified at 4 October capture	Final design documented; post-promotion evidence still required.
Dark-web monitoring	Active configured production views	Documented as deployed and bounded.
Wazuh	Runtime stack absent	Connector described as implemented but not deployed.
TAXII	No deployed ACTIT transport	Background/future interoperability only.
Filtered Threat Events	UI error while API returned HTTP 200	Workflow uses verified Global Search/direct-event path; UI defect remains follow-up.

Other corrected report discrepancies include active dark-web configuration, non-deployed Wazuh, non-implemented TAXII transport, MISP's sharing role, observable/indicator semantics, ATT&CK candidate semantics, and the dated NER deployment state.

6.10 Discussion and Threats to Validity

The evidence supports a working VPS-hosted CTI prototype and several verified analyst workflows, but it does not establish enterprise availability, universal enrichment, labelled anomaly/correlation effectiveness, comprehensive cross-source correlation in current stored data, full STIX conformance, backup restoration, or a fresh complete regression result.

BERT evidence is limited by one deterministic seed, malformed rows, within-split conflicts, cross-split sentence overlap, non-equivalent paper metrics, and reduced

generalization performance on the unique train-unseen subset. Production UI observations are dated samples and may change as data and deployment state evolve.

6.11 Chapter Summary

Evaluation evidence is kept separate from implementation claims. The preserved artifacts establish bounded functional and model results; production inspection establishes a dated deployment and UI state; unresolved discrepancies and limitations constrain broader conclusions.

Chapter 7:

Conclusions and Future Work

7.1 Project Summary

ACTIT demonstrates a working VPS-hosted cyber threat intelligence tool that integrates bounded external collection, internal security telemetry, provenance-preserving processing, AI-assisted analysis, analyst investigation, and governed intelligence sharing. Design, implementation, saved evaluation, and dated deployment evidence are reported separately.

7.2 Principal Contributions

1. A unified CTI lifecycle that converges heterogeneous external intelligence and internal telemetry into a source-independent processing and persistence model.

2. BERT is the adopted model for named entity recognition. Preserved offline evaluation supports this design, while dated production observations and pending deployment verification are reported separately.

3. Evidence-preserving analytics through deterministic indicator, entity, and relationship extraction; session-level Isolation Forest outlier analysis; correlation; explainable risk factors; ATT&CK review candidates; audit records; and source provenance.

4. Standards and interoperability support through STIX 2.1 export and selective MISP sharing while retaining PostgreSQL as the authoritative ACTIT datastore.

5. A VPS-oriented deployment with private Tailscale access, loopback/internal service boundaries, Docker/Compose infrastructure, preserved data volumes, and automated regression coverage.

7.3 Consolidated Limitations

1. The current Wazuh connector is implemented in code, but Wazuh Manager/Indexer/Dashboard are not deployed on the verified VPS baseline.

2. Live enrichment data is limited even though NVD/CVE enrichment capability exists; enrichment coverage should therefore be described separately from enrichment implementation.

3. ATT&CK rule-based mappings are analyst-review candidates unless an explicit technique identifier is present; they are not automatic proof of adversary behavior.

4. External-source collection is bounded and scheduled rather than a claim that every source and processing stage is fully real-time.

5. Repository and deployment snapshots differed during parts of the verification period; their exact identities and reconciliation history are retained in Appendix A. The submitted remote branches were reconciled before final delivery.

6. Registration, authenticated global intelligence search, storyline and readiness surfaces are present in the verified deployed release; deeper explanation/evidence drill-down and broader product hardening still require separate evaluation where not explicitly evidenced.

7. ACTIT adopts BERT for named entity recognition. The 26 September package reports original-split F1 0.867546 and unique train-unseen F1 0.719566. The unique train-unseen result satisfies the report acceptance criterion, Unique Train Unseen > 70%, and is considered satisfactory for this offline evaluation. Deployment of the adopted model had not been verified at the 4 October production capture.

Additional evidence limitations include the read-only UI sample, no fresh complete regression or coverage result, no verified off-host restore exercise, current same-pipeline correlation examples, and the BERT data-integrity and single-seed constraints.

7.4 Final NER Promotion and Post-Deployment Verification

After BERT is promoted through a separately authorized production change, ACTIT must verify immutable release identity, model identity and artifacts, readiness state, runtime error handling, output-contract consistency, model-status API and UI evidence, rollback target, and replacement English/LTR screenshots.

Promotion evidence should remain version-scoped so that the final architecture can be distinguished from each dated deployment state.

7.5 Future Work

1. Maintain immutable release tags and evidence manifests so that future deployments remain directly traceable to the submitted source baseline.

2. Expand controlled NVD/CVE enrichment runs and expose enrichment provenance, freshness, and risk-factor contributions consistently in the API and analyst interface.

3. Deploy Wazuh on an appropriately sized or separate host if full Wazuh runtime integration becomes a project requirement, while retaining the existing connector boundary.

4. Broaden MITRE ATT&CK catalog coverage while preserving the distinction between explicit identifiers, rule-based review candidates, and analyst confirmation.

5. Add optional TAXII interoperability only after the current STIX/MISP boundaries remain stable and authenticated, and document it as a separate capability.

6. Extend the already implemented bounded search/storyline/readiness capabilities with deeper correlation explanations, evidence drill-down, usability evaluation, and deterministic demonstration datasets.

7. Continue security hardening through rate limits, SSRF regression checks, input/output controls, audit completeness, secret-management review, and repeatable deployment verification.

8. To strengthen BERT after promotion, remediate DNRTI split overlap, conflicting labels, and malformed rows; rerun leakage-resistant unique train-unseen evaluation using a prospectively defined acceptance criterion; package auditable checkpoint weights; verify runtime selection and error handling; and retain reversible deployment evidence.

7.6 Conclusion

ACTIT demonstrates that heterogeneous external threat intelligence and internal security telemetry can be integrated into a single, traceable analyst workflow without treating automated outputs as unquestioned security judgments. The implemented tool combines controlled collection, deterministic processing, AI-assisted entity extraction and anomaly analysis, correlation, vulnerability enrichment, investigation, and governed STIX/MISP sharing while preserving provenance and analyst oversight. Production verification demonstrates the practical viability of the architecture within the project environment, while the documented model, dataset, deployment, and scalability limitations define clear boundaries for future improvement.

Project Repository: https://github.com/AmmarAikan/CTI-Tool.git

References

[1] A. Spyros, I. Koritsas, A. Papoutsis, P. Panagiotou, D. Chatzakou, D. Kavallieros, T. Tsikrika, S. Vrochidis, and I. Kompatsiaris, “AI-Based Holistic Framework for Cyber Threat Intelligence Management,” IEEE Access, vol. 13, pp. 20820–20846, 2025, doi: 10.1109/ACCESS.2025.3533084.

[2] L. Alevizos and M. Dekker, “Towards an AI-Enhanced Cyber Threat Intelligence Processing Pipeline,” Electronics, vol. 13, no. 11, Art. no. 2021, 2024, doi: 10.3390/electronics13112021.

[3] W. Tounsi and H. Rais, “A survey on technical threat intelligence in the age of sophisticated cyber attacks,” Computers & Security, vol. 72, pp. 212–233, 2018, doi: 10.1016/j.cose.2017.09.001.

[4] MISP Project, “MISP Documentation and Support.” [Online]. Available: https://www.misp-project.org/documentation/. [Accessed: Oct. 4, 2026].

[5] MITRE, “MITRE ATT&CK.” [Online]. Available: https://attack.mitre.org/. [Accessed: Oct. 4, 2026].

[6] C. Johnson, L. Badger, D. Waltermire, J. Snyder, and C. Skorupka, Guide to Cyber Threat Information Sharing, NIST Special Publication 800-150. Gaithersburg, MD, USA: National Institute of Standards and Technology, 2016, doi: 10.6028/NIST.SP.800-150.

[7] B. Jordan, R. Piazza, and T. Darley, Eds., STIX Version 2.1, OASIS Standard, Jun. 10, 2021. [Online]. Available: https://docs.oasis-open.org/cti/stix/v2.1/os/stix-v2.1-os.html.

[8] B. Jordan and D. Varner, Eds., TAXII Version 2.1, OASIS Standard, Jun. 10, 2021. [Online]. Available: https://docs.oasis-open.org/cti/taxii/v2.1/os/taxii-v2.1-os.html.

[9] MITRE, “Get Started: MITRE ATT&CK,” Apr. 2024. [Online]. Available: https://attack.mitre.org/resources/. [Accessed: Oct. 4, 2026].

[10] MISP Project, “MISP Features and Functionalities.” [Online]. Available: https://www.misp-project.org/features/. [Accessed: Oct. 4, 2026].

[11] J. Devlin, M.-W. Chang, K. Lee, and K. Toutanova, “BERT: Pre-training of Deep Bidirectional Transformers for Language Understanding,” in Proc. NAACL-HLT, Minneapolis, MN, USA, 2019, pp. 4171–4186, doi: 10.18653/v1/N19-1423.

[12] V. Yadav and S. Bethard, “A Survey on Recent Advances in Named Entity Recognition from Deep Learning Models,” in Proc. 27th Int. Conf. Computational Linguistics, Santa Fe, NM, USA, 2018, pp. 2145–2158.

[13] L. A. Ramshaw and M. P. Marcus, “Text Chunking using Transformation-Based Learning,” in Proc. Third Workshop on Very Large Corpora, Cambridge, MA, USA, 1995, pp. 82–94.

[14] P. Evangelatos, C. Iliou, T. Mavropoulos, K. Apostolou, T. Tsikrika, S. Vrochidis, and I. Kompatsiaris, “Named Entity Recognition in Cyber Threat Intelligence Using Transformer-Based Models,” in Proc. 2021 IEEE Int. Conf. Cyber Security and Resilience, Rhodes, Greece, 2021, doi: 10.1109/CSR51186.2021.9527981.

[15] F. T. Liu, K. M. Ting, and Z.-H. Zhou, “Isolation Forest,” in Proc. 8th IEEE Int. Conf. Data Mining, Pisa, Italy, 2008, pp. 413–422, doi: 10.1109/ICDM.2008.17.

[16] K. Peffers, T. Tuunanen, M. A. Rothenberger, and S. Chatterjee, “A Design Science Research Methodology for Information Systems Research,” Journal of Management

Information Systems, vol. 24, no. 3, pp. 45–77, 2007, doi: 10.2753/MIS0742-1222240302.

[17] National Institute of Standards and Technology, “National Vulnerability Database: Vulnerability Details.” [Online]. Available: https://nvd.nist.gov/vuln/Vulnerability-Detail-Pages. [Accessed: Oct. 4, 2026].

[18] FIRST, “Common Vulnerability Scoring System v3.1: Specification Document,” Jun. 2019. [Online]. Available: https://www.first.org/cvss/v3-1/specification-document. [Accessed: Oct. 4, 2026].

[19] MITRE, “Common Weakness Enumeration.” [Online]. Available: https://cwe.mitre.org/. [Accessed: Oct. 4, 2026].

[20] CVE Program, “Common Vulnerabilities and Exposures.” [Online]. Available: https://www.cve.org/. [Accessed: Oct. 4, 2026].

Appendix A: Verification and Version Ledger

This appendix records the source, date, and scope of each implementation and production claim so that different releases, test snapshots, model artifacts, and UI observations are not combined as one state. The primary production release for the final submission is 20260928T102847Z-ae9bf948, with authenticated UI evidence dated 4 October 2026. Earlier verification states included workspace 91c823a, prior deployment 7e6364b, audited VPS worktree HEAD 17d593765c84cf45518ce67b8f16dd6615dd05db, and upstream bfac0eab. Before final delivery, remote main and codex/actit-final-production both resolved to 7e76c14b8a47235d526a83bb61591e3f91315fb4; the earlier differences remain historical provenance.

The final submission evidence baseline uses production release 20260928T102847Z-ae9bf948 and authenticated UI observations captured on 4 October 2026. Source inspection, saved tests, model experiments, runtime observations, and screenshots are treated as distinct evidence classes.

A future production promotion of BERT would require recording immutable release identity, model identity, runtime error handling, health and readiness state, output-contract equivalence, rollback evidence, and replacement English/LTR screenshots. Until such verification exists, the dated runtime subsection remains historical evidence rather than a claim that the adopted model was deployed.

TableA-1. Verification and version ledger

Evidence class	Identity / date	Supported claim
Primary production release	20260928T102847Z-ae9bf948	Verified deployed service and durable-ingestion baseline.
Authenticated UI evidence	4 October 2026	Read-only production routes, workflows, screenshots, and point-in-time readiness.
BERT evidence package	20260924T000911Z package finalized 26 September 2026	Training configuration, exact metrics, quality gates, hashes, and limitations.
NVD bounded verification	Documentation evidence cycle, October 2026	28/28 lookup and persistence outcome; does not validate CVSS-to-risk recomputation.
Final NER deployment	Pending owner-controlled promotion	Requires new immutable release, runtime identities, fallbacks, health, screenshots, and rollback evidence.

Appendix B: Implementation Evidence Register

E01–E20 preserve the initial inspected evidence, E21–E27 record the completed 25 September release comparison, and E28 records the supplied 26 September BERT evidence package. Dated runtime checks, saved metrics, test source, and actual test execution have distinct evidentiary meanings.

TableB-1. Verified implementation evidence register

ID	Evidence locator	Established claim and boundary
E01	Workspace Git HEAD/branch/status/remotes; release symlink; 451-blob comparison	Version separation and tracked-source equality
E02	GitHub repository, branch, tree, compare and Actions responses	Default branches, development divergence, source structure, absence of observed Actions workflows
E03	backend/app/main.py; backend/app/api/v1/router.py; live /openapi.json	FastAPI application; historical 102 pairs, superseded by E23 with 104
E04	frontend/package.json; frontend/src/pages/App.tsx; client.ts token handling	React/TypeScript/Vite, routes and sessionStorage bearer-token handling
E05	core/security.py; core/rate_limit.py; config.py; router register/login/admin/dependency logic	Password hashing, JWT, active-user check, RBAC, throttling and account management
E06	backend/app/db/database.py; db/models.py	PostgreSQL configuration, SQLite alternative and 12 ORM tables
E07	backend/app/pipeline/ingestion/external/; integration/local.py _connector lines 205–248; application/collection_service.py lines 149–210	Source dispatch, collection control, review/export state and error isolation
E08	Dark-web connector, source enablement/path checks, redirect policy and Tor proxy configuration	Approved, bounded, opt-in onion collection; not evidence of a successful current onion run
E09	orchestrator.py lines 125–179; IoCExtractor; relevance_classifier.py; model_loader.py; relation_extractor.py lines 18–193	Actual external processing order and separation of extraction/classification methods

ID	Evidence locator	Established claim and boundary
E10	pipeline_service.py external processing lines 288–379 and session persistence lines 552–608	Historical transaction/correlation behavior; current external batching superseded by E24; all-session semantics retained
E11	Internal connectors; internal_orchestrator.py lines 60–66; sessionizer; outlier detector lines 32–46	Dionaea/host/web/Wazuh inputs, idle-gap sessions, Isolation Forest and fallback
E12	ner_extractor.py lines 77–131, 255–295; ml/training/train_ner_bert.py lines 187–285; model_evidence_service.py	Captured NER runtime and training implementation; not proof of deployment of the adopted BERT model
E13	ml/reports/ner_test_metrics.json, ner_unseen_test_metrics.json, dnrti_integrity_report.json	Historical evaluation reports and dataset documentation; adopted BERT metrics are supplied separately in E28
E14	risk_scorer.py; correlator.py; nvd_client.py; attack_mapping_service.py	Deterministic scoring, indicator/text correlation, NVD normalization and explicit-vs-candidate ATT&CK mapping
E15	integrations/stix_exporter.py lines 44–199; misp_client.py lines 58–220; MISP router checks	Actual STIX object subset, selective sharing, unpublished MISP events and role restrictions
E16	compose.yaml; infra/vps/central.compose.yaml; infra/vps/compose.yaml; misp/compose.override.yaml; Dockerfiles	Deployment configuration and intended service/resource/network boundaries
E17	HTTP health responses; Tailscale serve status; HTTPS certificate-verifying requests; systemd service/timer properties	Observed reachability and operational failure described below
E18	Static AST count of test files/methods; test implementations using temporary files/SQLite; GitHub workflow inspection	Test inventory and why no fresh suite result is claimed
E19	Attached Word, SHA-256 below; extracted 876 paragraphs, 31 tables, 7 inline images	Exact documentation version audited; zero-based P/T evidence locators
E20	Development commits 2391fa94a137cc927b398c99ec9b146ec31d28d2 and 12a3de36686e7f2c5573032559ad987d69f8e7e8	Historical development changes, now found in the current release source and API contract (E23/E25)

ID	Evidence locator	Established claim and boundary
E21	Current .git worktree pointer/HEAD metadata; 451-blob old-to-current comparison	Full local HEAD reference, 404 unchanged/47 changed/0 missing; no Git safety override
E22	GitHub bfac0eab recursive tree (506 blobs), per-file Git-blob hashes on VPS	485 identical, 19 different, 2 absent; real repository divergence
E23	AST router declaration extraction vs live /openapi.json	104 matching method/path pairs; new NVD GET/POST and legacy confirmation schema
E24	Current pipeline_service.py, http_connector.py, infra/vps/gateway/app.py; batching and retention tests	Durable per-batch persistence, deferred global correlation, checkpoint/HMAC ACK, protected unacknowledged retention
E25	Router ML status lines 2315–2390; enrichment request schema lines 737–740; CVEEnrichmentPanel; Intelligence UI	ML evidence/readiness projections, bounded NVD workflow and analyst confirmation
E26	Current Dockerfiles, constraints.production.txt, Compose and collector/deployer script diffs	Pinned backend dependencies/base, gateway memory setting, diagnostics, explicit rollback boundary; isolated demo configuration
E27	AST inventory: 55 Python test files/487 test methods; inspected added test assertions; current GitHub tree	Static inventory and test scope; no current suite run; no workflows in current upstream tree
E28	User-supplied ACTIT_BERT_Paper_Parity_Documentation.zip (26 Sep 2026); PAPER_PARITY_REPORT.md; quality_gate_analysis.md; production_audit.md; metrics/*.json; provenance/SHA256SUMS.txt	Adopted BERT model: preserved offline measurements and documented dataset-integrity limitations; deployment of the adopted model was not verified at the 4 October production capture. The package recorded 83/83 matching hashes; no weights were included, and training was not rerun during the final evidence review.

Current Evidence Boundaries

Production release evidence prevails over earlier checkout snapshots when they diverge. Preserved historical pass counts remain tied to their recorded snapshots; static test inventory is not an execution result; saved model metrics are not live accuracy; and the 4 October UI evidence predates adopted BERT model promotion. The evidence register preserves these provenance boundaries and should be interpreted together with the final verification artifacts.

Appendix C: ACTIT Final NER Model Evidence and Deployment Transition

C.1 Evidence Scope

This appendix summarizes the preserved ACTIT BERT paper-parity package. Its reports, metrics, charts, manifests, compatibility checks, and rollback evidence support the adopted BERT model. Model weights and raw production records are outside the documentation package. The package establishes artifact consistency and offline evidence, while deployment status is established separately.

C.2 Adopted BERT Model and Evaluation

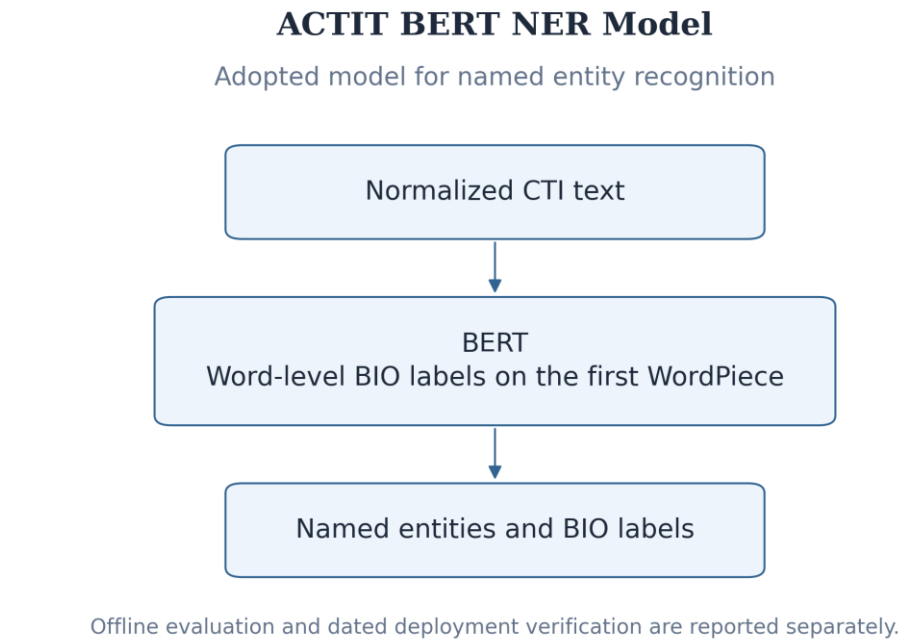
TableC-1. BERT evaluation and deployment transition

Model	Untouched test F1	Original test token accuracy	Unique train-unseen F1 (297 sentences)	State
BERT	0.867546	0.9629713253556107	0.719566	Adopted BERT model; offline evaluated; deployment verification pending at 4 October capture

BERT scores are measured on the original untouched test split, which still has train–test sentence overlap. Direct numerical parity with the reference paper is not claimed until metric aggregation and data preparation are shown equivalent. The experiment used one seed and physical batch size 2 with accumulation 8 (effective batch 16), rather than physical batch 16.

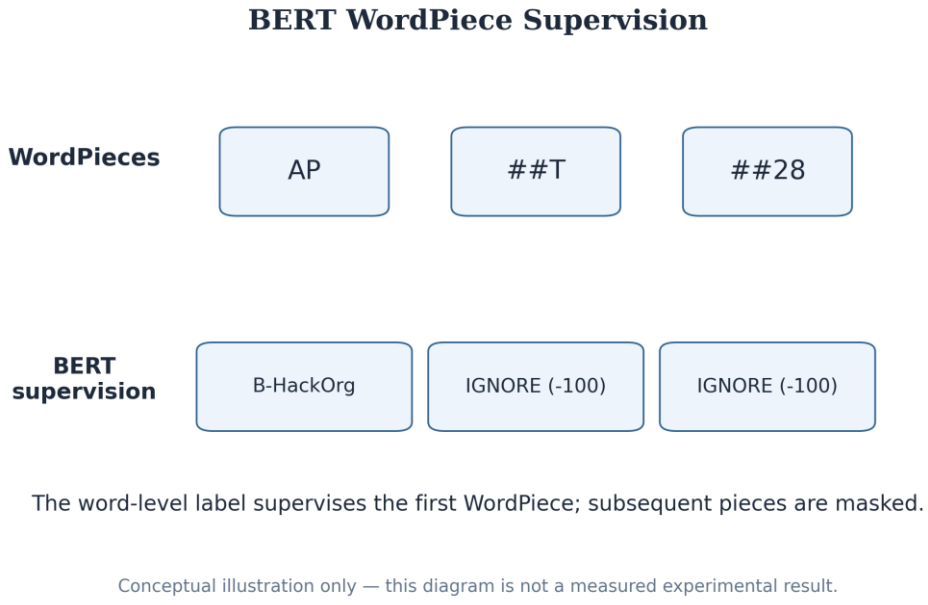
C.2.1 Adopted BERT Model

ACTIT adopts BERT for named entity recognition. The preserved evaluation records original-test exact-span entity F1 of 0.867546 and unique train-unseen F1 of 0.719566. The latter satisfies the report acceptance criterion, Unique Train Unseen > 70%. Deployment verification is reported separately from these offline results.



FigureC-1. ACTIT BERT NER Model and dated deployment transition

Source: final ACTIT design; the production note records the 4 October 2026 capture state.

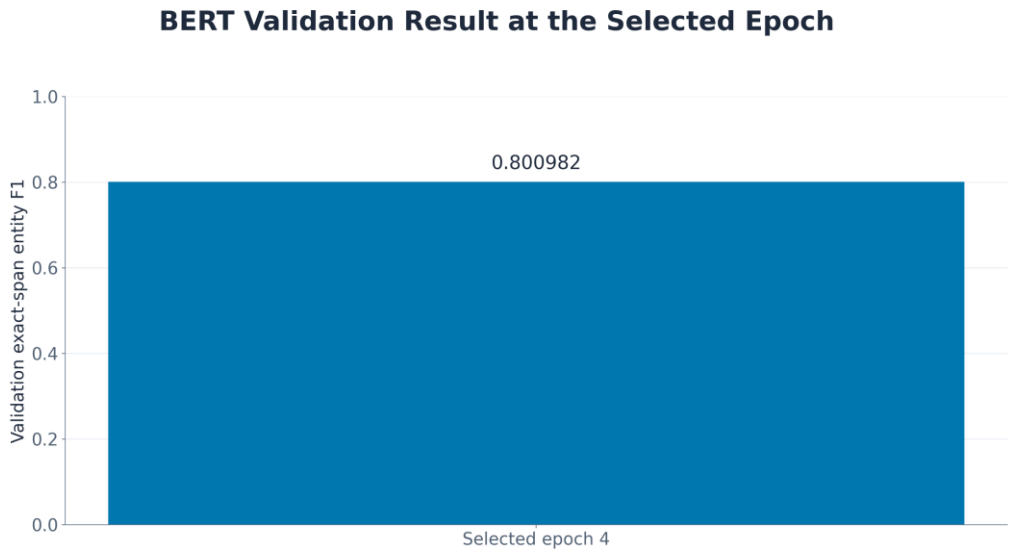


FigureC-2. BERT WordPiece supervision

Source: supplied paper-parity package. The WordPiece example illustrates BERT label assignment and is not an evaluation result.

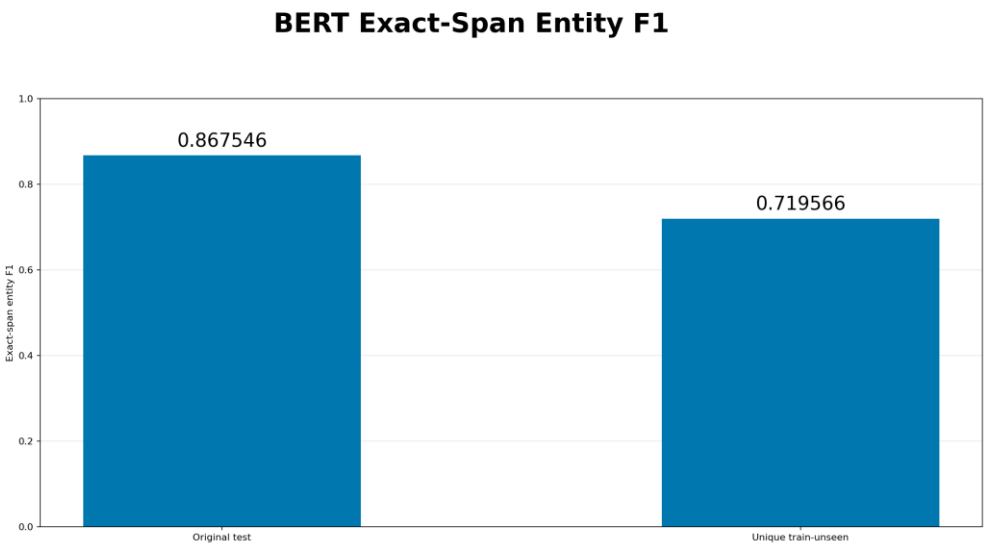
C.3 Training and Quality Gates

BERT completed four epochs and selected epoch 4 by validation exact-span entity F1 of 0.800982. Validation loss increased after epoch 3 while training loss decreased. On the 297 unique train-unseen sentences, BERT recorded 0.719566 F1. The report acceptance criterion is Unique Train Unseen > 70%, applied to F1 expressed as a percentage. The recorded result exceeds this threshold and is considered satisfactory. The measured F1 values are retained unchanged for comparison with the original-test results.



FigureC-3. BERT validation exact-span entity F1 at the selected epoch

Source: supplied 26 September 2026 paper-parity package; recorded BERT validation exact-span entity F1 at the selected epoch. Intermediate epoch scores are not reconstructed.



FigureC-4. BERT original-test and unique train-unseen F1

Source: supplied 26 September 2026 paper-parity package; recorded BERT original-test and unique train-unseen exact-span entity F1 values.

C.4 Captured Production and Benchmark Boundary

The authenticated production UI captured on 4 October 2026 for release 20260928T102847Z-ae9bf948 did not establish deployment of the adopted BERT model. The preserved model and report hashes remain historical evidence rather than proof of the model's later runtime state.

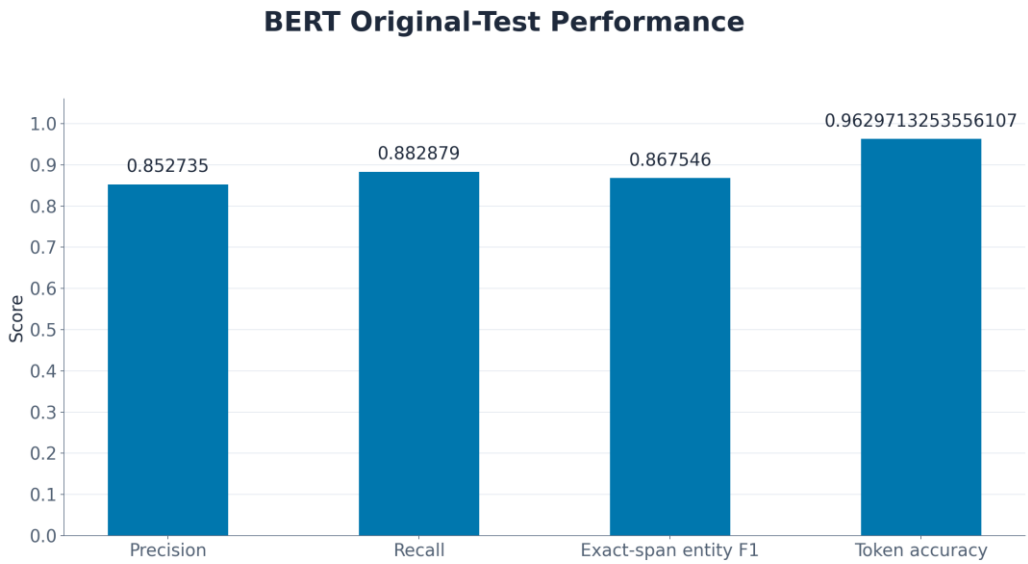
A bounded single-core CPU benchmark used six synthetic fixtures and 12 repeats for BERT (72 timed samples). It recorded mean warm latency of 230.06 ms, with peak process RSS near 799 MiB. Those fixtures produced zero entities at the configured threshold. The values demonstrate bounded contract and timing behavior on that fixture set, not representative live CTI semantic accuracy or production capacity. The package separately records schema-valid extraction on a 297-sentence public holdout and synthetic IoC input, without production records.

BERT was awaiting verified production promotion at the evidence-capture date. Before or during that transition, the documented dataset-integrity limitations require remediation, rerun, or explicit acceptance as appropriate. Operational verification additionally requires representative load, explicit state reporting, runtime error handling, immutable artifact

promotion, and a defined rollback. The supplied package documents no model cutover, restart, database change, or production record mutation.

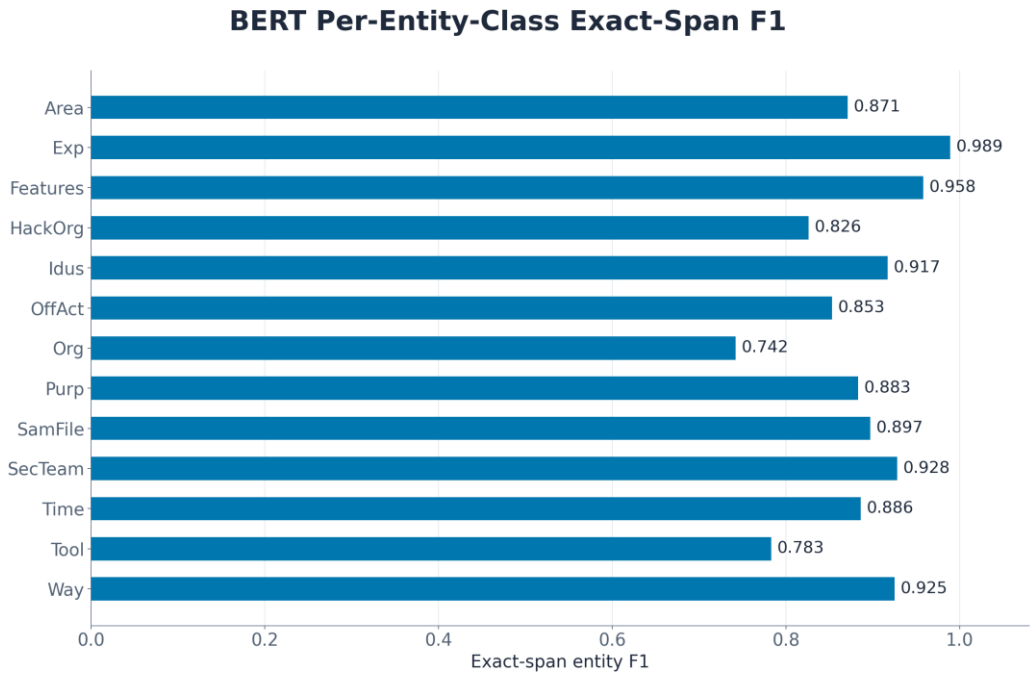
C.5 Supplementary Model Figures

Figures C-5–C-10 present the adopted BERT model at readable A4 size. They document original-test performance, class-level results, unique train-unseen acceptance, token-level results, the recorded validation-loss change, and bounded CPU training time. The figures use preserved numerical values and do not establish a production cutover.



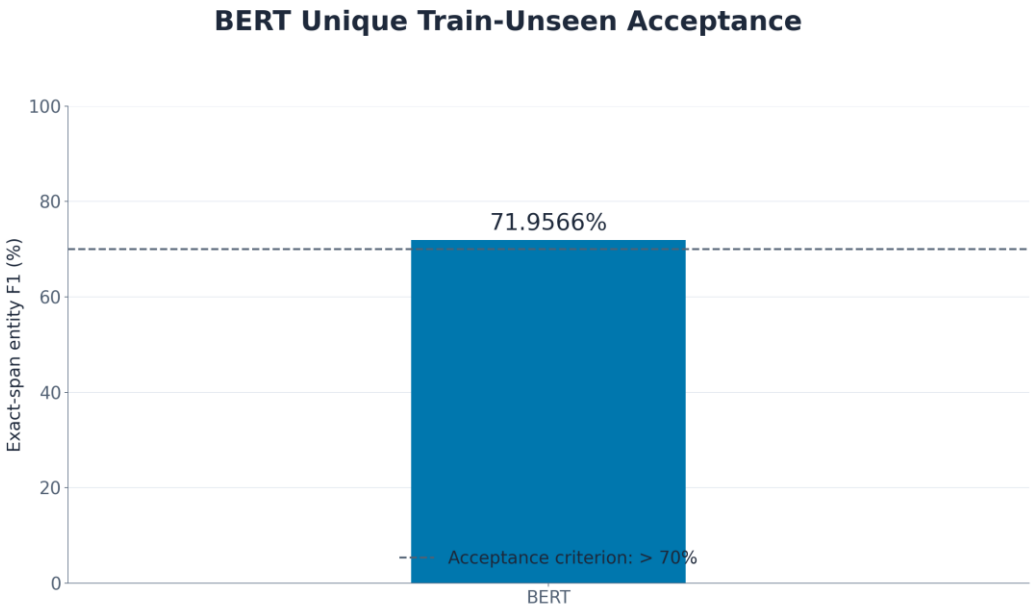
FigureC-5. BERT performance on the original test split

Source: supplied 26 September 2026 BERT package. Recorded original-test precision, recall, and exact-span entity F1 for the adopted model.



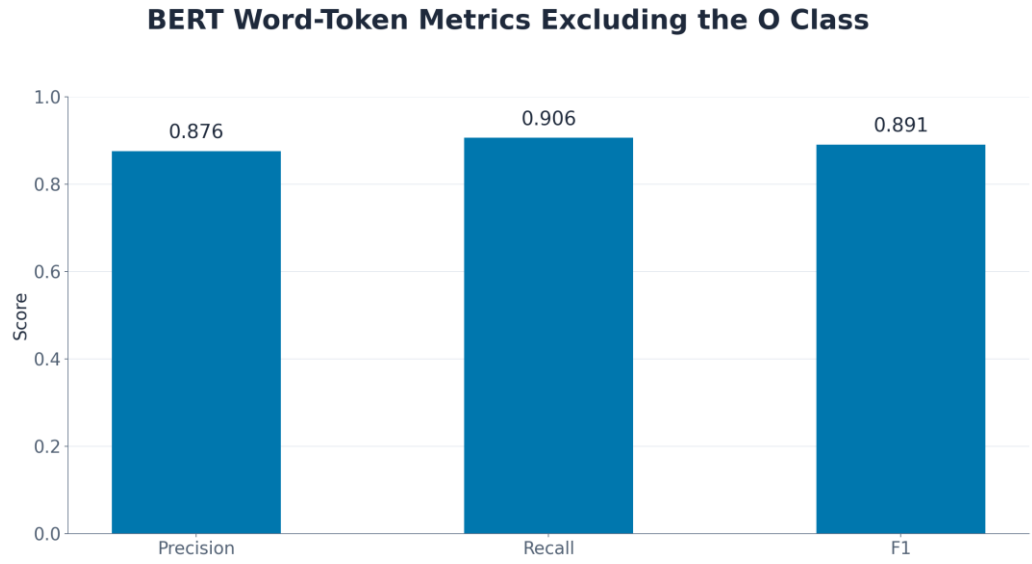
FigureC-6. Per-entity-class exact-span F1 for BERT

Source: supplied 26 September 2026 BERT package. Class-level outcomes vary. This chart comes from the recorded original split, which has train–test overlap.



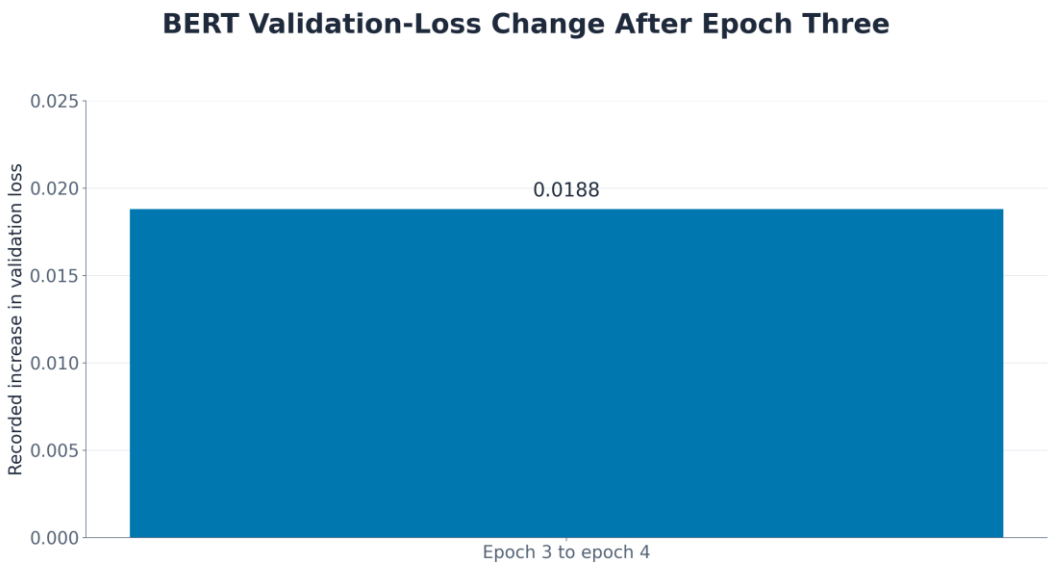
FigureC-7. BERT unique train-unseen acceptance criterion

Source: preserved BERT unique train-unseen F1 of 0.719566, assessed against the report acceptance criterion, Unique Train Unseen > 70%.



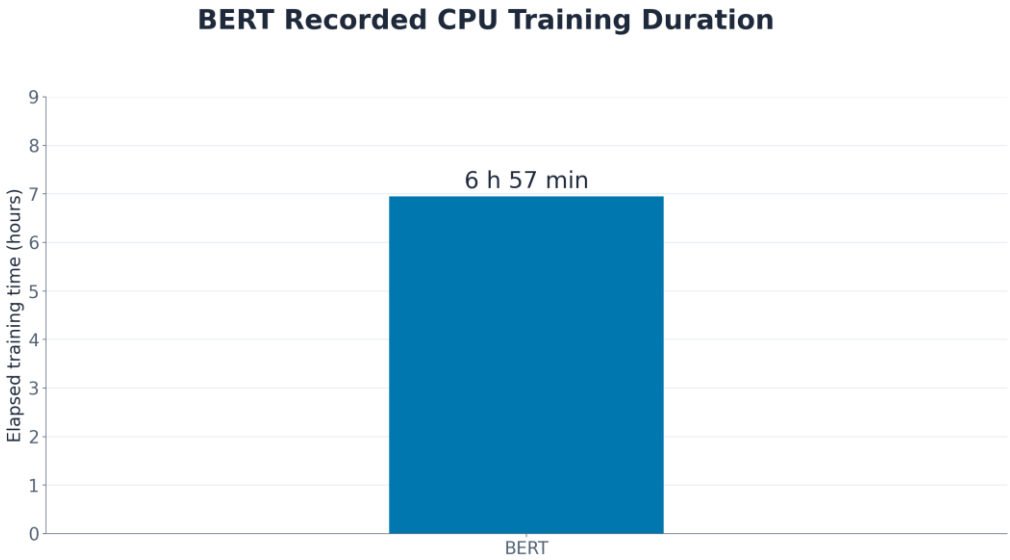
FigureC-8. Word-token metrics excluding the O class

Source: supplied 26 September 2026 BERT package. These token-level scores complement, but do not replace, exact-span entity micro-F1 and the unique train-unseen evaluation.



FigureC-9. BERT validation-loss change after epoch three

Source: supplied 26 September 2026 BERT package. The chart reports the recorded BERT validation-loss increase of 0.0188 after epoch three; intermediate loss values are not reconstructed.

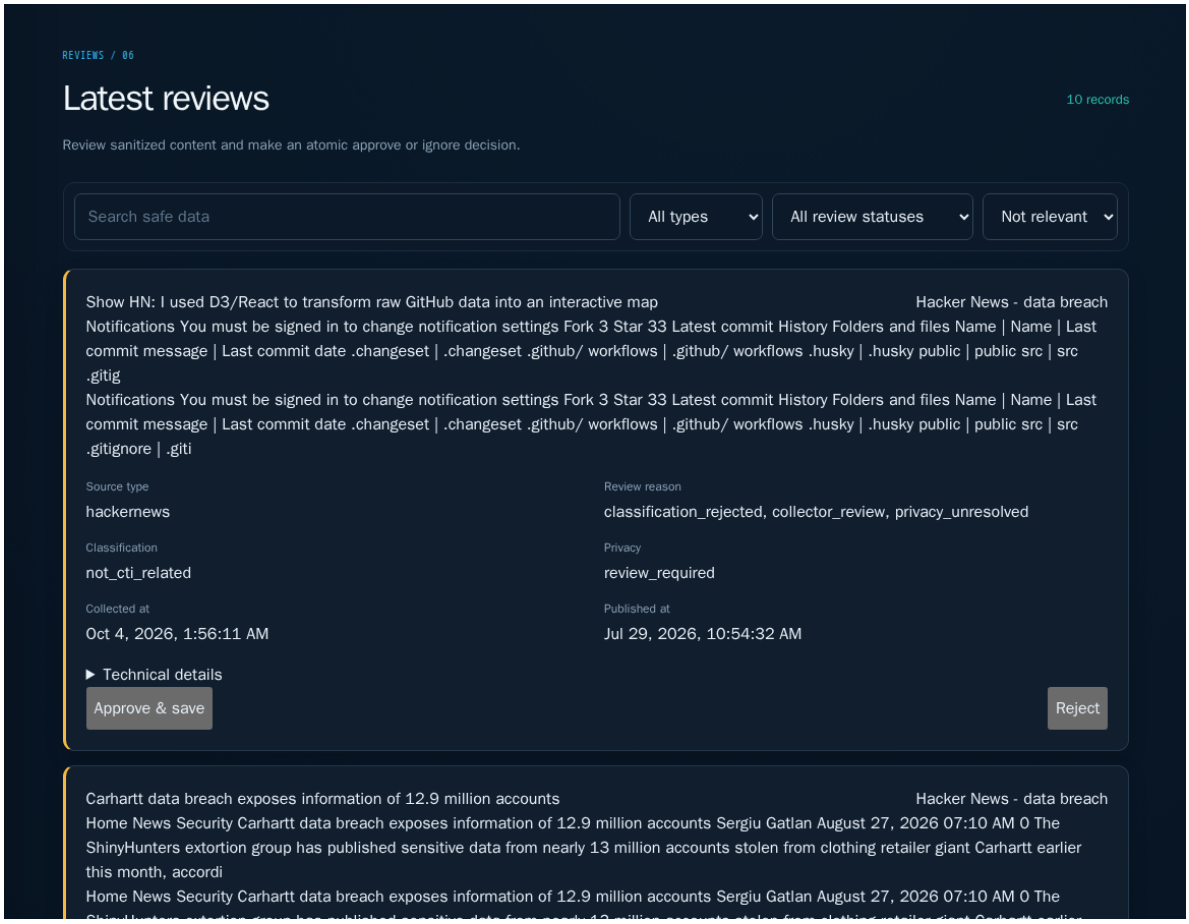


FigureC-10. Recorded CPU training duration for BERT

Source: supplied 26 September 2026 BERT package. Elapsed times are specific to the supplied VPS CPU experiment and are not live inference throughput.

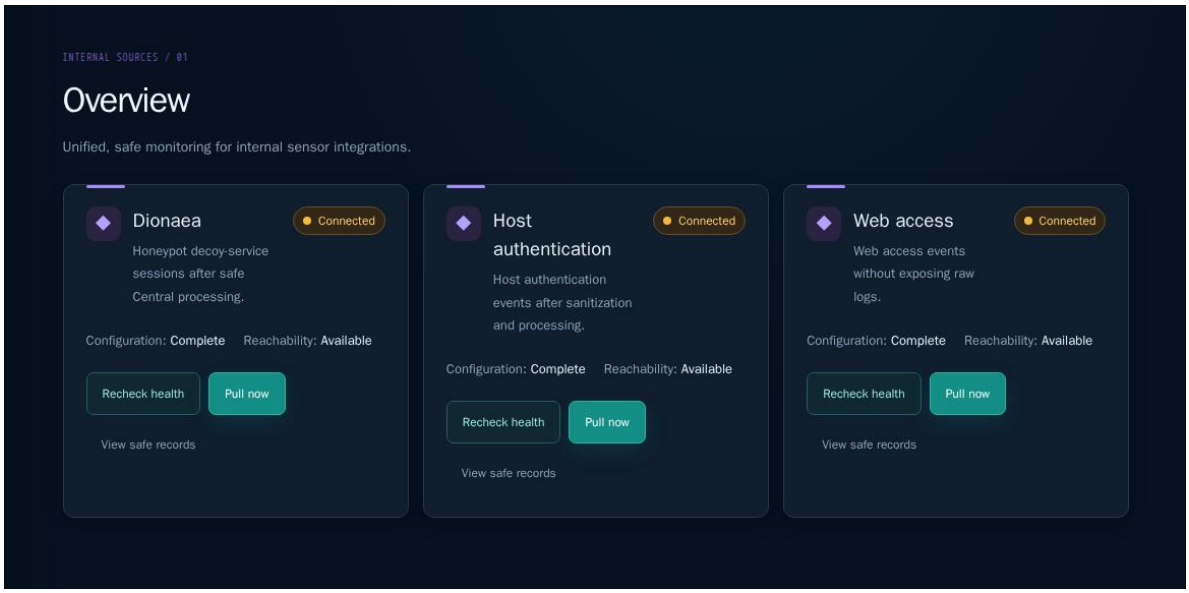
Appendix D: Supplementary Production Interface Evidence

These authenticated English/LTR screenshots supplement the main workflow evidence. They are dated production observations and do not imply that state-changing controls were used.



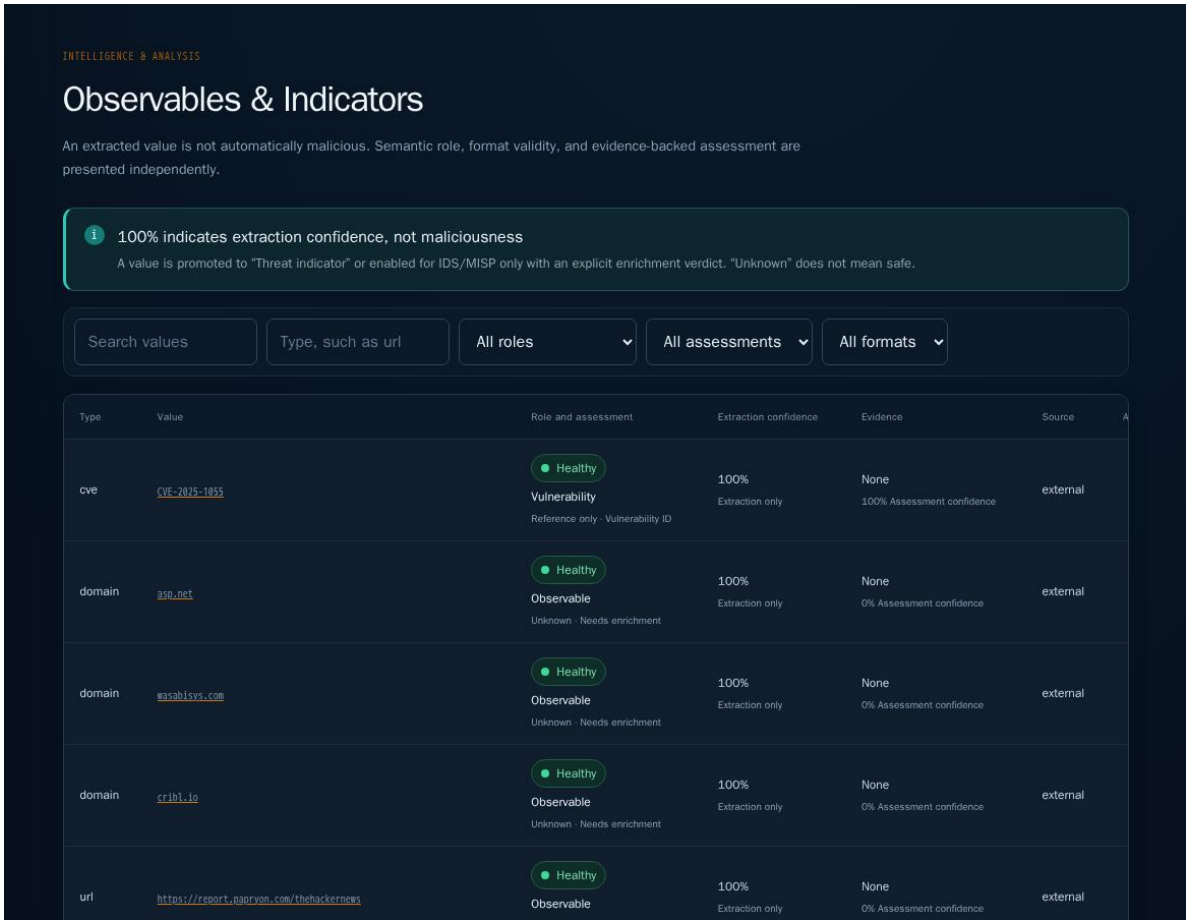
FigureD-1. Review governance queue

Appendix evidence only; no record was approved or rejected during capture.



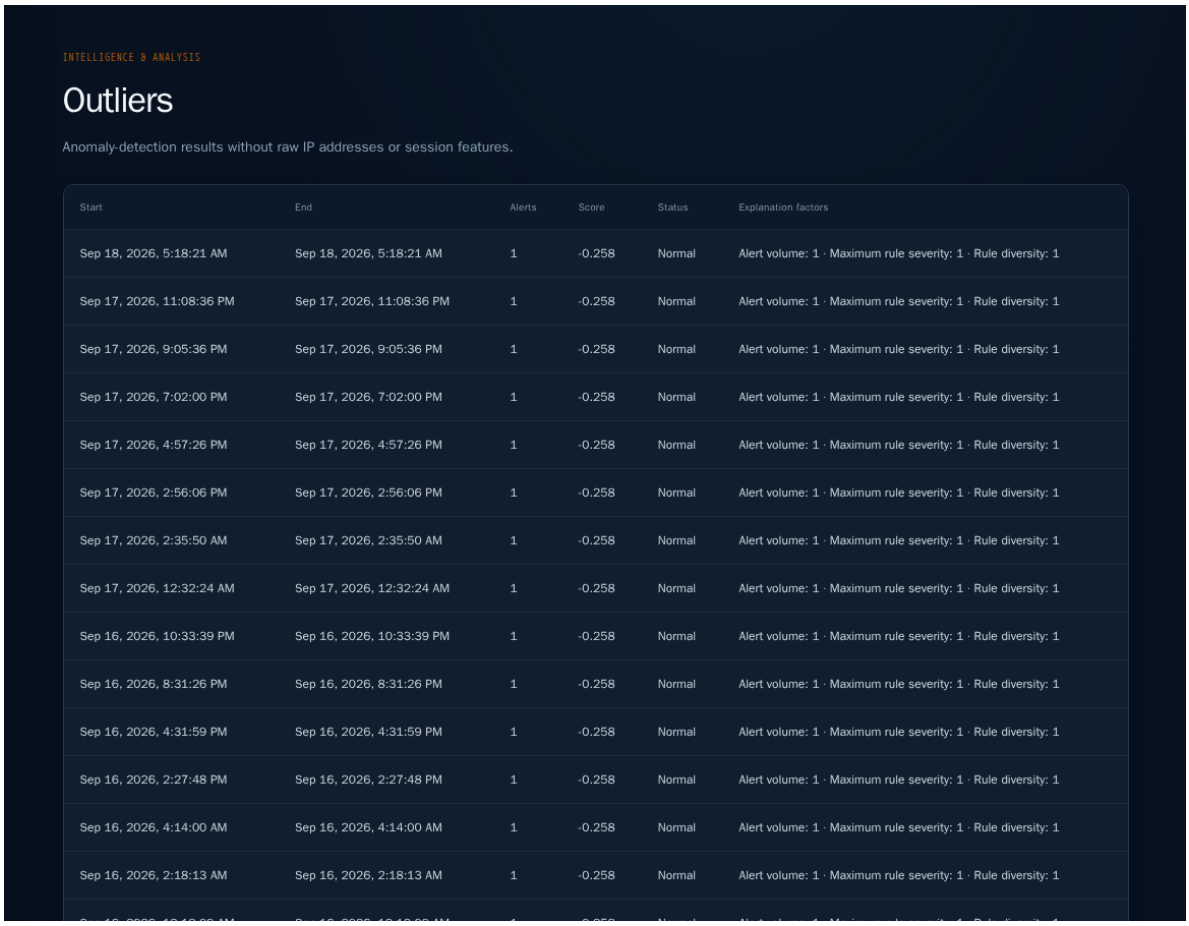
FigureD-2. Internal Sources overview

Appendix evidence of deployed Dionaea, host-authentication, and web-access integrations; pull controls were not used.



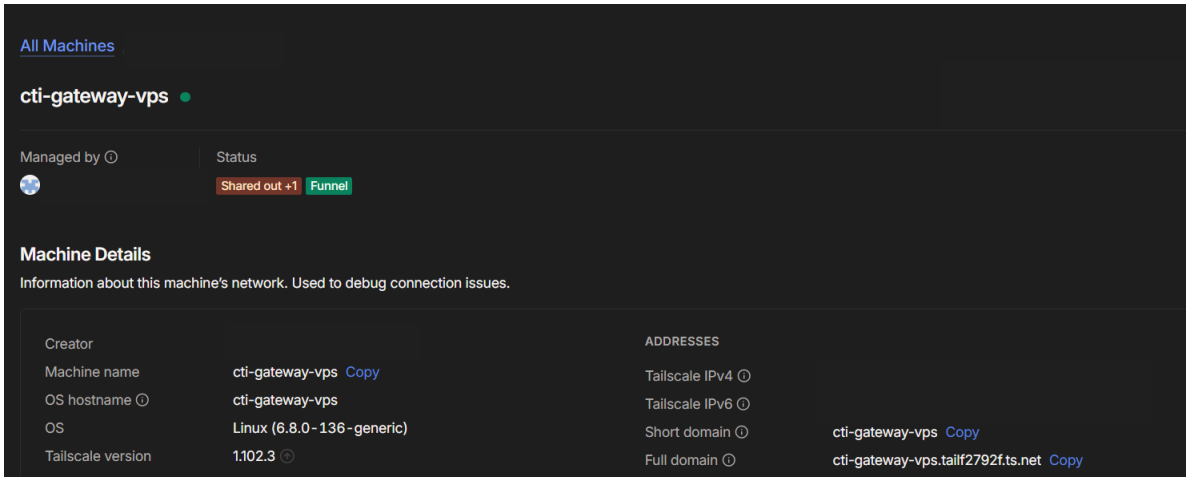
FigureD-3. Observables and Indicators

Appendix evidence that extraction confidence and format validity do not equal maliciousness.



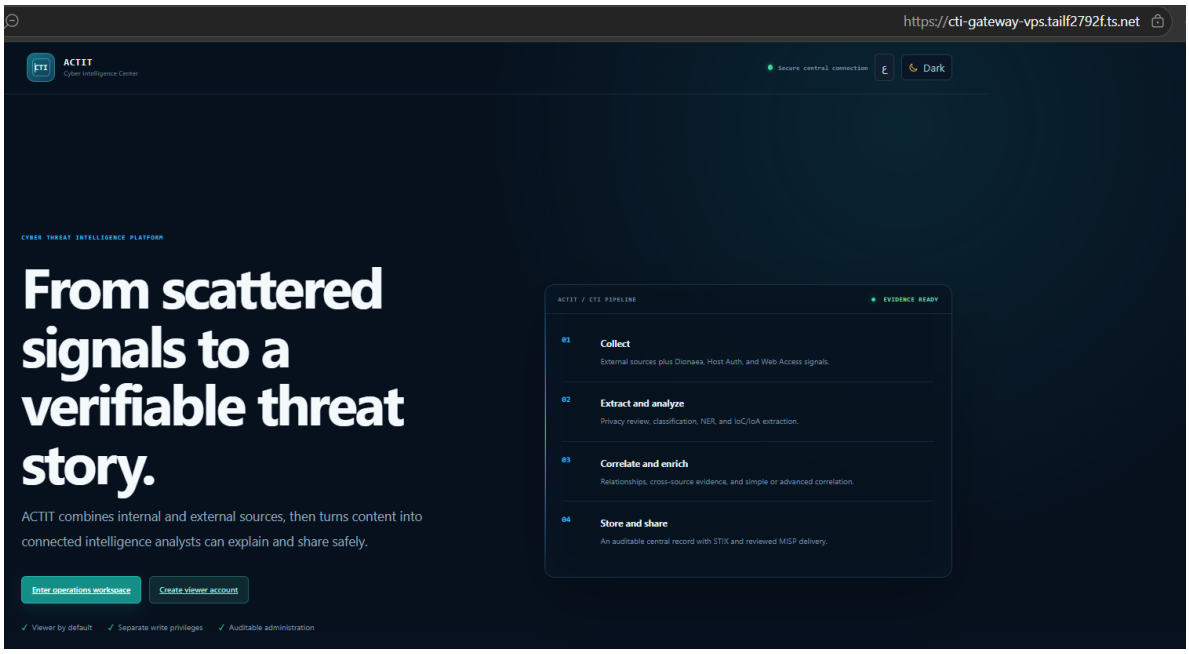
FigureD-4. Outlier Sessions

Appendix evidence of the result contract and explanations; visible rows are normal sessions and do not establish anomaly accuracy.



FigureD-5. Tailscale Funnel machine status for controlled public ACTIT defense access

Source and limitation: sanitized Tailscale administration view captured on 7 October 2026. It establishes the Funnel-enabled machine and public-domain state; it does not independently establish ACTIT authentication or direct backend exposure.



FigureD-6. ACTIT frontend reached through the public HTTPS Funnel endpoint

Source and limitation: public browser view captured on 7 October 2026. It establishes frontend reachability through the HTTPS Funnel URL; it does not establish authenticated user capabilities.